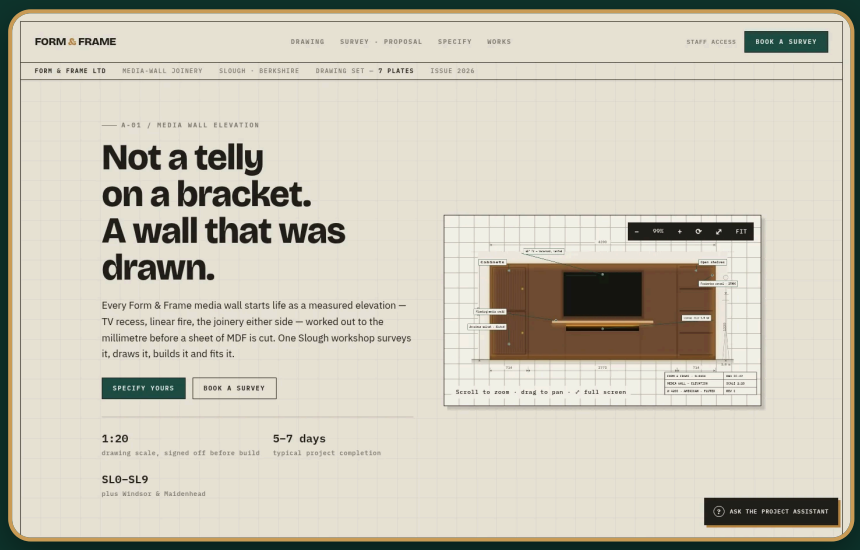
FORM & FRAME · MEDIA WALLS

Master Book

Identity, platform, public website, Owner Dashboard, backend, security, tests and roadmap, from the code, with evidence.



INTERNAL · CONTAINS SECURITY FINDINGS

Version 1.0.0 · 18 October 2026 · prepared by FRAME (Grok Bot) for Mark Ferrer Marquez

Analysed commit `31a08f6ee1fa507d4f78c30ede78c4b1fda746a4` (`origin/main`). Features that exist only in open Draft PRs are labelled PLANNED. Production and live Supabase were not accessed.

Contents

Introduction 5

What this is 5

How to read the status labels 5

Chapters 6

Draft PRs that are not part of main 6

Hosting the Live Master 6

Rebuilding 6

What this book does not claim 7

1. Identity and design system 8

1.1 Brand mark and logo 8

1.2 Colour: public website (index.html:21-56) 9

1.3 Colour: staff app (operations/styles.css) 10

1.4 Typography 11

1.5 Components (public site) 11

1.6 Components (staff app) 11

1.7 Responsive rules 12

1.8 Icons 13

1.9 Observations for the designer 14

2. Platform map and architecture 15

2.1 The platform on one page 15

2.2 Front end and back end 16

2.3 Vercel and CI/CD 17

2.4 Page-by-page map 17

2.5 Sequence: enquiry submit to notification 19

2.6 Sequence: staff sign-in 19

2.7 Sequence: invoice and manual payment 20

2.8 Owner Desk navigation 20

3. Public website 21

3.1 Navigation and title strip 23

3.2 A-01 Hero: "Not a telly on a bracket." 25

3.3 A-02 Survey vs proposal 26

3.4 A-03 Configurator "Build the drawing. Watch the price move." 27

3.5 A-04 Process and A-05 Completed works 28

3.6 A-06 Testimonials 30

3.7 A-07 Contact, form and footer 30

3.8 Project assistant 32

3.9 Mobile views of every section 34

3.10 Search, metadata and accessibility on main 35

3.11 Public-site status summary 35

4. Owner Dashboard (staff app, /operations/) 36

4.0 Modules at a glance 36

M1 Today 36

M2 Enquiries (Work) 36

M3 Enquiry workspace 36

M4 Quotes 36

M5 Jobs (work orders) 36

M6 Calendar and availability 36

M7 Appointments and follow-ups 36

M8 Invoices 36
M9 Payments (manual recording only) 36
M10 Money panel and finance strip 48
M11 Business settings (seller details) 49
M12 Notification centre and push 50
M13 Activity history 50
M14 Roles and access 50
State handling and errors (observed in code) 51

5a. Backend 52
Edge Functions (supabase/functions/) 52
Notification delivery 53
Authentication flow 54
Public build configuration 54
Storage 54

5b. Database (from supabase/migrations/) 55
Tables 55
Integrity rules enforced in the database 56
Row Level Security today 57
Scripts that are not migrations 57
Not in main (Draft PRs) 57

5c. Integrations 59
Stripe: absent, shown as planned 60
Pending configuration (Mark, 19 October 2026) 60

6. User journeys 61
6.1 Customer 61
6.2 Owner 62
6.3 Staff 62

7. Feature matrix 63

8. Security 68
8.1 Summary 68
8.2 Roles and the current permission model 68
8.3 Authentication and sessions 69
8.4 Client (customer) data protection 70
8.5 Secrets handling (names only) 70
8.6 Content-Security-Policy, headers, dependencies 70
8.7 Webhooks 70
8.8 Pending weaknesses (no exploit detail) 70
8.9 Payments and domain configuration (pending) 71

9. Testing and quality 72
9.0 How this book is built 72
9.1 Where each result comes from 72
9.2 CI replay on main (Node 24) 72
9.3 Draft PR suites (run locally on Node 24) 72
9.4 Test inventory on main 73
9.5 Gaps 73

10. Roadmap 75
10.1 P0 : before real money or more than one staff member 75
10.2 P1 75
10.3 P2 76

10.4 P3 *(proposed)* 76
10.5 Suggested order (FRAME recommendation, not a decision) 76

11. Pending confirmation and not verified 77
11.1 Needs Mark (owner decisions and content) 77
11.2 Could not be verified in this work 77
11.3 Observations to confirm 78

12. Coverage summary 79
12.1 What is documented 79
12.2 Screenshots and diagrams 79
12.3 Tests 80
12.4 Not covered 80

Evidence inventory 81

Changelog 85
1.0.0 : 18 October 2026 85

Diagrams

Diagram 1: Platform map: public site, forms, backend, Supabase, Owner Desk, quotes, payments, notific 4
Diagram 2: Front end and back end: browser, Vercel static hosting, Supabase 4
Diagram 3: Build and hosting on Vercel 4
Diagram 4: CI: 17
Diagram 5: Sequence diagram: enquiry submission to notification 19
Diagram 6: Sequence diagram: staff sign-in 19
Diagram 7: Sequence diagram: invoice and payment 20
Diagram 8: Owner Desk navigation 20
Diagram 9: Edge Functions: callers, authentication, secrets (names only), data touched 52
Diagram 10: Notifications pipeline 53
Diagram 11: Staff sign-in and access check 54
Diagram 12: Database map: tables and foreign keys, from the migrations 55
Diagram 13: RLS today versus the proposal in PR #23 57
Diagram 14: Stripe: not implemented (design only) 60
Diagram 15: Customer, owner and staff journeys 61
Diagram 16: Roadmap P0 to P3 with issue and PR numbers 75

SECTION 01

Introduction

Version 1.0.0 (draft for owner review) · 18 October 2026 · prepared by FRAME (Grok Bot) for Mark Ferrer Marquez

> **Commit analysed:** `31a08f6ee1fa507d4f78c30ede78c4b1fda746a4` (`origin/main`, "Fix Android status-bar icon: immediate worker takeover, monochrome manifest icons, verified FF badge", 16 Oct 2026). Repository: `mfm2712-droid/form-and-frame-media-walls2`. Tracking issue: **#44**. Everything in this book describes that commit. Work that exists only in open Draft PRs is labelled as such and is never described as part of the product today.

What this is

The Master Book is the single, evidence-based description of the Form & Frame platform: the public website, the staff **Owner Desk** (`/operations/`), the Supabase backend, the security posture, the tests, and what is still missing. It is written from the code, and every factual claim points to a row in the Evidence Inventory (file and line, or the command that was run).

It has three renderings of the same source (`docs/master/*.md`):

Rendering	File	Use
Editable source	`docs/master/*.md`, `docs/master/assets/`	Edit here. Update when routes, features or architecture change.
Book (PDF)	`FORM_AND_FRAME_MASTER_BOOK.pdf`	Print / hand-over.
Live Master (static HTML)	`docs/master/live/` (`FORM_AND_FRAME_LIVE_MASTER`)	Side menu, client-side search, zoomable images. **Internal only: see Hosting the Live Master.**

How to read the status labels

Only these seven statuses are used for features. Implemented is not the same as verified.

Status	Meaning in this book
`IMPLEMENTED`	Code for it exists on `main`. No test or observed run proves that it works.
`VERIFIED`	Implemented **and** proven by a named automated test, or by a run observed while writing this book (named in the row).
`PARTIAL`	Part of the capability exists on `main`; the missing part is stated.
`BROKEN`	Observed or proven to behave wrongly, or a confirmed gap with a known bad effect.
`PLANNED`	Not on `main`. May have a design or code in an open Draft PR (named) but it is not part of the product today.
`NOT IMPLEMENTED`	No code anywhere; may be wished for or absent by design.
`BLOCKED`	Cannot proceed until an owner decision or an external action.

Other conventions: **DEMO MODE** screenshots use the staff app's built-in fictional data and are captioned as such. A screen that needs a real sign-in or live Supabase data is marked **not verifiable** and is never mocked. "Pending Mark" marks content or facts only the owner can confirm.

Chapters

1. Identity and design system: colours, fonts, components, responsive rules, from the CSS.
2. Platform map and architecture: how the pieces connect, page by page.
3. Public website: every section, with screenshots and placeholders flagged.
4. Owner Dashboard: every implemented module.
5. Backend, Database, Integrations: functions, tables, third parties, Stripe (absent).
6. Journeys: customer, owner, staff, with broken steps marked.
7. Feature matrix: feature, route, component, backend, status, tests, dependencies, issue, PR, version.
8. Security: roles, financial access, RLS, sessions, secrets handling, CSP, pending findings.
9. Testing and quality: what was run, local vs Preview vs production.
10. Roadmap: P0 to P3 linked to issues and PRs.
11. Pending confirmation, Coverage summary, Evidence inventory, Changelog.

Draft PRs that are not part of `main`

Open Draft PRs at the time of writing (state read from GitHub on 18 Oct 2026): #19 master project doc, #20 auth tests, #22 notification retry cap draft, #23 permission matrix and RLS draft, #25 Stripe design, #26 public site unpublish-unvalidated-works, #27 self-hosted supabase-js and CSP report-only, #41 server-side numbering draft, #42 role-aware money UI, #43 payment reversals draft; plus PR #8 (ready for review, not a draft; audit fixes) and PR #1 (draft, older Today/push fixes). **None of these is merged. This book does not merge, deploy or apply anything.** The roadmap chapter lists what each one adds.

Hosting the Live Master

The Live Master contains internal architecture, security findings and product decisions. It is **not hosted anywhere** and must not be published on an open URL. It is delivered as a static build in `docs/master/live/`. To use it:

1. Preferred: serve it only behind authentication, for example a Vercel project with Vercel Authentication / password protection enabled, a Cloudflare Access application, or an internal web server behind SSO or HTTP basic auth.
2. Local only: open `docs/master/live/index.html` from disk, or run `npx serve docs/master/live`. It makes no network requests.
3. Never place it inside `dist/public` or in the public site's Vercel project: `scripts/build-public.mjs` copies only an explicit allow-list of files, and `docs/` is not on it (see Evidence `E-21`), so the Live Master stays out of the public build unless someone changes that script.

Rebuilding

```
# Node 24, Google Chrome (for the PDF only). No network is used.
node scripts/master-docs/diagrams.mjs      # regenerates assets/diagrams/*.svg
node scripts/build-master-docs.mjs         # builds the Live Master + the PDF + the evidence inventory
```

Details, options and the screenshot-capture procedure are in testing.md.

What this book does not claim

It does not claim anything about the production Supabase project, the Vercel dashboard or the live site beyond what the repository proves. The pending-confirmation chapter lists everything that could not be verified.

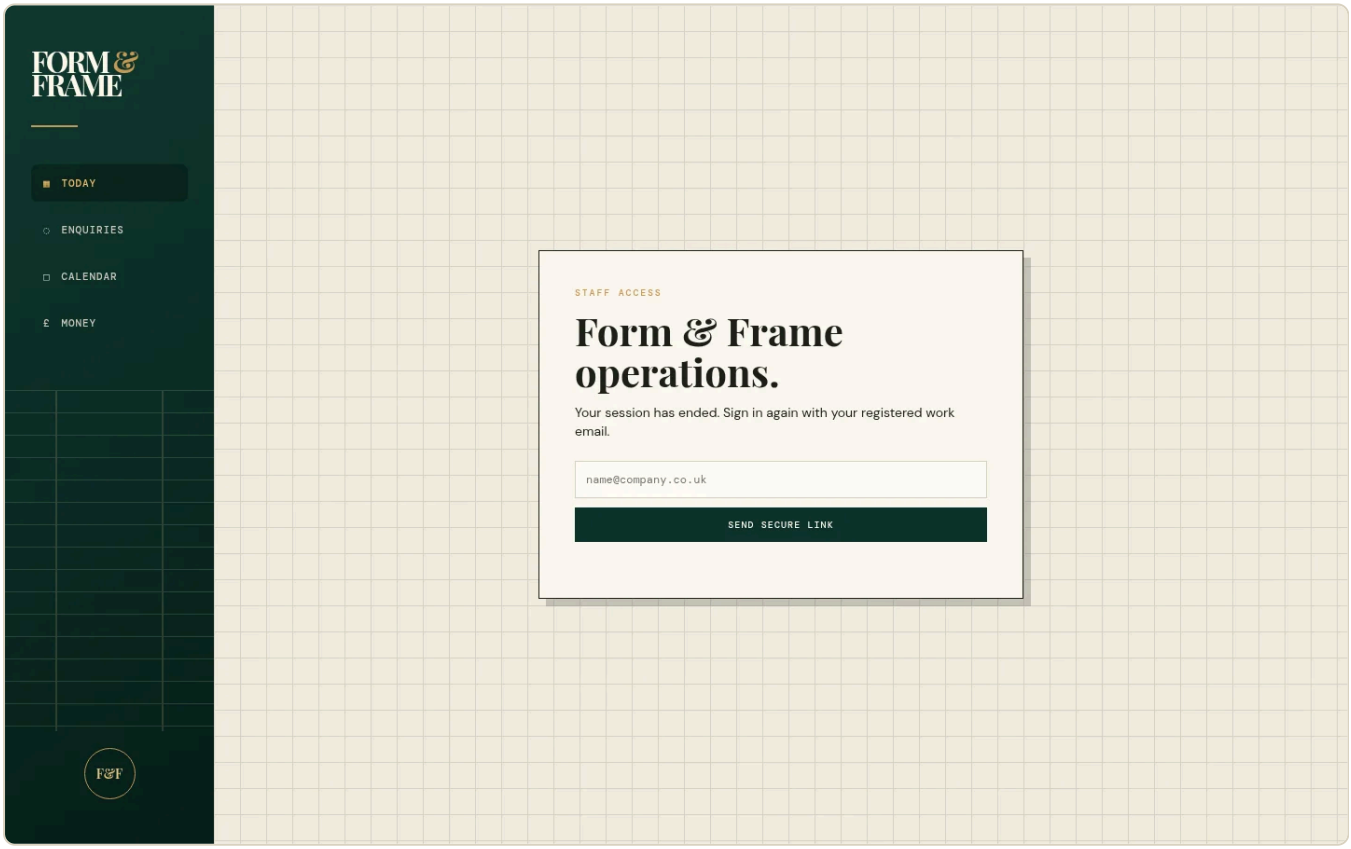
SECTION 02

1. Identity and design system

Everything here is read from the code at `31a08f6`: colours and fonts from the CSS custom properties, components from the class rules. Nothing is invented. The most important finding: **the repository contains two visual languages**, one for the public site and one for the staff app, and they share a brand mark but not tokens or fonts.

1.1 Brand mark and logo

- **Public wordmark**: text `FORM & FRAME` in Bricolage Grotesque 800 at 19 px, with the ampersand in oak (`.mark b{color:var(--oak)}`, `index.html:138-139`). No image logo file exists for the public site. [`E-24`]
- **Staff wordmark**: stacked `FORM & FRAME` in Playfair Display 700 at 31 px, ampersand in gold (`operations/styles.css`, `.brand`). A round **F&F** monogram badge (55 px circle, gold border) sits at the bottom of the sidebar. [`E-25`]
- **App icon** (`operations/icon.svg`): a 512 px rounded square `#0e342c` containing a cream (`#f1ecdf`) shelving frame with a gold (`#c99b55`) centre bar. Raster variants: `icon-180.png`, `icon-192.png`, `icon-512.png`, `icon-maskable-192.png`, `icon-maskable-512.png`. [`E-27`]
- **Notification badge**: monochrome `FF` mark, `notification-badge-ff.png` and `notification-badge-ff-192.png`. [`E-27`]



Staff sign-in screen with the Playfair Display wordmark, round F&F badge and card (built site, fictional configuration; no sign-in attempted)

1.2 Colour: public website (`index.html:21-56`)

Paper
`#E6E1D5`
page background (drafting-paper putty)

Paper 2
`#EEEADF`
alternate surface

Paper 3
`#F4F1E8`
cards, forms, nav button text

Frame
`#211F1A`
text, borders, shadows (graphite)

Ink
`#1E4D45`
primary action, links, focus ring (workshop green)

Ink 2
`#2E6A5E`
secondary green

Oak
`#B4823F`
accent, ampersand, step numbers (oak timber)

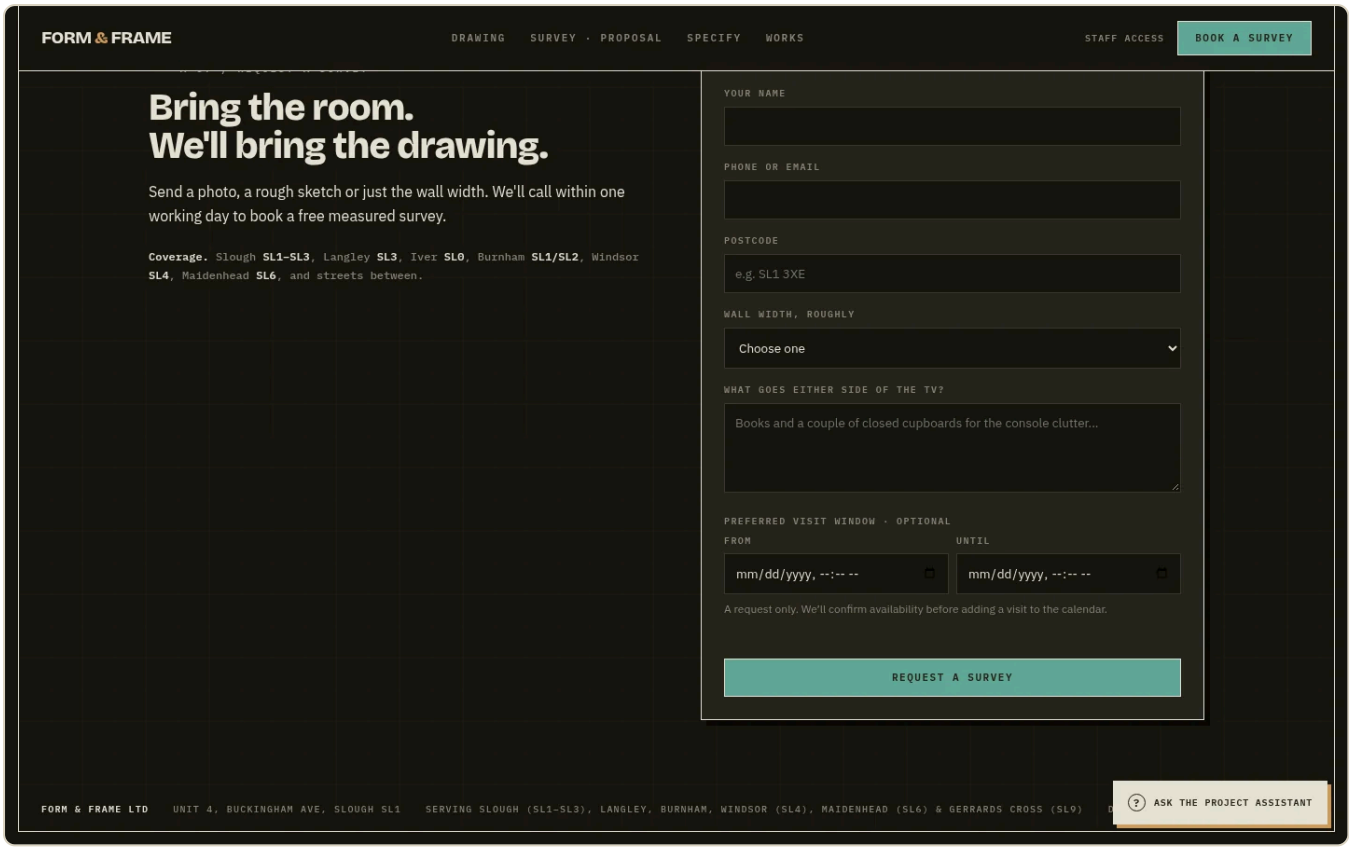
Pencil
`#7C766A`
secondary text

Pencil 2
`#B8B2A2`
grid lines, hairlines

Glow
`#D2892A`
warm-light semantic only (amber)

Bad
`#9E3B2C`
error and validation

A dark theme exists and follows `prefers-color-scheme: dark` (or `data-theme="dark"`): paper `#16160F`, paper 2 `#1E1E16`, paper 3 `#26251C`, frame `#E7E2D5`, ink `#63A997`, ink 2 `#83C7B4`, oak `#CE9C5F`, pencil `#8C8577`, pencil 2 `#3B3A30`, glow `#E7A63F`, bad `#D8705E`. Observed rendering of the dark theme:



Public site fold in dark colour scheme (emulated prefers-color-scheme: dark), 1440 px

1.3 Colour: staff app (`operations/styles.css`)

Paper
`#F1ECDF`
app background

Card
`#FBF8F0`
panels and cards

Ink
`#1D211C`
text

Green
`#0E342C`
sidebar, primary buttons, headings (gradient #123B32 to #071F1A in the sidebar)

Gold
`#C99B55`
accent, new-enquiry status, "next step" border

Line
`#D9D1BF`
hairlines

Muted
`#766F63`
secondary text

Red
`#A84137`
blocked, errors

Status colours (workflow badges): new `#c99b55`, opened `#0e342c`, quoted `#2d4a5c`, accepted `#2f7d4f`, in progress `#a8531c`, completed `#0e342c`, archived `#766f63`. Notice banners: error `#b84f42` border on `#fff1ed`, success `#6f9877` on `#edf6ec`, warning `#c99b55` on `#fff7e7`.

1.4 Typography

Role	Public site	Staff app
Headings	**Bricolage Grotesque** 800, tight tracking (`-.02em`), line-height 1.02, balanced wrapping	**Playfair Display** 600/700 serif
Body	**IBM Plex Sans** 400, 16 px/1.62	**DM Sans** 400–600, 14 px/1.45
Labels, buttons, data	**IBM Plex Mono** 500–600, 10–11 px, uppercase, letter-spacing .09–.16em	**DM Mono** 400–500, 9–11 px, uppercase

Both sites load their web fonts from `fonts.googleapis.com` (`index.html:15` , `operations/index.html:15`). [`E-24`] This is a third-party request at page load and an item for the CSP work (see Security). **For this book**, the fonts are installed locally on the build machine, so the PDF uses the real brand fonts for the public brand (Bricolage Grotesque, IBM Plex Sans/Mono); the book's own chrome uses the public-site tokens. The Live Master references the same families without loading them from the network and falls back to system fonts on machines that do not have them installed.

1.5 Components (public site)

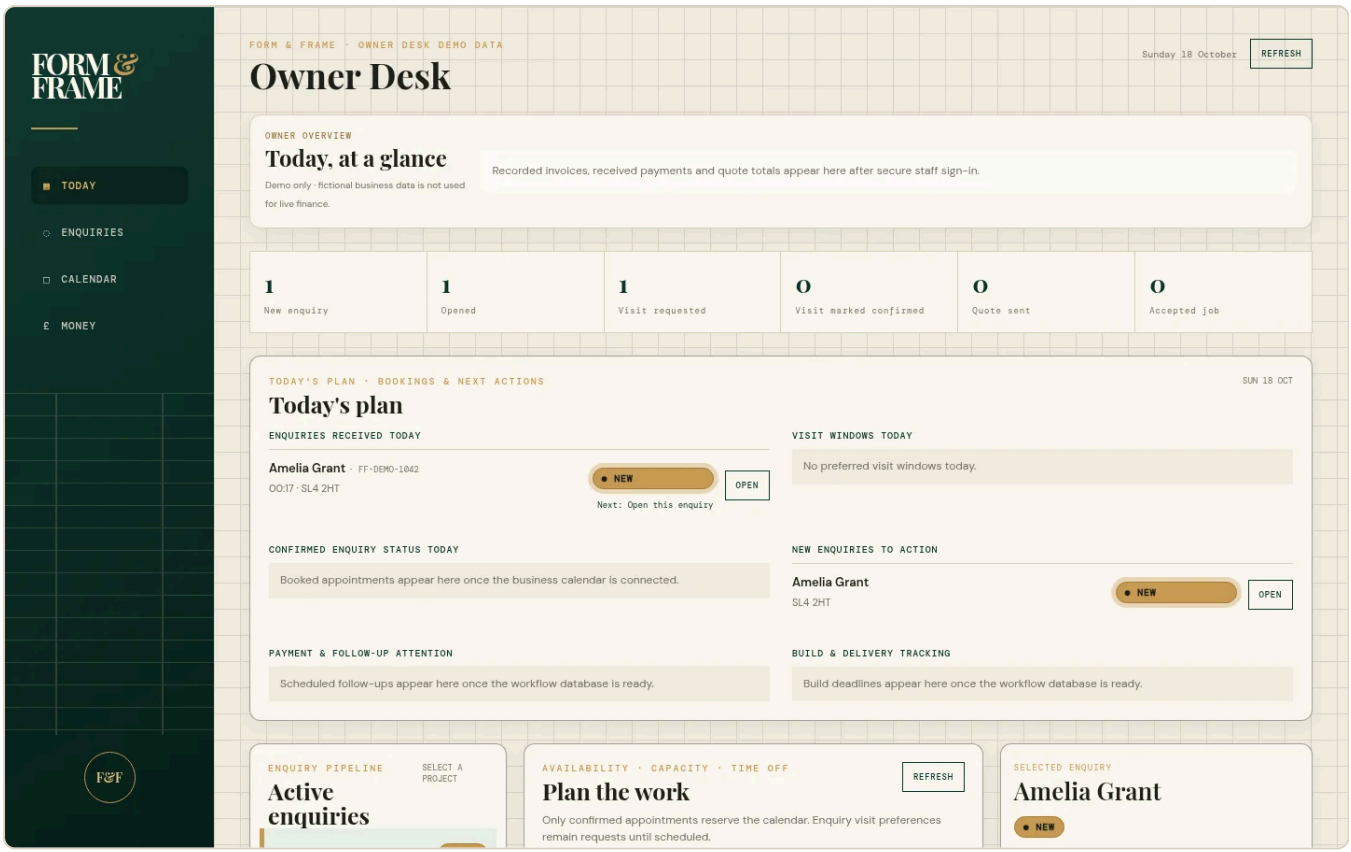
Component	Rule (from CSS)
Button `.btn`	Square corners (`border-radius:0`), 1 px frame border, Ink fill, Paper 3 text, IBM Plex Mono 11 px uppercase, `.14em` tracking, padding 12x18. Hover lifts 1 px with a 3 px hard shadow; active presses down. `.btn.ghost` is transparent; `.btn.sm` 9x12 padding; disabled at 40% opacity. (`index.html:145-157, 277`)
Sheet frame `.sheet`	1 px frame border, 14 px margin, a 34 px drafting grid built from two linear gradients in Pencil 2.
Plate `.plate`	Section wrapper, 72 px vertical padding, 1 px frame bottom rule. Sections are titled "A-01" to "A-07" like drawing plates.
Content width `.wrap`	max-width 1180 px, 24 px side padding; `.prose` 58ch.
Eyebrow `.eyebrow`	Mono label preceded by a 26 px hairline.
Card styles	`.work` , `.step` , `.testimonial` , `.form` : 1 px frame border on Paper 3 with a **hard offset shadow** (4 px or 6 px, `var(--shadow)` = `rgba(33,31,26,.16)`), no blur and no radius.
Form `.form`	Paper 3, 24 px padding, 6 px hard shadow; rows with 16 px bottom margin; labels mono uppercase; error text in Bad colour; honeypot field hidden.
Chip `.chip`	Square selection tiles in the configurator, focus ring 2 px Ink at 3 px offset, disabled 32% opacity.
Focus	Global `:focus-visible{outline:2px solid var(--ink);outline-offset:3px}` .

Spacing is not a token scale; values are literal (4, 6, 8, 12, 14, 16, 18, 20, 24, 26, 34, 72 px recur). Borders are always 1 px solid frame; shadows are always hard offsets. Motion is limited to 120 ms transforms and is disabled by `@media (prefers-reduced-motion:reduce)` (`index.html:659`).

1.6 Components (staff app)

Rounded 12 px cards (`border-radius:12px`) on `#fbf8f0` with a soft shadow `0 5px 16px rgba(28,41,34,.06)` , and the "Today" and "Business" panels use a 1 px translucent ink border with a 4 px hard shadow. Status pills are 999 px radius mono badges. Primary buttons (`.ws-primary`) are `#0e342c` with `#fff8ea` text, 9 px radius, 44 px

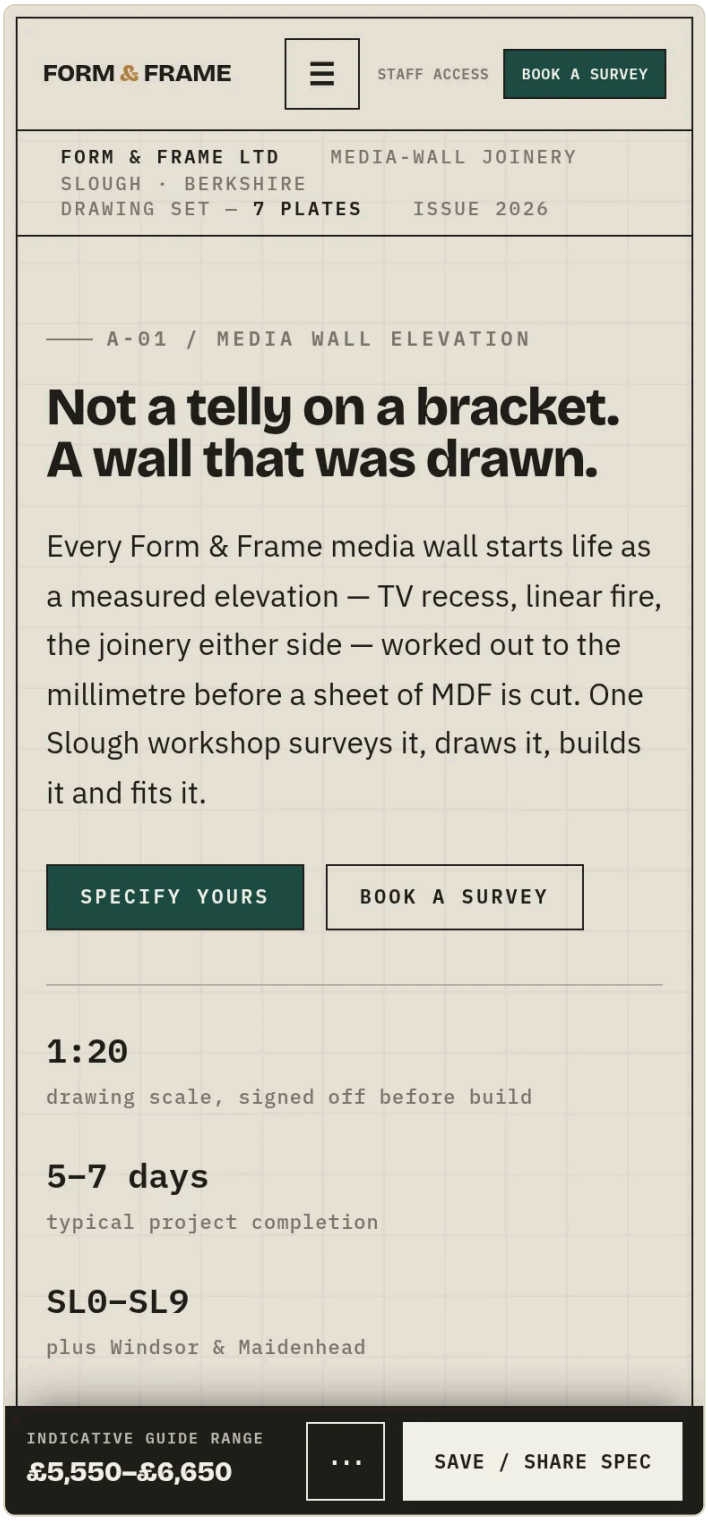
minimum height. The workspace uses a 10-step stepper and a gold-bordered "Next step" card. A fixed bottom navigation bar with four items (Today, Work, Calendar, Money) appears under 760 px.



Staff app on desktop 1440 px. DEMO MODE — fictional data, not production.

1.7 Responsive rules

Surface	Breakpoints in the CSS
Public site	`max-width:900px` (navigation collapses to a toggle, multi-column grids stack), `max-width:560px` (visit-window fields stack), `min-width:901px` (configurator side-by-side), `hover:none` (touch adjustments), `prefers-reduced-motion`, `prefers-color-scheme`
Staff app	`max-width:1120px` (metrics 6 to 3 columns, Today columns stack), `max-width:900px`, `max-width:760px` (sidebar becomes a top bar, bottom nav appears, metrics 2 columns, cards single column, notification panel full width)



Public site on a 390 px phone, fold

1.8 Icons

There is no icon library. Navigation icons in the staff app are Unicode glyphs (▦ ◌ ☐ £, ⌂ ▤), the bell is an emoji, and the configurator draws its elevation as inline SVG generated in JavaScript. [E-25]

1.9 Observations for the designer

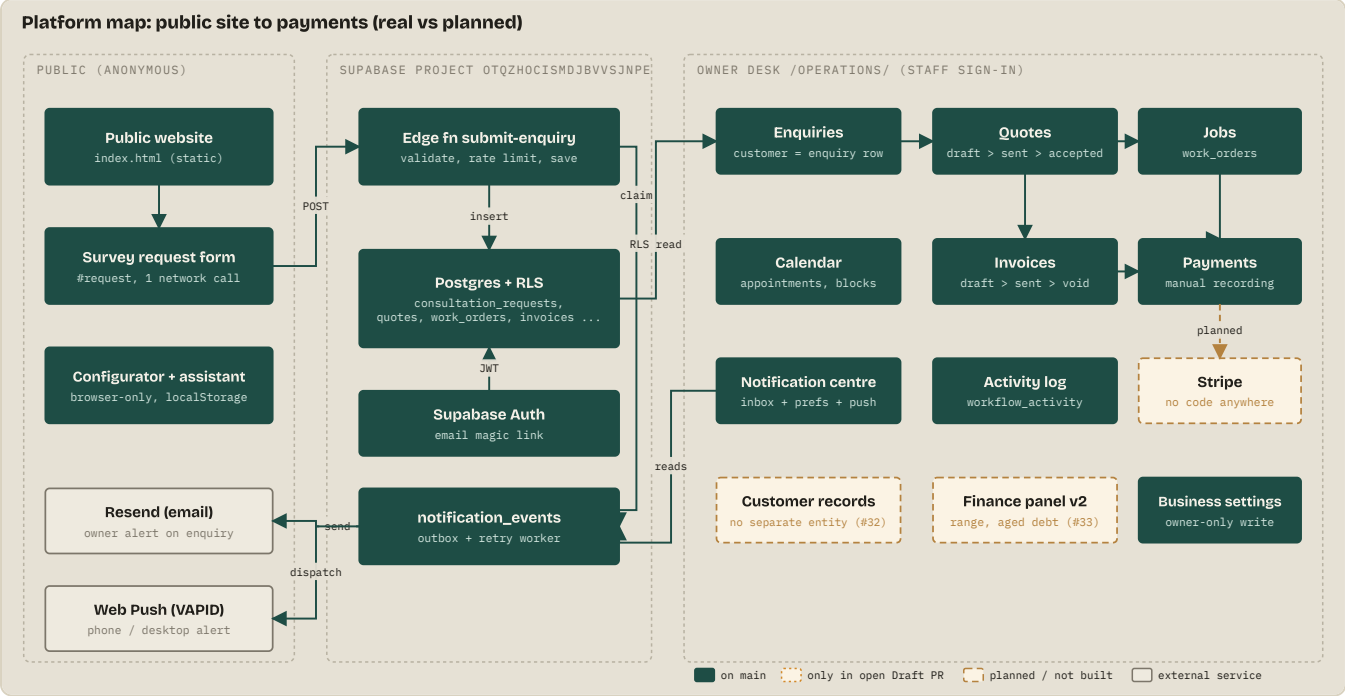
- Two palettes and two font stacks (green `#1E4D45` vs `#0E342C`, oak `#B4823F` vs gold `#C99B55`, Bricolage/Plex vs Playfair/DM). Unifying them is a decision for the owner; this book documents both as built.
- The public tokens carry a full dark theme; the staff app has none.
- The public site has no image logo, so a favicon and social image rely on `operations/icon.svg` and a project photo (see Website).

SECTION 03

2. Platform map and architecture

2.1 The platform on one page

Form & Frame is a **static website plus a static staff web-app (PWA), both served by Vercel, talking directly to one Supabase project** (`otqzhocismdjbvvsjnpe`, pinned in `scripts/public-config.mjs` and `supabase/config.toml`). There is no application server, no framework and no bundler: `index.html` has inline CSS and JavaScript, and `/operations/` is plain ES modules. [`E-21`] [`E-18`]



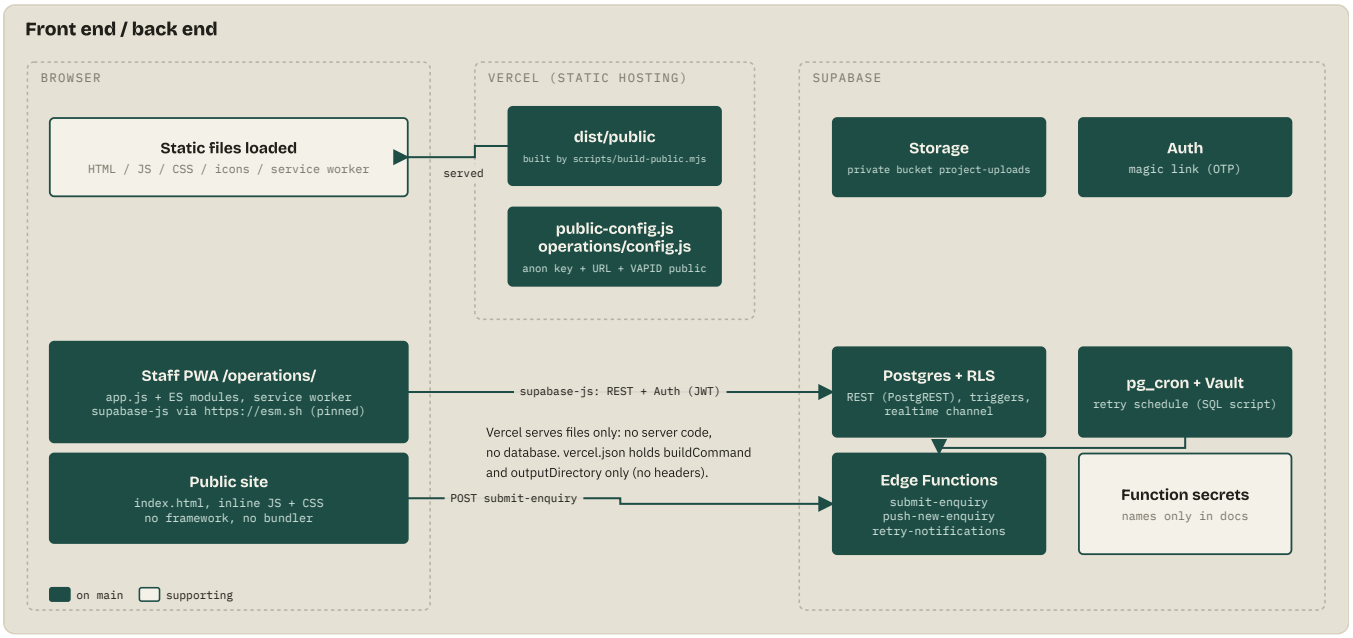
Platform map: public site, forms, backend, Supabase, Owner Desk, quotes, payments, notifications. Green = on main; dotted amber = only in a Draft PR; dashed oak = planned

The chain the owner asked about, with its real status on `main`:

Link	Status on `main`	Notes
Public site to form	VERIFIED UI observed; validation messages screenshot	The form is the only network call from the public site (one `fetch`, `index.html:2837`). [`E-05`]
Form to backend (Edge Function)	VERIFIED by 27 offline handler tests	Not observed live: the live Supabase project was not contacted.
Backend to Supabase DB	IMPLEMENTED	Migrations exist; the live schema state is not verified (see pending).
DB to Owner Desk	IMPLEMENTED	Staff PWA reads through supabase-js with the staff JWT and RLS.
Owner Desk: enquiries to quotes to jobs to invoices to payments	IMPLEMENTED	Pure logic is VERIFIED by tests; the screens need a live login and are **not verifiable** here.
Clients	PARTIAL	There is **no separate customer entity**: the customer is the enquiry row (`consultation_requests`). Issue #32.

Link	Status on `main`	Notes
Notifications	`IMPLEMENTED`	Internal alert e-mail (Resend), Web Push, an in-app notification centre; no customer-facing messages.
Online payments (Stripe)	`NOT IMPLEMENTED`	Only a `stripe` value in a column check. [`E-17`] Design in Draft PR #25.

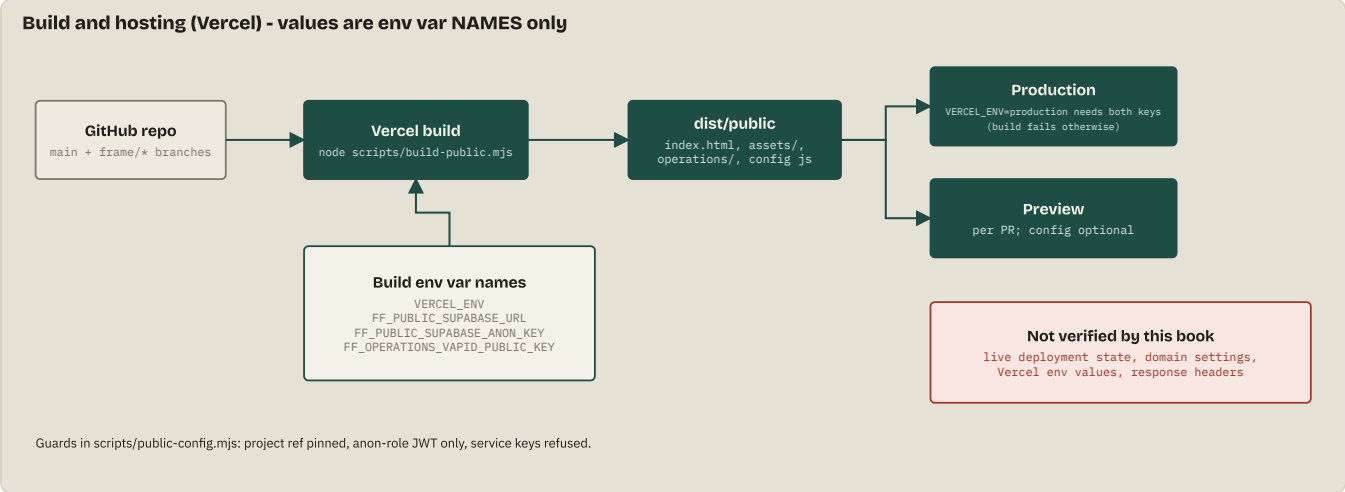
2.2 Front end and back end



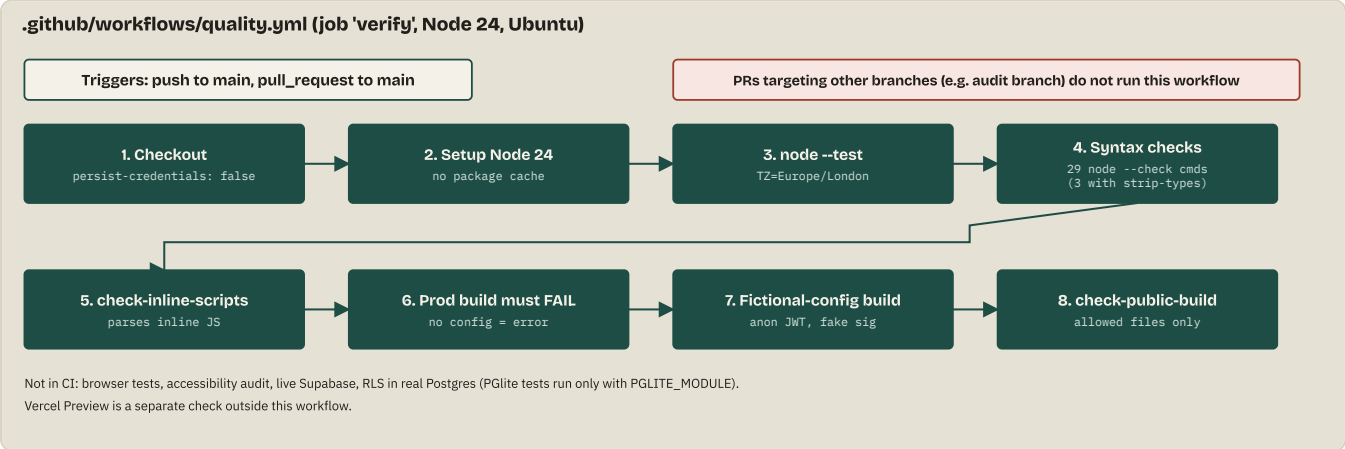
Front end and back end: browser, Vercel static hosting, Supabase

- **Hosting**: `vercel.json` on `main` has only `buildCommand` and `outputDirectory`; **no response headers (no CSP)** are configured. [`E-23`]
- **Build**: `node scripts/build-public.mjs` copies `index.html`, `assets/` and an explicit list of `operations/` files into `dist/public/` and writes two generated config files (`public-config.js`, `operations/config.js`) that contain only the public Supabase URL, the anon key and the public VAPID key. A production build **fails** if the keys are missing. [`E-21`]
- **Third-party loads at runtime** (browser): `https://esm.sh/@supabase/supabase-js@2.117.2` (unvendored, no SRI; staff app and Edge Functions), `fonts.googleapis.com` / `fonts.gstatic.com`. [`E-24`] [`E-26`]

2.3 Vercel and CI/CD



Build and hosting on Vercel



CI: .github/workflows/quality.yml

The workflow runs only for pushes to `main` and for pull requests **targeting** `main`; PRs aimed at other branches get no CI. [`E-22`] Vercel Preview/Production behaviour is **not verified** in this book.

2.4 Page-by-page map

There are exactly two user-facing pages on `main`: the public site and the staff app. Other HTML files in the repo (`anthony-roadmap.html`, `owner-desk-approval-preview.html`, `docs/MASTER_DOCUMENTATION.html`) are not copied by the build and are not routes. [`E-21`]

Route `/` — Public website (`index.html`)

Item	Detail
Purpose	Marketing and enquiry: configurator, process, works, request form.
Sections (anchors)	`#drawing`, `#survey`, `#specify`, `#process`, `#works`, `#testimonials`, `#request`, footer. [`E-04`]

Item	Detail
Interactive elements	Nav links (4) + **Staff access** + **Book a survey**; hero zoom/pan controls (−, +, rotate, maximise, fit); survey/proposal comparison slider; configurator (budget mode, wall/ceiling, left/right bays, module/unit sizes, finish, texture, glass, fronts, handles, TV, fire, lighting, room-photo overlay); Save/Share spec; Send with survey; enquiry form (name, phone-or-email, postcode, wall width, brief, optional visit window); project assistant chat (3 suggestion chips + free text); final-brief dialog (email draft, copy, download .txt).
Button destinations	Nav links scroll to anchors. **Staff access** goes to `https://form-and-frame.vercel.app/operations/` (external, `index.html:686`). **Book a survey** scrolls to `#request`; "Send with survey" copies the configured spec into the brief field and scrolls to `#request` (`index.html:2270-2278`). The form submits to `POST {supabaseUrl}/functions/v1/submit-enquiry`. "Open email app" uses a `mailto:` link with no recipient. [`E-05`]
Backend actions	One: `submit-enquiry`. The assistant is rule-based in the browser (no `fetch`); the saved spec lives in `localStorage` (`ff_spec`). [`E-05`]
Roles	Anonymous.
Status	`VERIFIED` UI shell and validation observed; `IMPLEMENTED` live submit (not observed live).
Dependencies	Google Fonts; `/public-config.js` (generated at build); Supabase project.

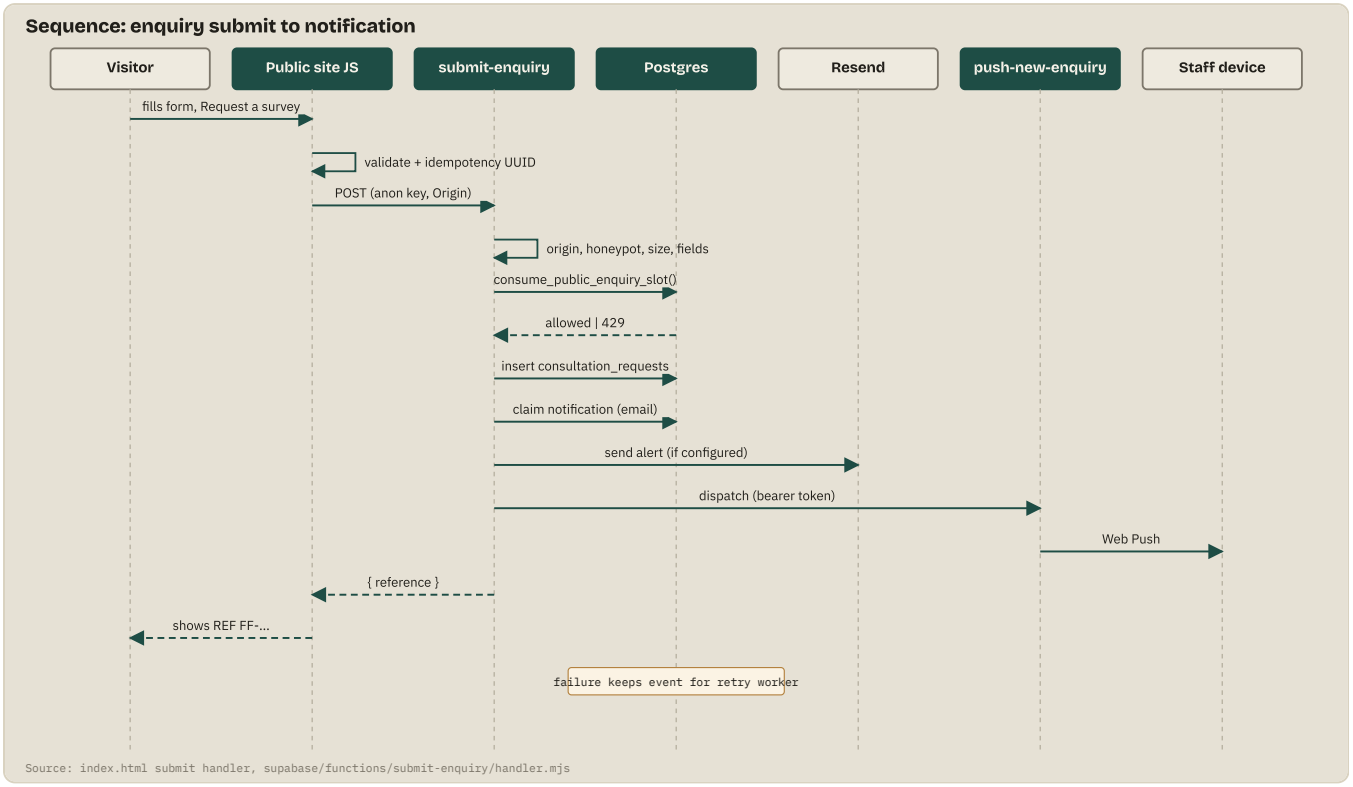
Route `/operations/` — Staff app "Owner Desk" (`operations/index.html`, `app.js`)

Item	Detail
Purpose	Private desk for the team: enquiries, quotes, jobs, calendar, invoices, payments, notifications.
States	(a) **Sign-in** (magic link) when a Supabase config is present; (b) **Demo mode** with fictional data when no config is present (a build without `config.js`); (c) **Owner Desk** after a verified staff sign-in; (d) enquiry workspace overlay; (e) notification panel.
Navigation	Desktop: left sidebar Today / Enquiries / Calendar / Money. Phone: fixed bottom bar Today / Work / Calendar / Money.
Button destinations	Sidebar items link to `#desk`, `#leads`, `#availability`, `#business` (**`#desk` does not exist in the HTML**, so the Today link does not jump anywhere; minor). Brand and badge link to `../index.html`. Open (enquiry) opens the workspace; Alerts opens the notification panel; Sign out calls `auth.signOut()` then reloads.
Backend actions	Reads: `consultation_requests`, `quotes`, `work_orders`, `appointments`, `follow_up_tasks`, `invoices` (+ `invoice_balances`), `invoice_payments`, `workflow_activity`, `business_settings`, `notification_events`, `push_subscriptions`. Writes: see Owner Dashboard. Calls `push-new-enquiry` for test/dispatch. Realtime channel `ff-operations` listening to row changes on ten tables including `profiles`. [`E-10`]
Roles	`owner` and `staff` (from `profiles.role`); an authenticated user without a profile sees "not added to the team". Owner-only: invoice seller details.
Status	Sign-in screen and demo mode `VERIFIED` (observed); signed-in desk `IMPLEMENTED`, not verifiable here.
Dependencies	esm.sh (supabase-js), Google Fonts, Supabase Auth/PostgREST/Realtime, service worker for push.

Generated and static files

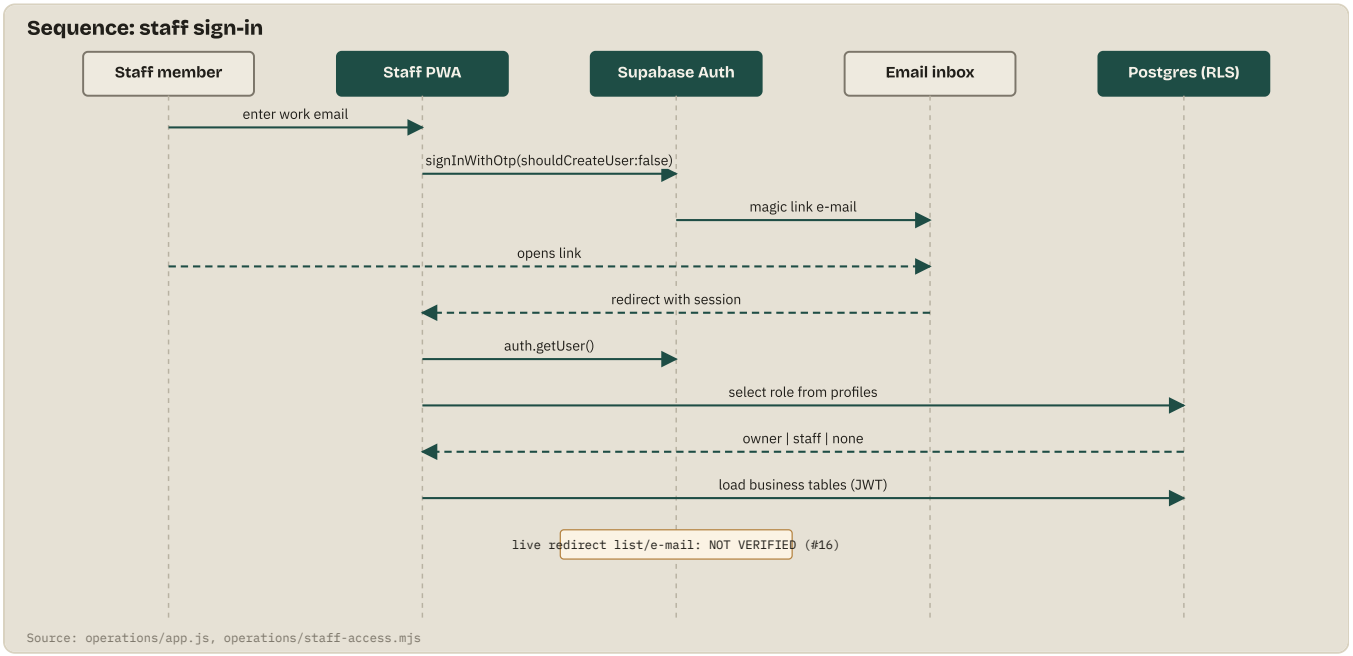
Path	Purpose
`/public-config.js`, `/operations/config.js`	Generated at build: URL, anon key, public VAPID key only.
`/operations/manifest.webmanifest`, `/operations/service-worker.js`	PWA install and Web Push handling.
`/assets/cases/*.webp`	Eight before/after photographs for the "Completed works" section.
`/robots.txt`, `/sitemap.xml`	**Not on main** (added in PR #8).

2.5 Sequence: enquiry submit to notification



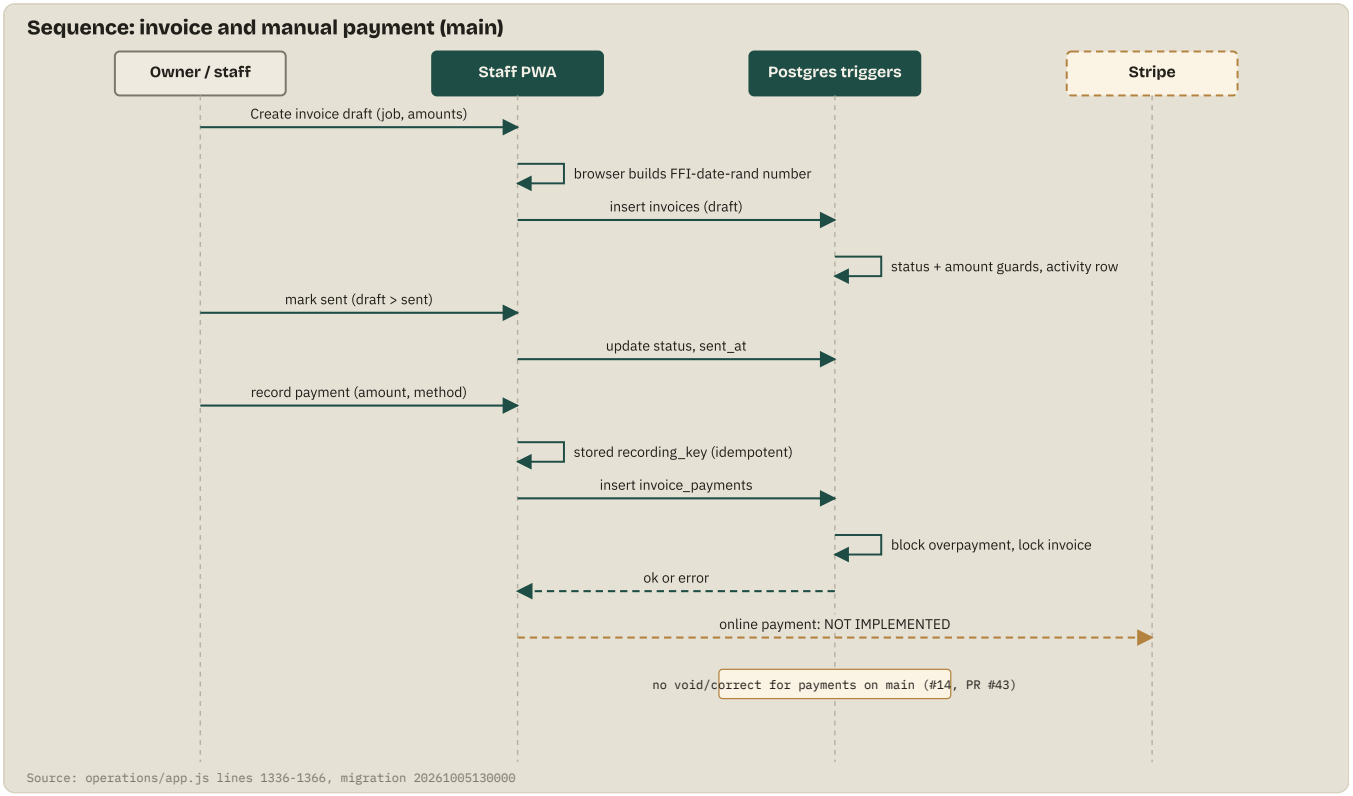
Sequence diagram: enquiry submission to notification

2.6 Sequence: staff sign-in



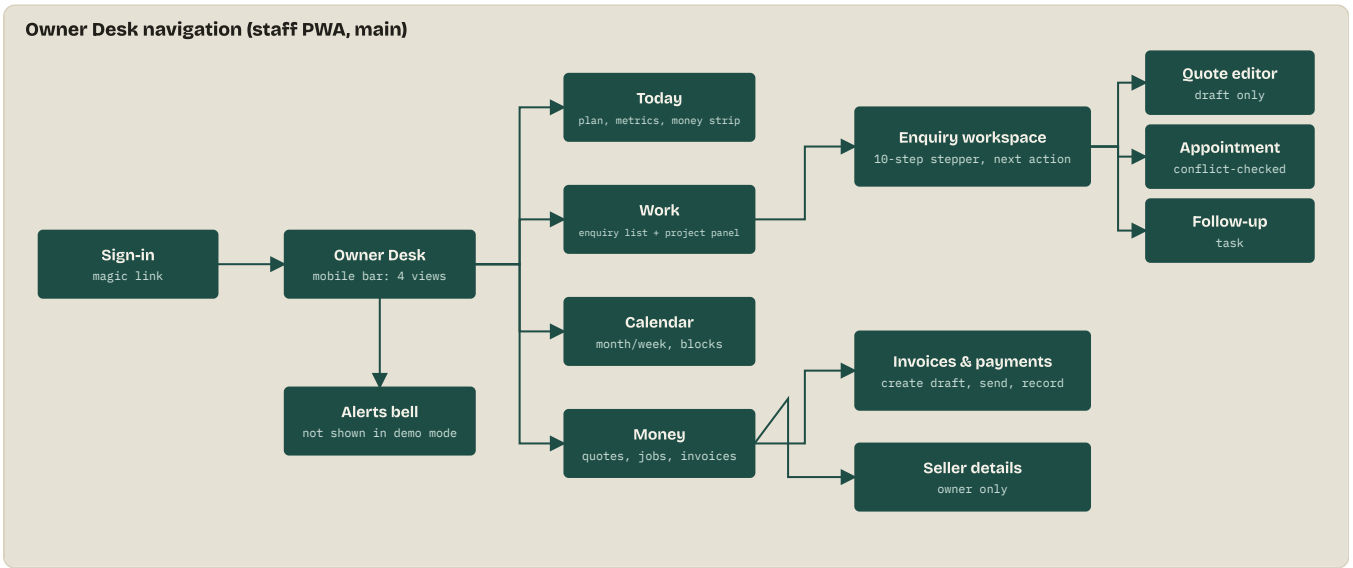
Sequence diagram: staff sign-in

2.7 Sequence: invoice and manual payment



Sequence diagram: invoice and payment

2.8 Owner Desk navigation

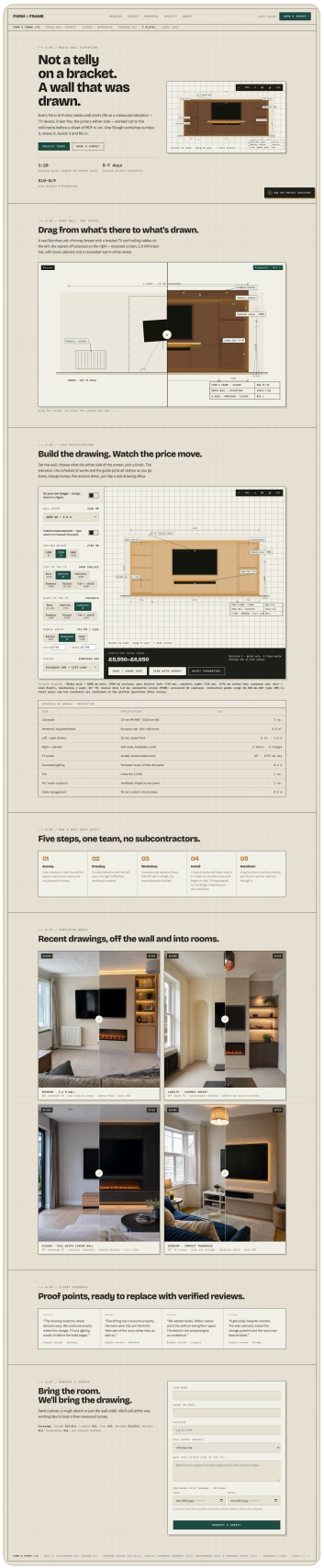


Owner Desk navigation

SECTION 04

3. Public website

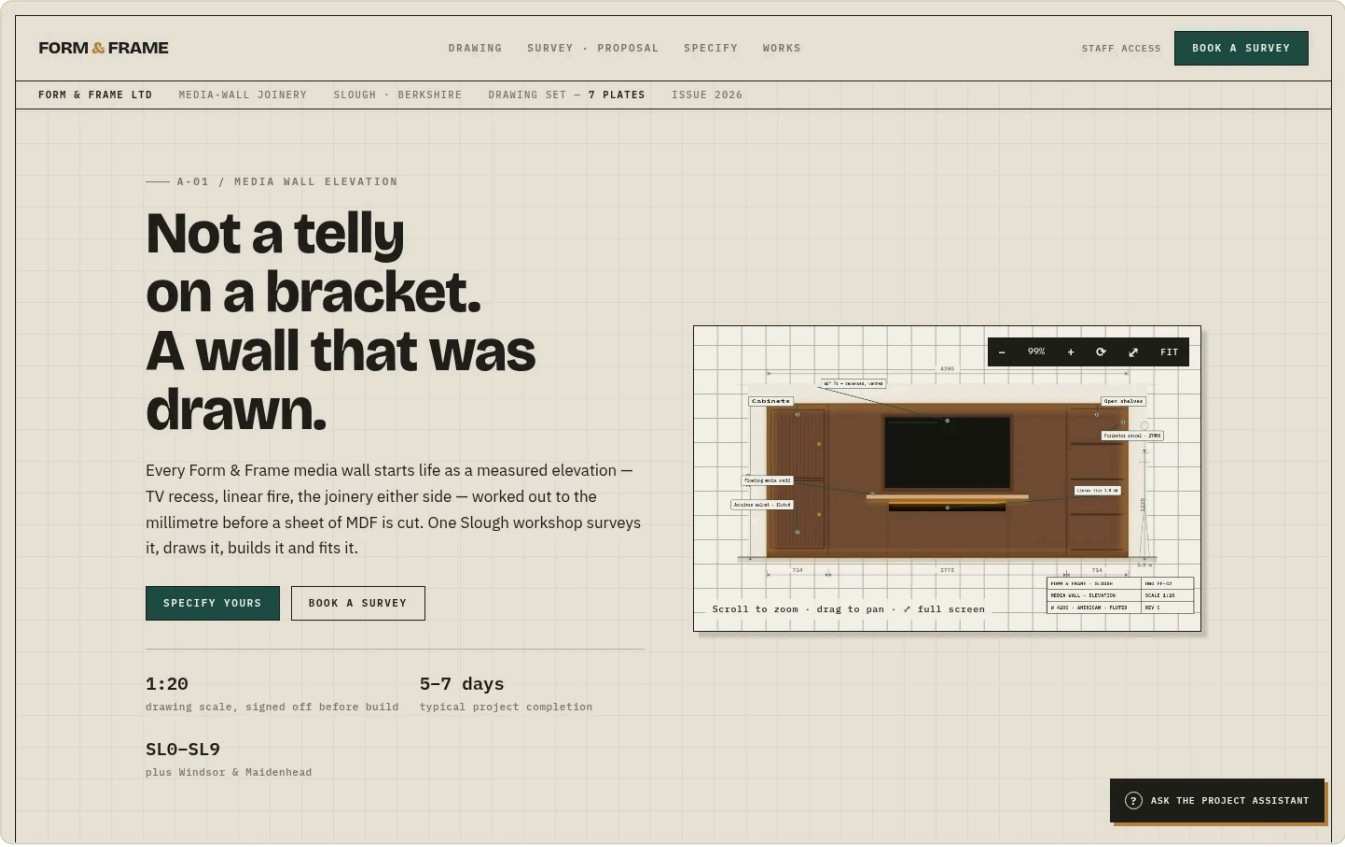
Route `/` (`index.html`, 2,888 lines, inline CSS and JavaScript). Screenshots in this chapter are real captures of the **built** site (`node scripts/build-public.mjs` with the same fictional Supabase configuration CI uses) served locally and rendered in headless Chrome 155 at 1440 px (desktop) and 390 px (mobile, 2x pixel density). No request reached the live Supabase project (all `supabase.co` requests are blocked by the capture script). Fixed elements (sticky navigation, chat launcher) are hidden in the per-section crops and visible in the "fold" captures.



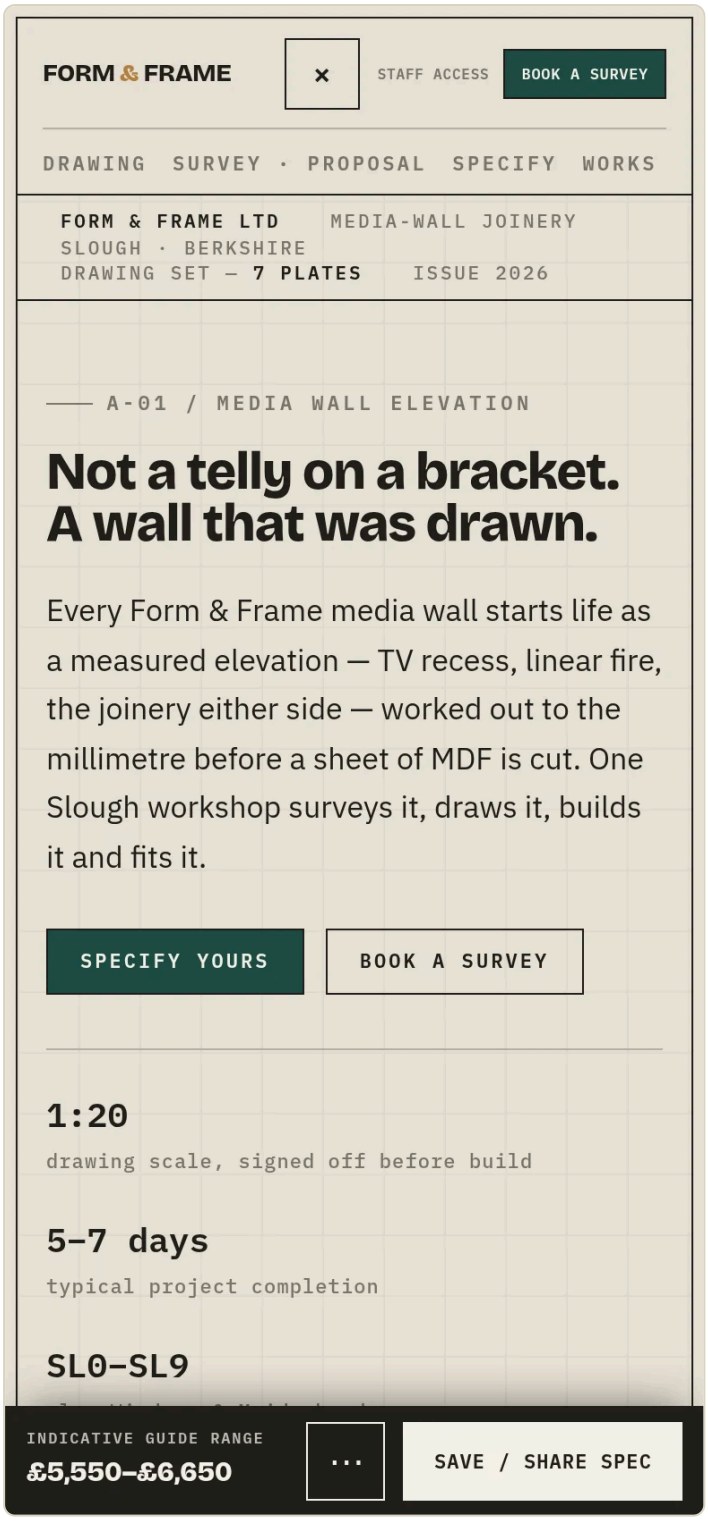
Public site, full page, desktop 1440 px

3.1 Navigation and title strip

Sticky navigation: wordmark; links DRAWING, SURVEY · PROPOSAL, SPECIFY, WORKS; a small **Staff access** link; a green **Book a survey** button. Under 900 px the links collapse behind a ☰ toggle. A title strip states "Form & Frame Ltd · Media-wall joinery · Slough · Berkshire · Drawing set — 7 plates · Issue 2026". Note: the nav has no link to Process, Testimonials or Request; "Book a survey" is the way to the form.

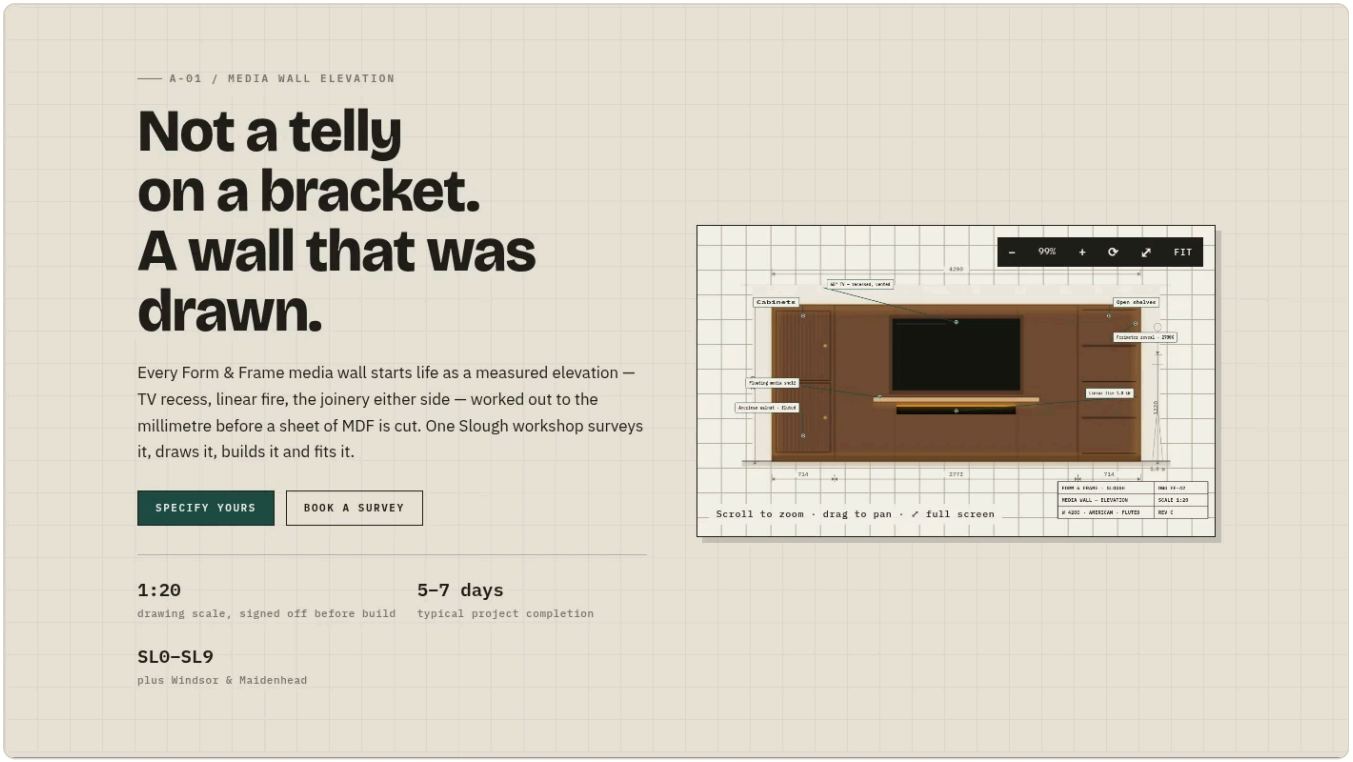


Desktop fold: navigation, title strip, hero and the project-assistant launcher



Mobile navigation opened with the toggle (390 px). A fixed bottom bar shows the indicative guide range and "Save / share spec".

3.2 A-01 Hero: "Not a telly on a bracket."

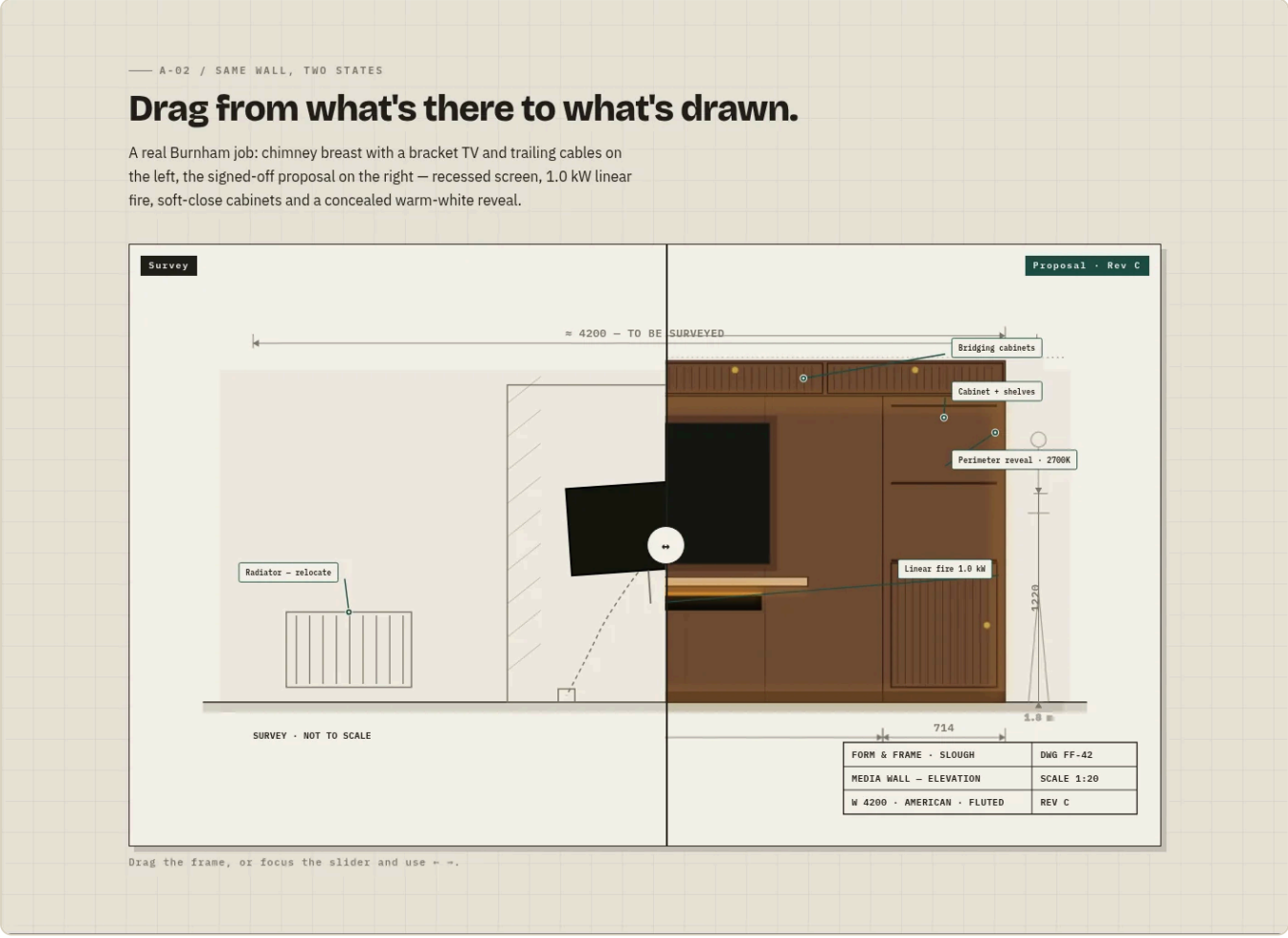


A-01 hero (desktop)

Interactive drawing of a media-wall elevation with zoom out/in, rotate, maximise and fit controls and "Scroll to zoom · drag to pan". Buttons: **Specify yours** (to `#specify`) and **Book a survey** (to `#request`). Three hero facts: "1:20 drawing scale, signed off before build", "5–7 days typical project completion", "SL0–SL9 plus Windsor & Maidenhead".

> **Pending Mark:** "5–7 days typical completion", "signed off before build", "One Slough workshop" and the postcode coverage are business claims in the code. Nothing in the repository proves them; the owner must confirm them before they are treated as fact.

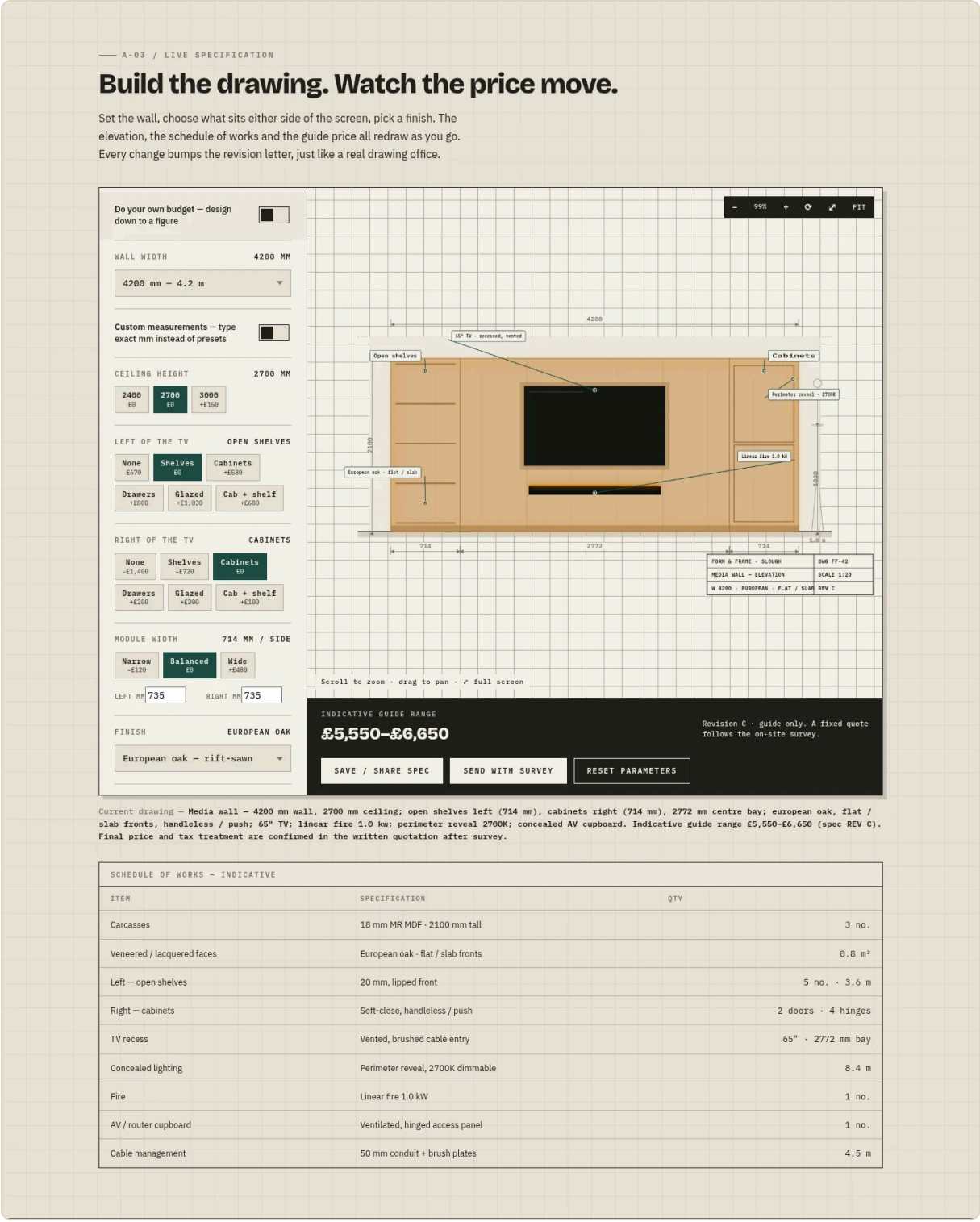
3.3 A-02 Survey vs proposal



A-02 compare slider (desktop)

A draggable before/after slider ("Survey" vs "Proposal · Rev C"), also operable with the keyboard (range input with `aria-valuetext`). The copy says "A real Burnham job: chimney breast…", which is a claim about a real project: **pending Mark** (see 3.5).

3.4 A-03 Configurator "Build the drawing. Watch the price move."



SCHEDULE OF WORKS — INDICATIVE

ITEM	SPECIFICATION	QTY
Carcasses	18 mm MR MDF · 2100 mm tall	3 no.
Veneered / lacquered faces	European oak · flat / slab fronts	8.8 m²
Left — open shelves	20 mm, lipped front	5 no. · 3.6 m
Right — cabinets	Soft-close, handleless / push	2 doors · 4 hinges
TV recess	Vented, brushed cable entry	65" · 2772 mm bay
Concealed lighting	Perimeter reveal, 2700K dimmable	8.4 m
Fire	Linear fire 1.0 kW	1 no.
AV / router cupboard	Ventilated, hinged access panel	1 no.
Cable management	50 mm conduit + brush plates	4.5 m

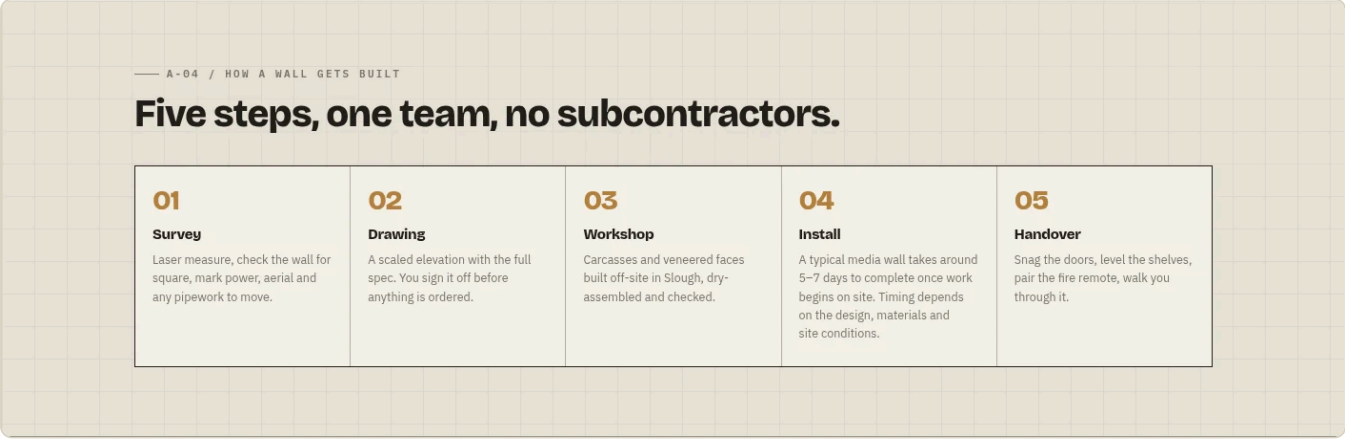
A-03 configurator (desktop)

Browser-only. Controls: "Do your own budget" mode with a slider and **Fit spec to it**; wall width (3.0–6.0 m or custom); ceiling height 2400/2700/3000 or custom; left and right bays (None, Shelves, Cabinets, Drawers, Glazed, Cab + shelf) each with a price delta; module width; unit height; finish, surface texture, glass type, door & drawer front, handles; TV size; fire; light type; optional overlay on a room photo. The elevation, a "Schedule of works — indicative" table and an **Indicative guide range** (for example £5,550–£6,650 for the default) redraw live; every change bumps a revision letter. Buttons: **Save / share spec** (stored in `localStorage` key `ff_spec`), **Send with**

survey (copies the spec into the form brief), **Reset parameters**. The page states the figure is a guide only: "A fixed quote follows the on-site survey."

> The price logic is pure browser JavaScript inside `index.html`; **the guide prices are not covered by any automated test** (no test file touches `index.html` pricing). The guide-price range is saved with the enquiry as `guide_low` / `guide_high`. Formal quotes are separate records in the Owner Desk.

3.5 A-04 Process and A-05 Completed works



A-04 process: Survey, Drawing, Workshop, Install, Handover

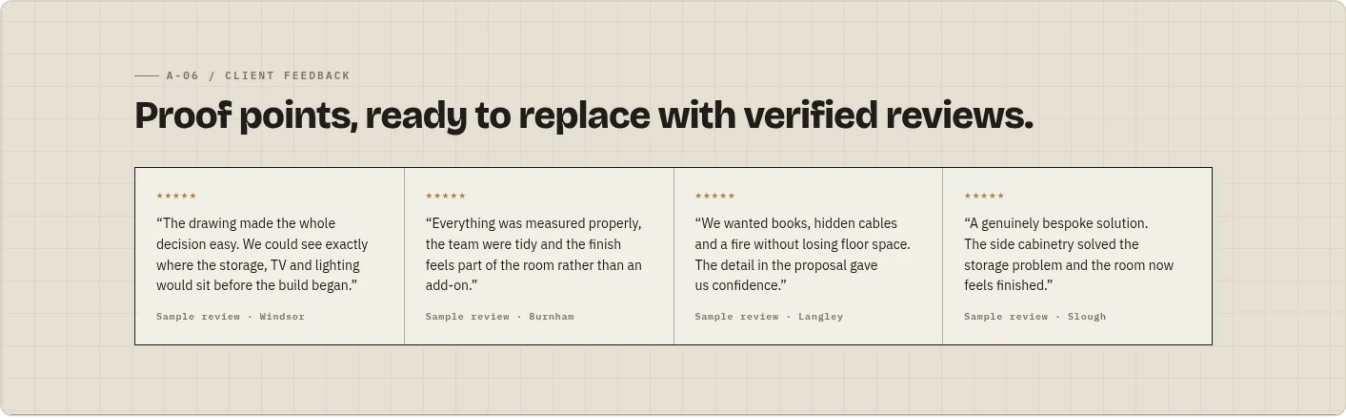
Five steps. The install step says "around 5-7 days … depends on the design, materials and site conditions".



A-05 "Completed works": four before/after sliders captioned Burnham, Langley, Slough, Windsor

PLACEHOLDER / UNCONFIRMED CONTENT — pending Mark. The four "Completed works" cases (Burnham, Langley, Slough, Windsor), their photographs (`assets/cases/*.webp`) and captions are presented on `main` as completed jobs, but no repository evidence shows they are real Form & Frame projects, or where the photographs came from. Draft PR #26 removes the section from the page (archived under `docs/pending-mark/` so it can be restored in one step) once the owner decides. Until then this book treats the section as **unvalidated**.

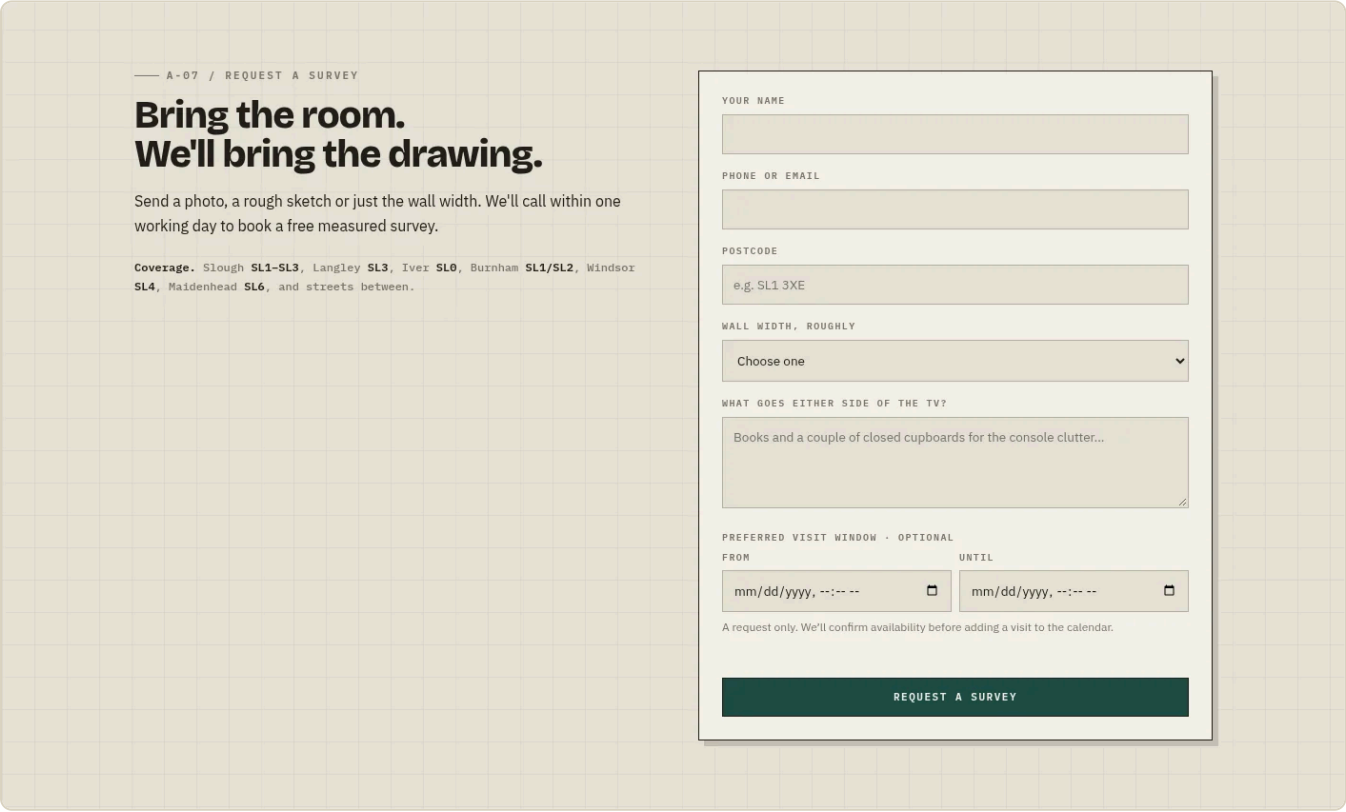
3.6 A-06 Testimonials



A-06 testimonials (desktop)

> **Placeholder content.** The heading reads "Proof points, ready to replace with verified reviews." and each card is captioned "Sample review · Windsor/Burnham/Langley/Slough" with five stars. These are **sample texts, not customer testimonials**; the page labels them as samples, but they are still publicly visible on `main`. PR #8 removes them; no real review exists in the repository. This book does not present them as testimonials.

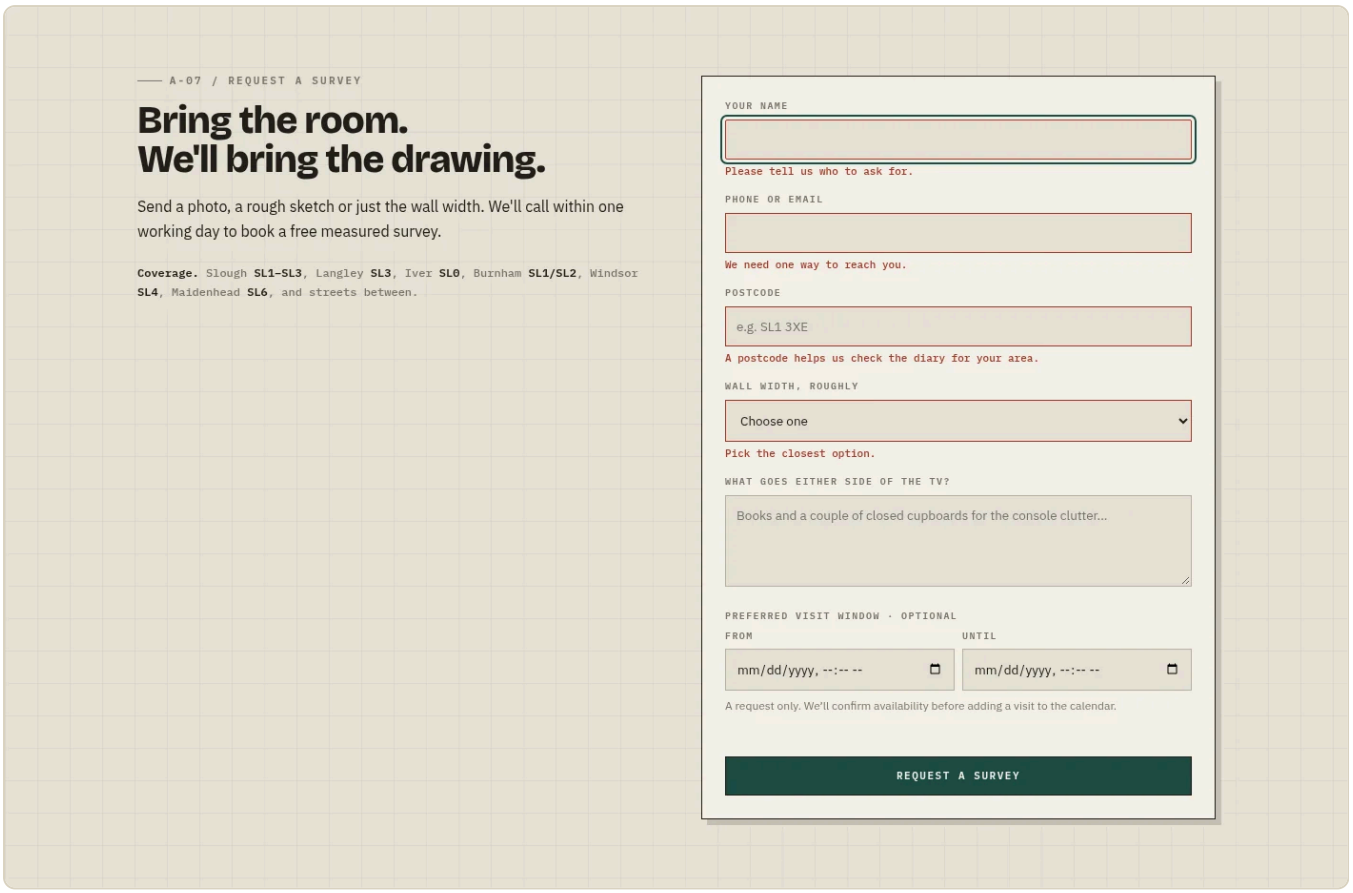
3.7 A-07 Contact, form and footer



A-07 "Request a survey": coverage text and form (desktop)

Form fields: Your name, Phone or email (one field; an `@` routes it to the email column, otherwise phone), Postcode, Wall width (4 options + "not sure"), brief ("What goes either side of the TV?"), optional preferred visit window

(From/Until) and a hidden honeypot. Validation messages appear on submit:



Form validation messages after pressing "Request a survey" with an empty form (observed)

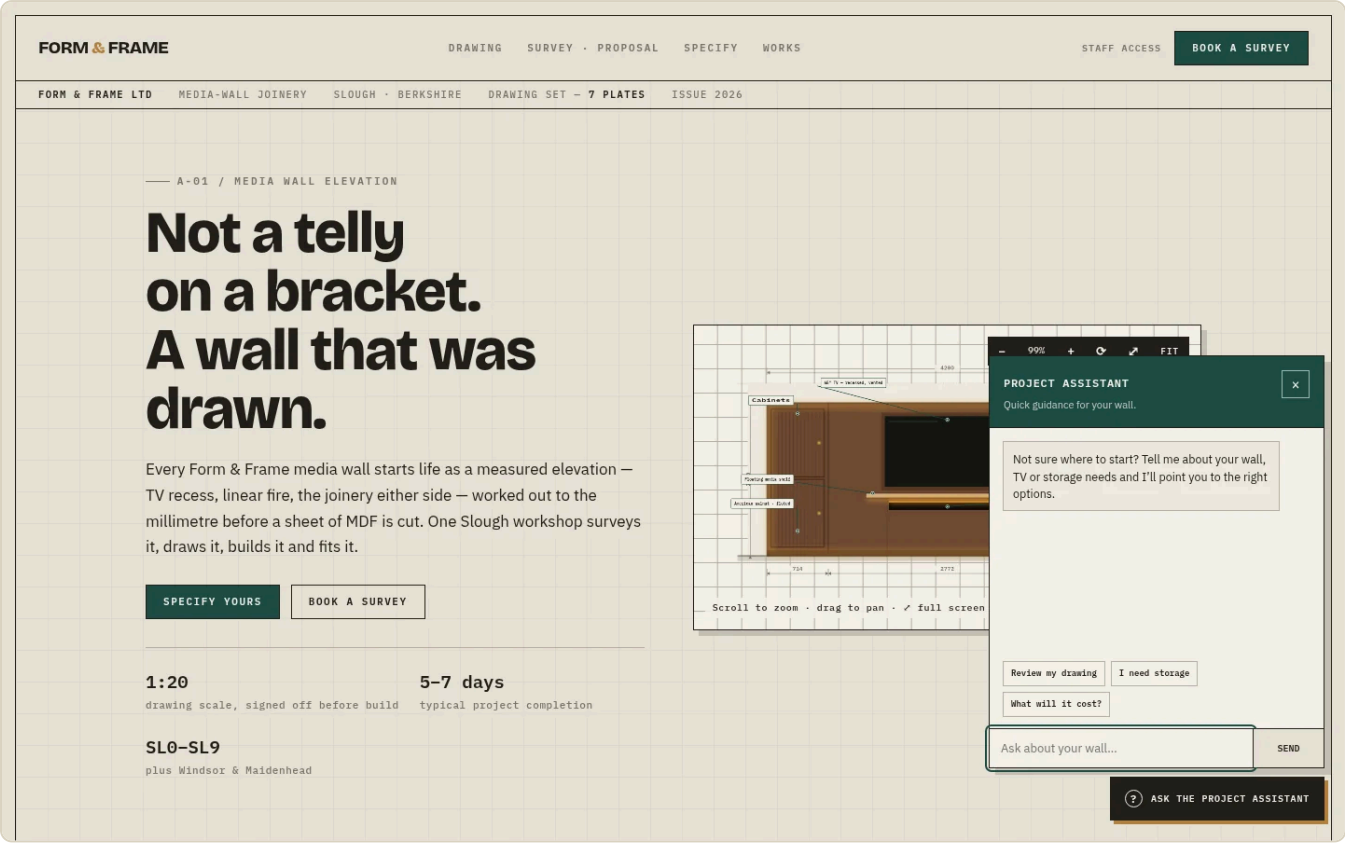
On success the form is replaced by "Thanks. We've received your enquiry." with a `REF` number. If the site was built without Supabase configuration, the form says "The enquiry form is being connected. Please contact us directly for now." (`index.html`, form handler): note that the page publishes **no phone number or e-mail address anywhere**, so there is nothing to "contact directly".

The submit sends `POST /functions/v1/submit-enquiry` with the public anon key, a client-generated idempotency UUID and the payload (name, email or phone, postcode, width, message, preferred window, project spec, guide range, `source: "website"`). Retry-safety, a 30-second timeout and 429 handling ("Please wait about N minutes") are implemented. [`E-05`] [`E-06`]

Footer (desktop)

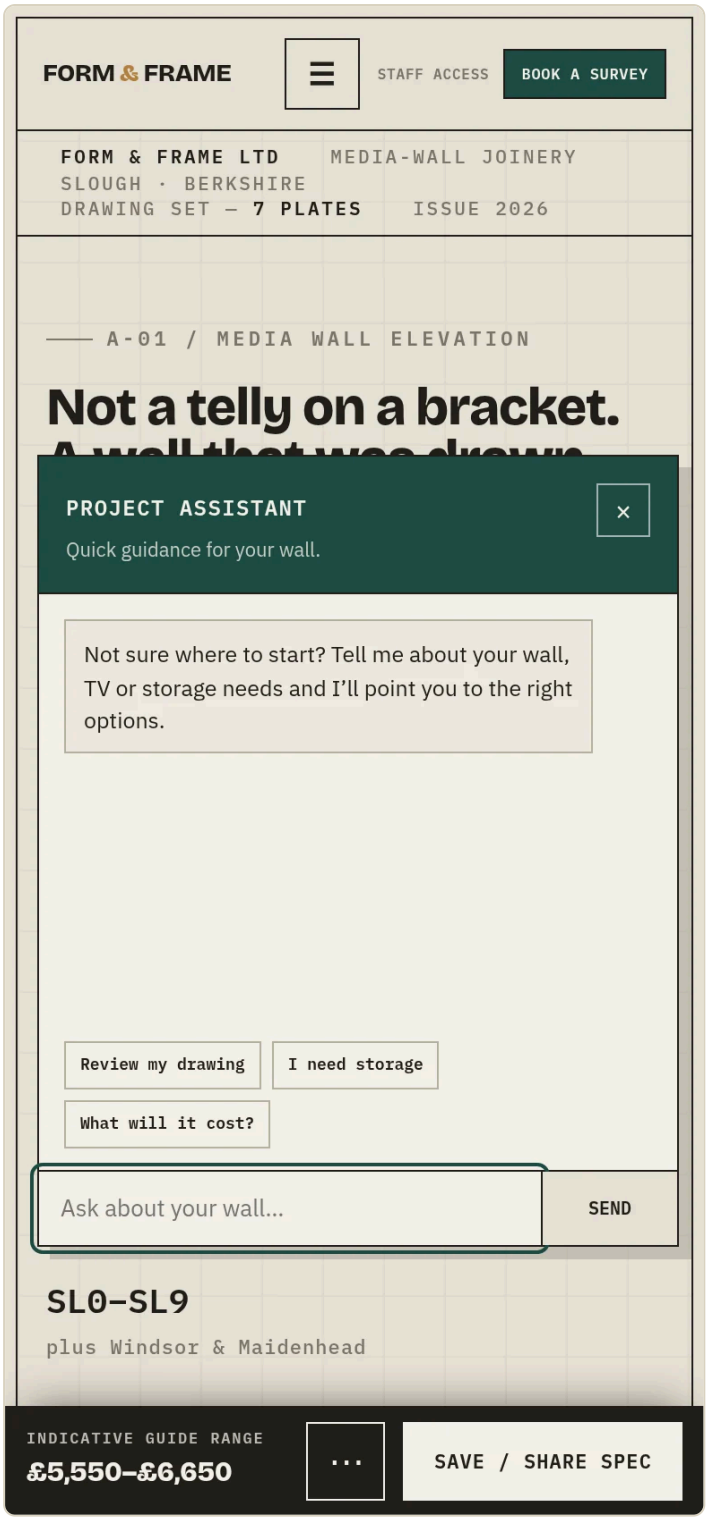
> **Pending Mark: contact facts.** The footer prints "Unit 4, Buckingham Ave, Slough SL1" and the contact copy promises "We'll call within one working day to book a free measured survey". Neither the address nor the free-survey / one-working-day promises can be verified from the repository. No phone number or e-mail is published; real contact fields are prepared only in Draft PR #26's pending file and are **not** to be published until confirmed.

3.8 Project assistant



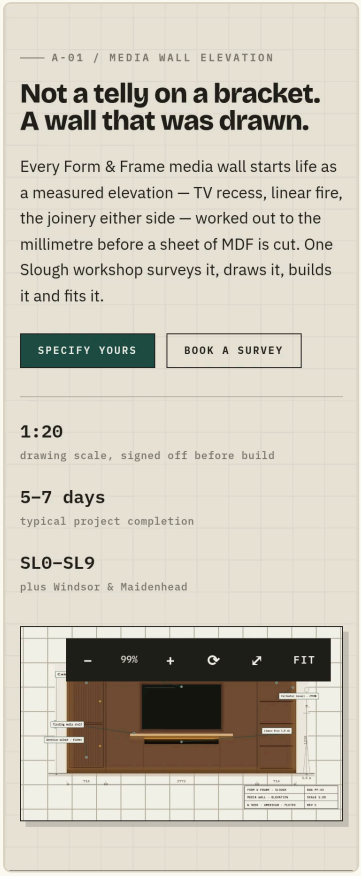
Project assistant open on desktop

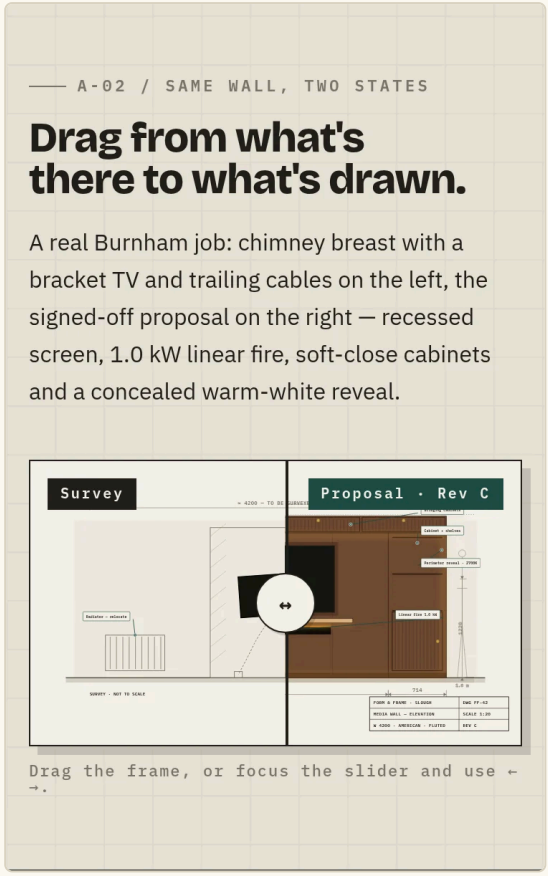
A floating **Ask the project assistant** launcher opens a chat panel with three suggestion chips (Review my drawing, I need storage, What will it cost?) and a text field. It is **rule-based and local**: the code contains no network call for it, and the repository's own handoff notes say there is no connected language model. [`E-05`] It can hand the configured spec to the form.

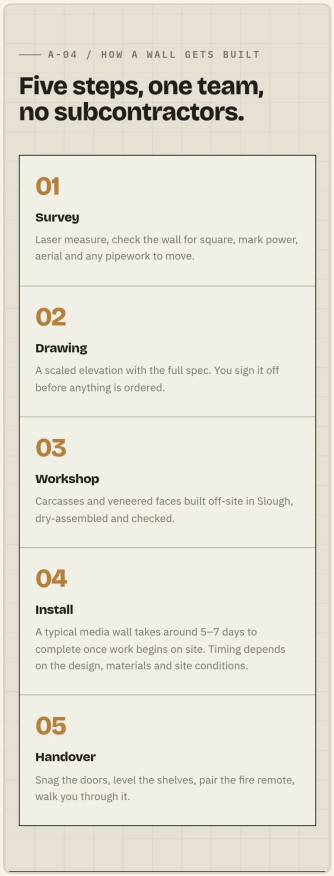


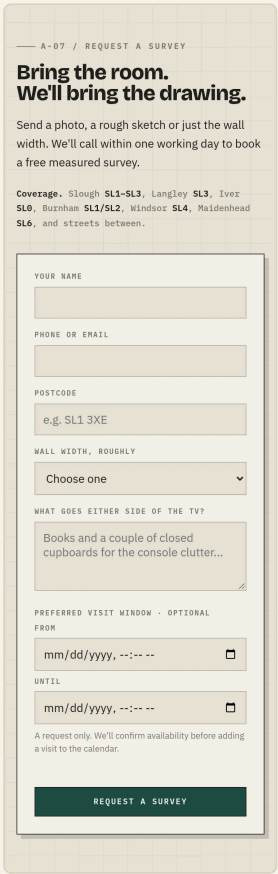
Project assistant on a 390 px phone

3.9 Mobile views of every section









The configurator, works and testimonials mobile captures are in `assets/screenshots/public/sec-mobile-390-*.webp`.

3.10 Search, metadata and accessibility on `main`

- `<html lang="en-GB">`, a meta description, Open Graph title/description/type, and an `og:image` pointing at `burnham-library-after.webp` on a GitHub Pages URL; a `canonical` link to `https://mfm2712-droid.github.io/form-and-frame-media-walls2/`. JSON-LD `HomeAndConstructionBusiness` is present and publishes the street address and a `priceRange` of "£££" (both **pending Mark**). **No `robots.txt` or `sitemap.xml` on `main`** (added by PR #8). The canonical/OG host (GitHub Pages) differs from the staff-link host (`form-and-frame.vercel.app`): which one is the real public address is **pending Mark**. [`E-04`]
- Keyboard: global focus ring, slider keyboard operation, `aria-live` status on the form; reduced-motion support. No automated accessibility audit has been run on `main` (see Testing).
- Performance: one 181 KB HTML file plus 436 KB of images; no performance measurement was taken for this book.

3.11 Public-site status summary

See the Feature matrix for statuses. In short: the enquiry path is implemented and unit-tested; **Completed works, testimonials, address, free-survey and one-working-day claims are unvalidated owner content**; there is no legal text (privacy notice, terms) on the page.

SECTION 05

4. Owner Dashboard (staff app, `/operations/`)

The Owner Desk is a mobile-first staff PWA: `operations/index.html`, `app.js` (1,386 lines) and 21 small ES modules; all but one (`notification-view.mjs`) have a test file. It shows business records only after a verified Supabase sign-in; without a configuration it falls back to a **demo mode**.

> **DEMO MODE — fictional data, not production.** Every staff-app screenshot in this chapter was captured from the app's built-in demo mode (the page served from `operations/` with no `config.js`, so `window.FF_OPERATIONS_CONFIG` is undefined and `startDemo()` runs, `operations/app.js:560,484`). The names (Amelia Grant, Hugo Clarke, Saira Patel), references (`FF-DEMO-10xx`), reserved example e-mail domains and sample figures are hard-coded fictional values; the tag "DEMO DATA" is visible in the header. The demo never saves records and shows no financial data. All live Supabase requests were blocked while capturing.

> **Screens that need a real sign-in are marked "NOT VERIFIABLE" and are not mocked.** The quote editor results, jobs list, invoice and payment lists, finance totals, activity log, seller-details form and notification inbox all render only from live Supabase rows. Their logic is covered by unit tests (named per module) but the rendered screens were **not observed** for this book.

4.0 Modules at a glance

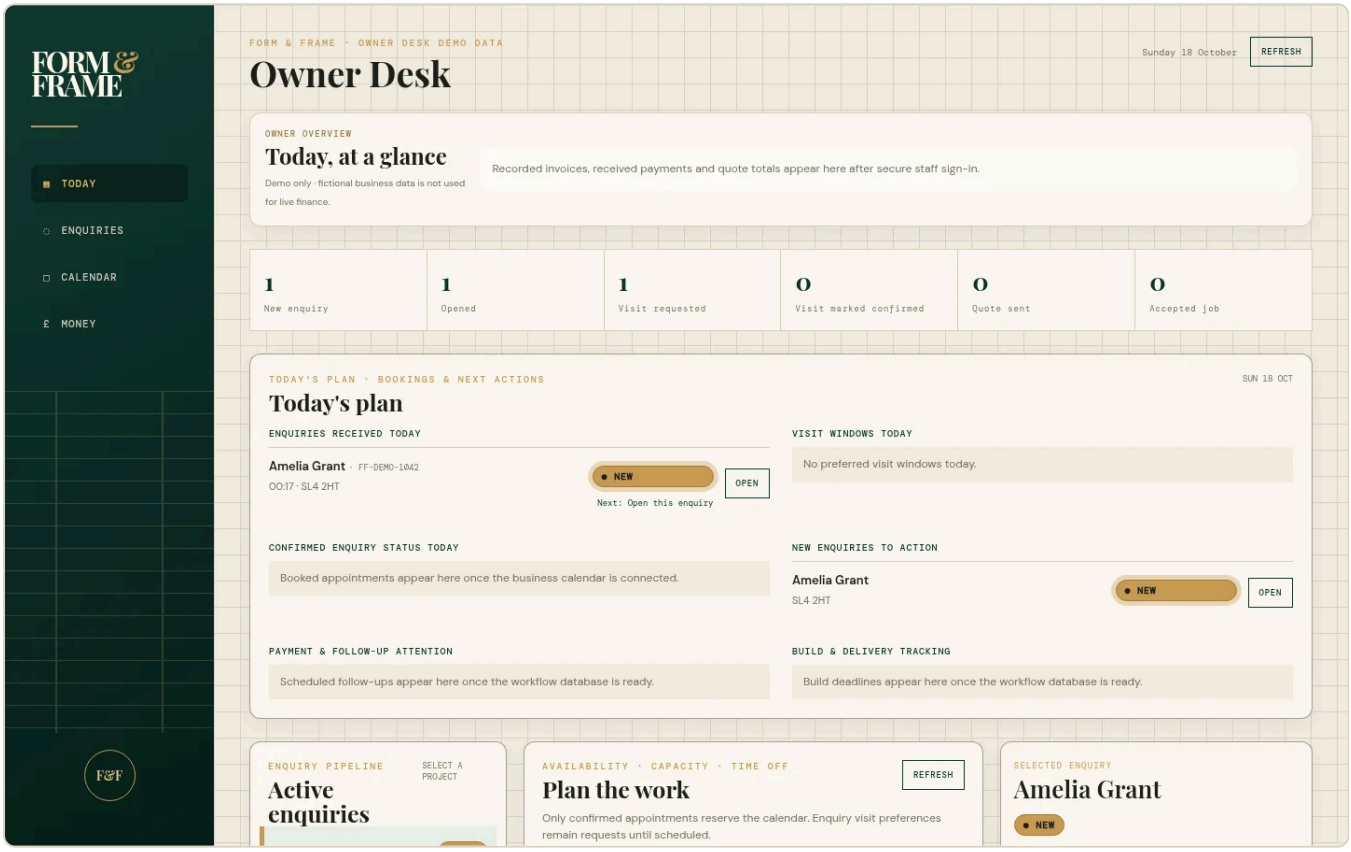
#	Module	Where	Status on `main`
M1	Today	Sidebar "Today" / phone tab	`VERIFIED` (demo observed; logic tests)
M2	Enquiries (Work)	"Enquiries" / "Work"	`VERIFIED` (demo observed; tests)
M3	Enquiry workspace (10-step flow)	opens from an enquiry	`VERIFIED` (demo observed; tests)
M4	Quotes	workspace + Money	`IMPLEMENTED`
M5	Jobs (work orders)	workspace + Money	`IMPLEMENTED`
M6	Calendar and availability	"Calendar"	`VERIFIED` (demo observed; tests)
M7	Appointments and follow-ups	workspace, Today	`IMPLEMENTED`
M8	Invoices	Money	`IMPLEMENTED`
M9	Payments (manual recording)	Money	`IMPLEMENTED`
M10	Money / finance strip	"Money"	`PARTIAL` (totals only)
M11	Business settings (seller details)	Money, owner only	`IMPLEMENTED`
M12	Notification centre and push	Alerts bell	`IMPLEMENTED`
M13	Activity history	Money, workspace	`IMPLEMENTED`
M14	Roles and access	sign-in gate	`PARTIAL`

Not present on `main` (do not read as features): a **Clients/customers module** (issue #32), **staff/user management** (#31), a **finance panel with ranges and exports** (#33), a **credit-note flow** (#34), **per-record**

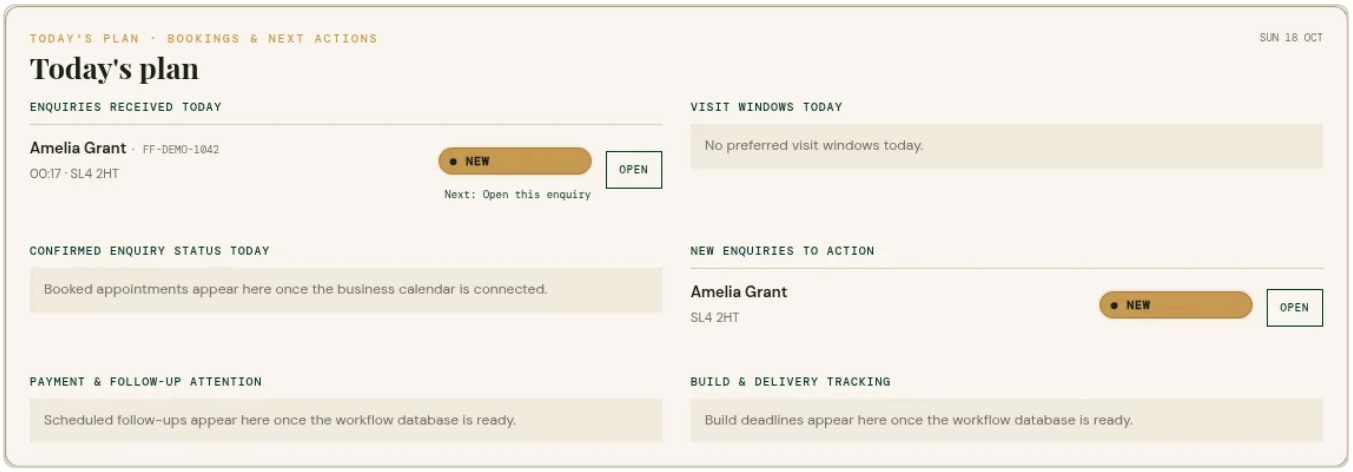
activity with actor names (#35), **business settings v2** (#37), a **printable quote** (#38), **quote expiry** (#39), **analytics** beyond the five figures in M10, and online payments. `NOT IMPLEMENTED`

M1 Today

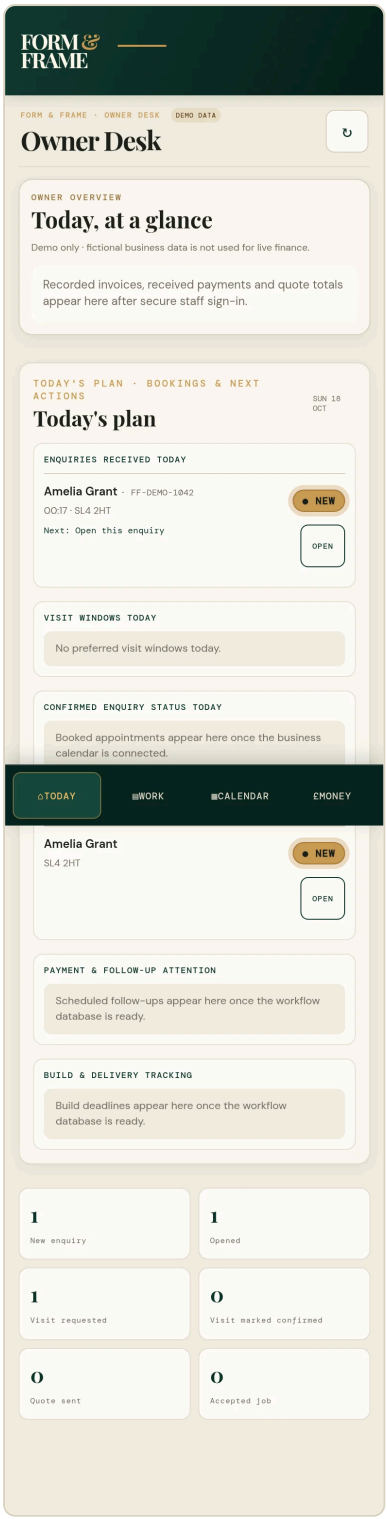
Purpose. What needs attention right now. **Data shown.** A recorded-money strip (invoiced, received, outstanding) for signed-in staff; six metric tiles (new enquiry, opened, visit requested, visit marked confirmed, quote sent, accepted job); "Today's plan" with six lists: enquiries received today, visit windows today, appointments today, replies due today, payment attention, delivery blockers. **Actions.** Open an enquiry from any row (each row shows its next action). **Backend.** Reads enquiries, appointments, follow-ups, invoices, jobs. **Permissions.** Owner and staff (money strip included: see Security). **States.** Loading; empty-state sentences for each list ("Booked appointments appear here once the business calendar is connected"); an error notice on failure. **Tests.** `today-view.test.mjs`, `pipeline.test.mjs`, `project-model.test.mjs`.



M1 Today, desktop fold. DEMO MODE — fictional data, not production.



M1 Today plan panel. DEMO MODE — fictional data, not production.



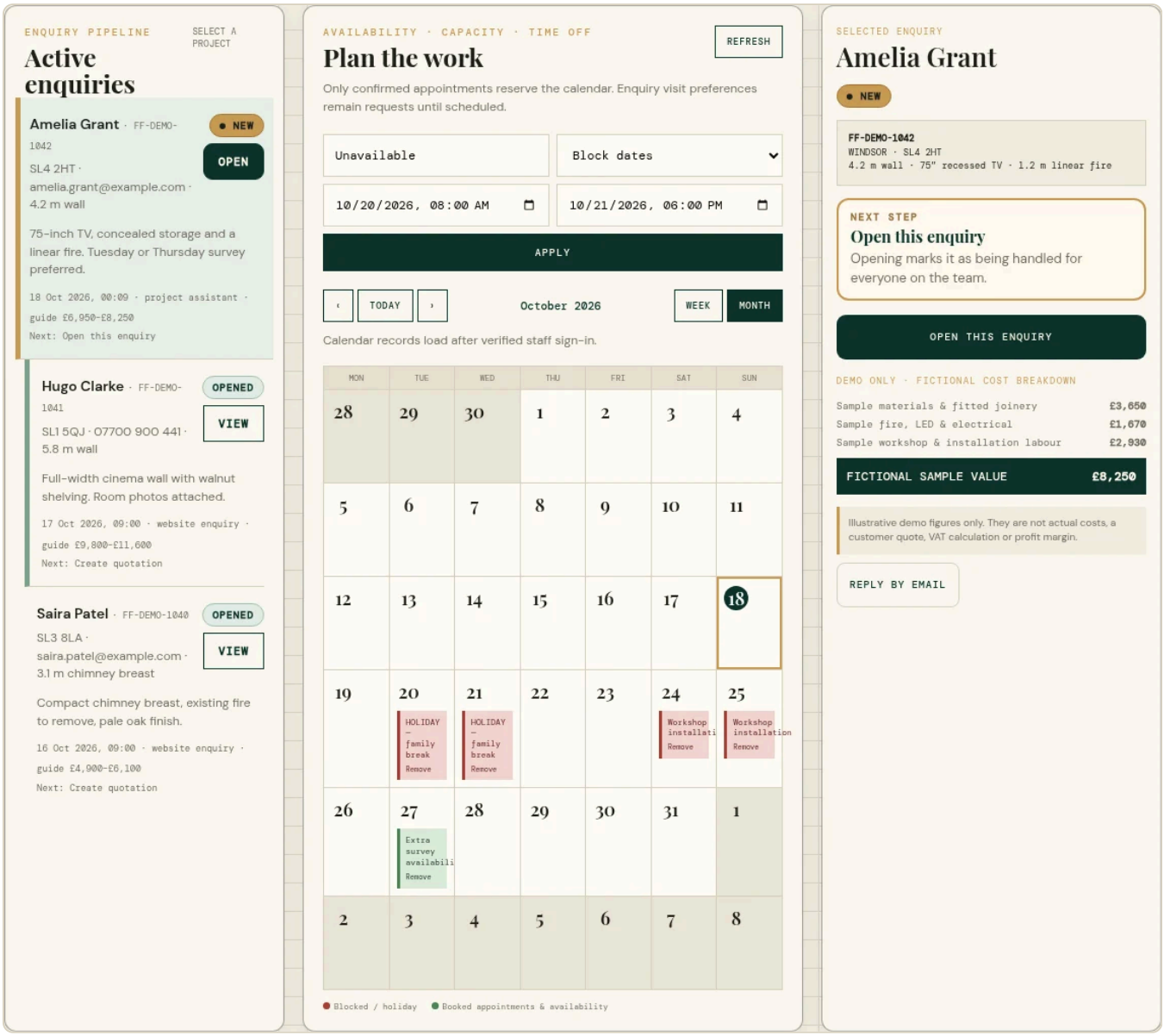
M1 Today on a 390 px phone with the bottom navigation. DEMO MODE — fictional data, not production.

Money strip with real figures: NOT VERIFIABLE. In demo mode it reads "Recorded invoices, received payments and quote totals appear here after secure staff sign-in."

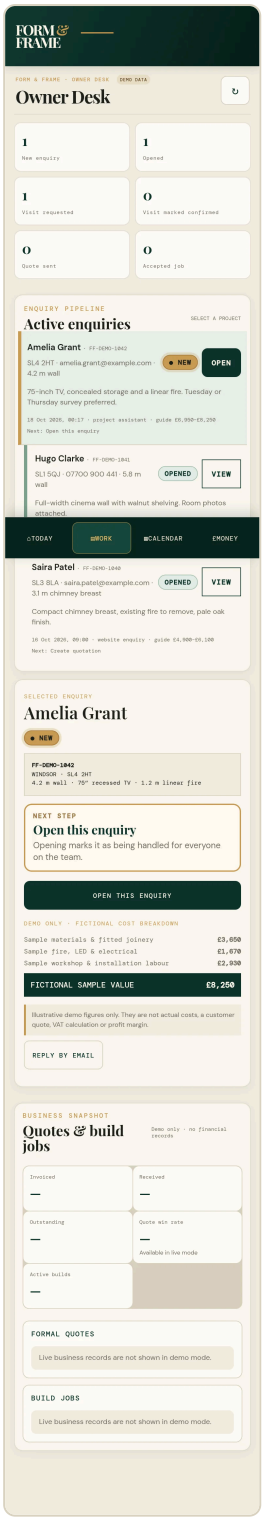
M2 Enquiries (Work)

Purpose. The pipeline of customer enquiries. **Data shown.** Each enquiry card: customer, reference, postcode, wall size, status pill, source, the website guide range, and the recommended next action; a "Selected enquiry" panel

with an indicative project drawing (demo only: labelled "DEMO ONLY · FICTIONAL COST BREAKDOWN"). **Actions.** Open the workspace; edit customer details (live only); toggle "site assessment required". Status is advanced by workflow actions (quote sent/accepted, job steps), not by a free status selector. **Backend.** `consultation_requests` (select, update), realtime refresh. **Permissions.** Owner and staff. **States.** New enquiries are visually emphasised (left border, bold); unopened enquiries move to "Opened" when opened (`statusAfterOpen`). **Tests.** `enquiry-workspace.test.mjs`, `pipeline.test.mjs`, `assignment.test.mjs`.



M2 enquiry list, availability and selected-enquiry panel. DEMO MODE — fictional data, not production.

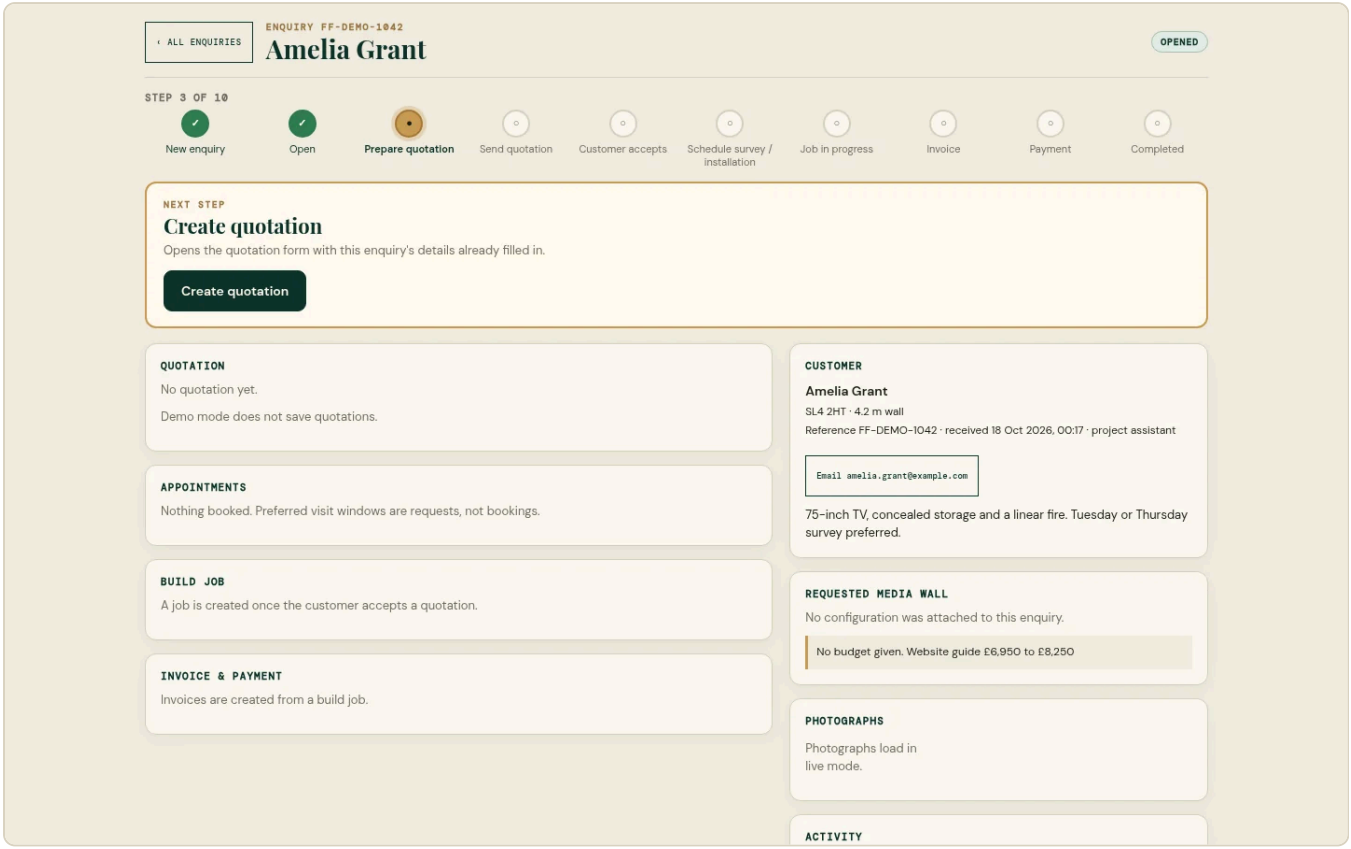


M2 Work tab on a phone. DEMO MODE — fictional data, not production.

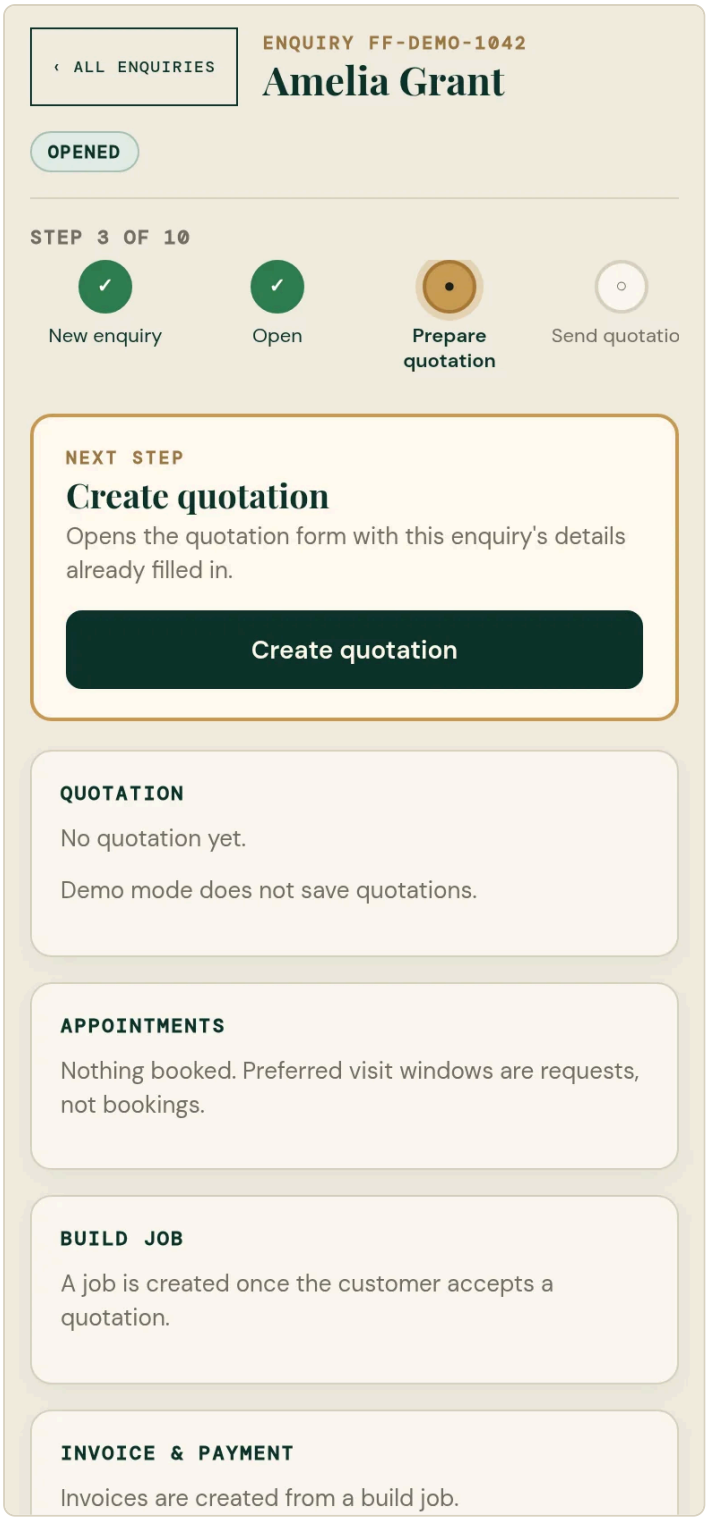
M3 Enquiry workspace

Purpose. One page that walks an enquiry through the ten-step workflow and always shows the next action. **Flow.** New enquiry → Open → Prepare quotation → Send quotation → Customer accepts → Schedule survey / installation → Job in progress → Invoice → Payment → Completed (`WORKFLOW_STEPS`, `enquiry-workspace.mjs:16`). **Data shown.** Stepper; "Next step" card; Quotation, Appointments, Build job and Invoice & payment cards; Customer card with direct e-mail/phone actions; Requested media wall; photographs; activity. **Actions.** Whatever the next

step is (for example **Create quotation**). **Permissions.** Owner and staff. **Tests.** `enquiry-workspace.test.mjs`, `enquiry-workspace-view.test.mjs`, `quote-readiness.test.mjs`.



M3 enquiry workspace opened from the first demo enquiry. DEMO MODE — fictional data, not production.



M3 workspace on a phone. DEMO MODE — fictional data, not production.

In demo mode the cards say "Demo mode does not save quotations", "Photographs load in live mode" and "Invoices are created from a build job."

M4 Quotes

Purpose. Formal quotations, kept separate from the website guide price. **Flow.** Create draft (scope, subtotal in £, explicit tax rate %, valid-until) → mark **sent** → **accepted** / **rejected** / **expired** / **superseded**; accepting creates the right to convert into a job. **Rules enforced in code.** A quote cannot be issued until a required site

assessment is completed (`canIssueQuote`); tax rate is explicit (no default); money is kept in integer pence; statuses follow a fixed transition table (`workflow.mjs`) mirrored by a database trigger; an accepted quote is locked by a trigger (`protect_accepted_quote`). Marking **sent** records the status only: **"No email was sent."** **Backend.** `quotes` insert/update; on sent/accepted the enquiry status becomes quoted/won. **Numbering.** The quote number `FFQ-YYYYMMDD-XXXX` is built **in the browser** from the date and four random characters (`app.js:1128`): uniqueness is by luck plus a unique constraint; draft fix in PR #41 (issue #15/#29). **Permissions.** Owner and staff (PO finding: see Security). **Tests.** `workflow.test.mjs`, `quote-readiness.test.mjs`, `business-migration.test.mjs`. There is **no edit-quote form** (a new version is created instead).

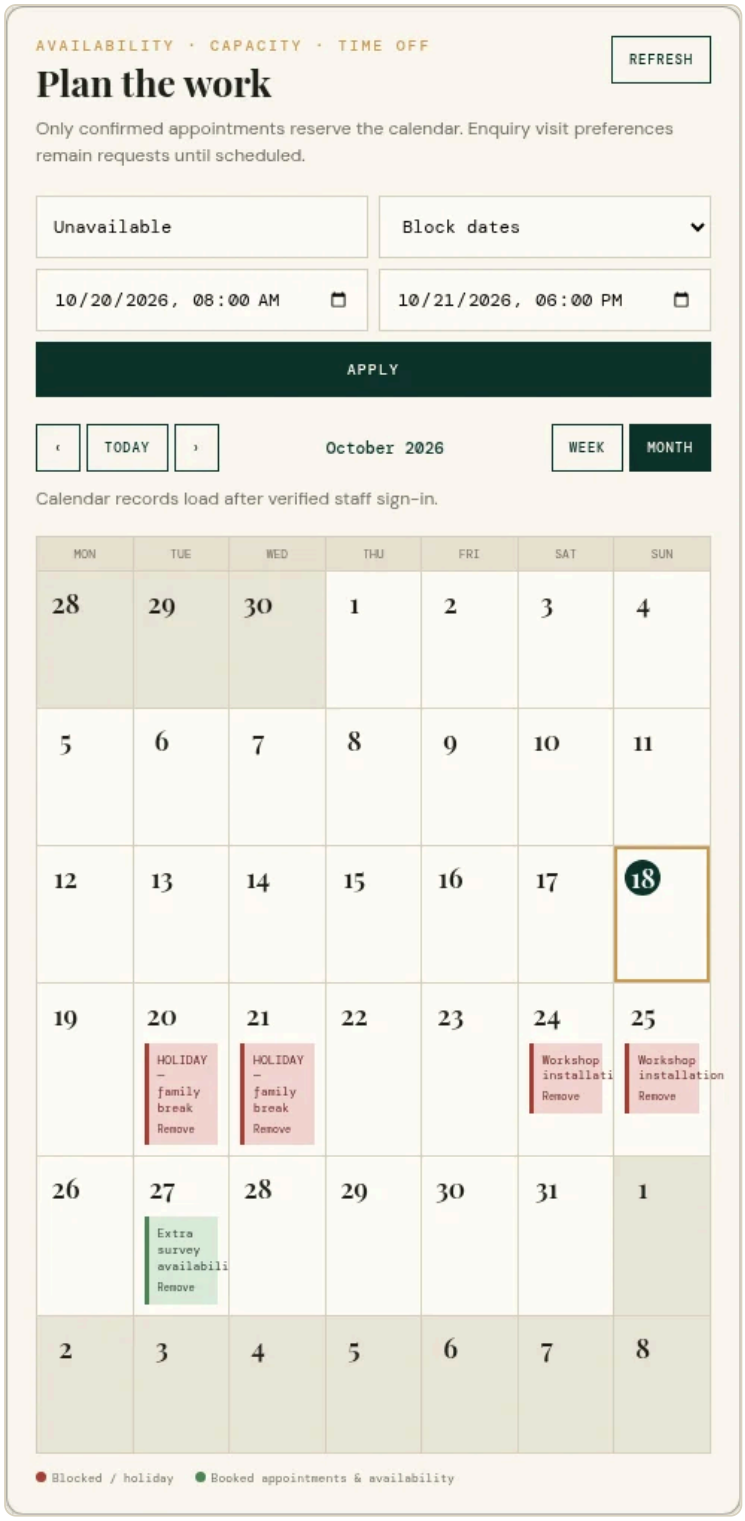
> **Quote editor with live data, quote list cards: NOT VERIFIABLE** (needs a signed-in staff session). Source: `operations/enquiry-workspace-view.mjs` (`quoteEditorHtml`), `app.js:183`.

M5 Jobs (work orders)

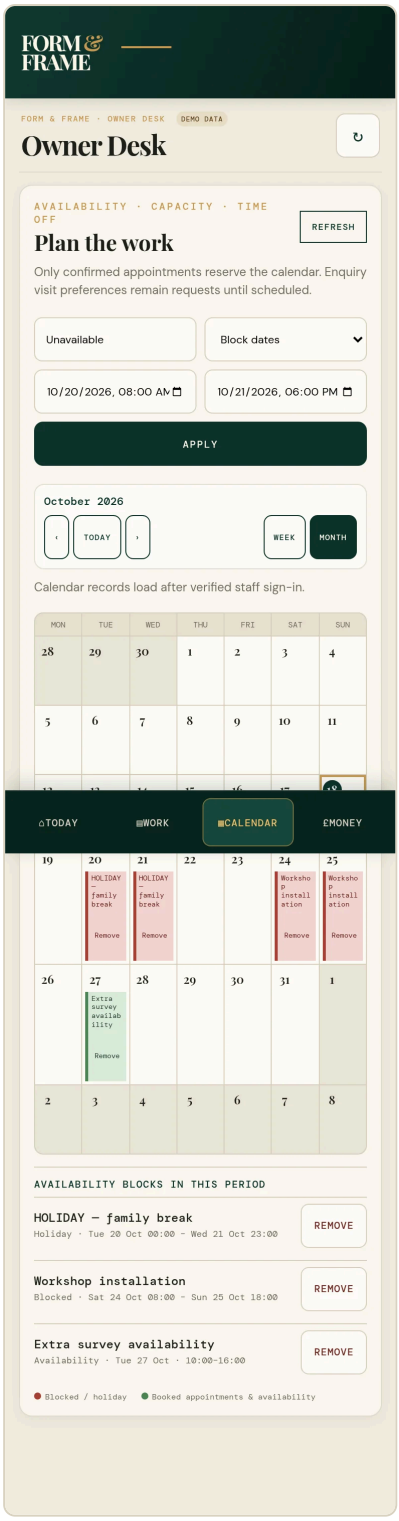
Purpose. Build jobs created from an accepted quote. **Flow.** accepted → ready to build / in progress → quality check → ready for install → installation scheduled → installed → completed (or cancelled); the UI offers only the next legal step and the database trigger rejects illegal jumps. **Data.** Agreed total (copied from the accepted quote), planned start, target completion, actual cost, assigned member. **Actions.** Convert accepted quote to job; advance status; plan build dates; record actual job costs. **Number.** `FFJ-YYYYMMDD-XXXX`, browser-generated (`app.js:1296`). **Permissions.** Owner and staff, including **actual cost** (PO finding). **Tests.** `workflow.test.mjs`, `assignment.test.mjs`, `business-migration.test.mjs`.

M6 Calendar and availability

Purpose. Plan the work; only saved, conflict-checked appointments reserve time ("A requested visit window is not a booking"). **Actions.** Month/week views with previous/next/today; add a block (Block dates, Holiday, Add availability); remove blocks; retry on load failure. **Backend.** `appointments`, `availability_blocks`; an exclusion constraint forbids overlapping active appointments and the trigger `prevent_calendar_overlap` forbids booking into blocked time (and blocks over reserved appointments). **Permissions.** Owner and staff. **Tests.** `calendar-records.test.mjs`, `availability-list.test.mjs`, `datetime-local.test.mjs`, `business-migration.test.mjs`.



M6 calendar panel. DEMO MODE — fictional data, not production.



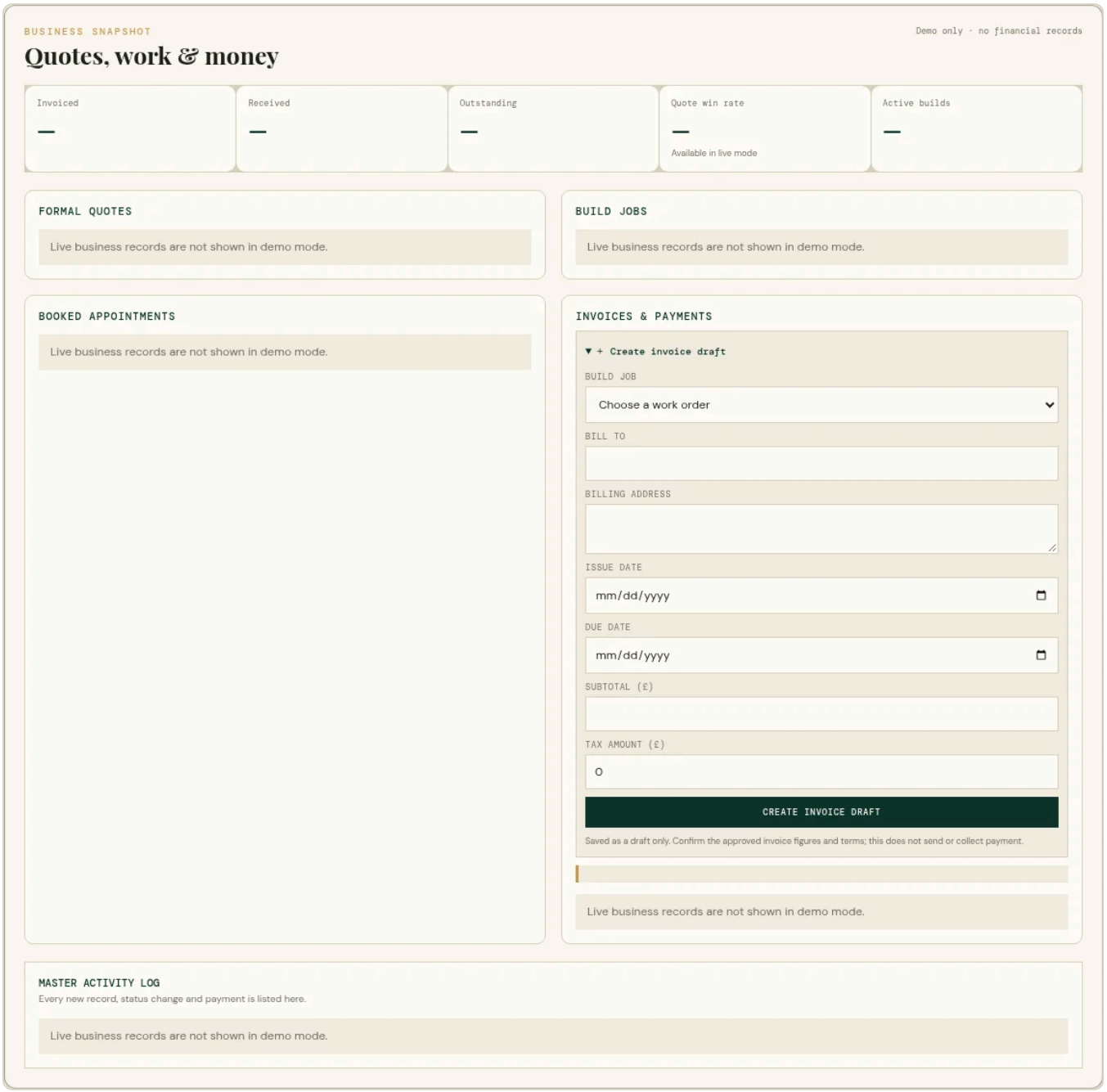
M6 Calendar tab on a phone. DEMO MODE — fictional data, not production.

M7 Appointments and follow-ups

Appointments (survey or installation; start/end; location; assignee) and follow-up tasks (title, due time) are created from the workspace and listed in Today. Saving an appointment sends **no customer message** (the form says so). Follow-ups can be completed. Tests: `calendar-records.test.mjs`, `assignment.test.mjs`. Status: `IMPLEMENTED`.

M8 Invoices

Flow. Create a **draft** from a build job (bill-to name, address, issue and due dates, subtotal and tax amount in £) → mark **sent** → may be **void** (only if no payments). Sent invoices are frozen by `protect_paid_invoice_balance`. A printable invoice document is rendered from the owner's seller details (`invoice-document.mjs`); it refuses to render until legal name, address and contact e-mail are set (`invoiceSettingsReady`). **Marking sent sends nothing. Number.** `FFI-YYYYMMDD-XXXX`, browser-generated (`app.js:1336`). **Tests.** `invoice-document.test.mjs`, `workflow.test.mjs`, `business-migration.test.mjs`.



M8/M9/M10 the Money panel in demo mode, with the "Create invoice draft" form open. DEMO MODE — fictional data, not production.

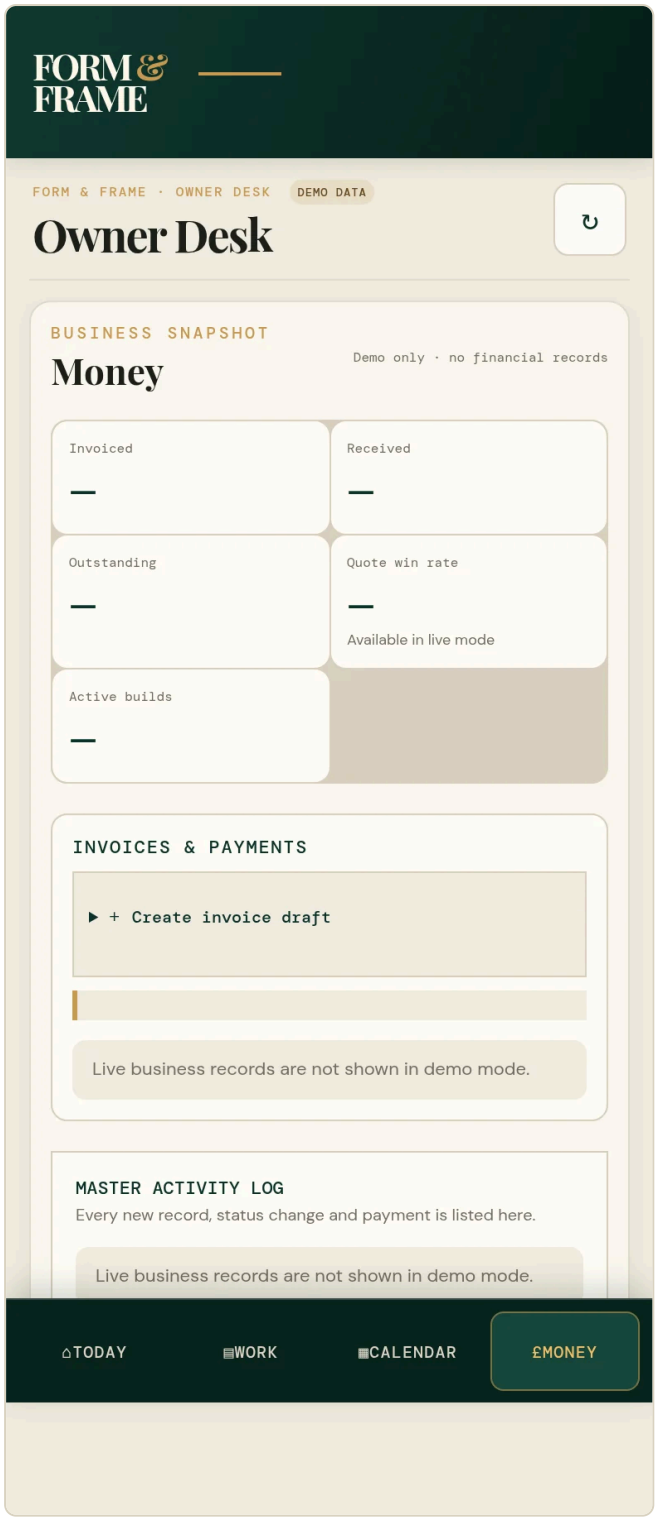
Invoice list, invoice document and overdue flags with real rows: NOT VERIFIABLE. Demo mode shows "Live business records are not shown in demo mode."

M9 Payments (manual recording only)

Flow. Record a payment against a **sent** invoice: amount in £ and method (`bank_transfer`, `card`, `cash`, `stripe`, `other`). The form generates an idempotency key held in `sessionStorage` per (invoice, amount, method), so a double-click or a retry after a lost response does not create a second payment (`payment-idempotency.mjs`). Database triggers lock the invoice row and **reject overpayment**. **Limits.** There is **no way to void, correct or reverse a payment** on `main` (issue #14, draft in PR #43). Choosing method `stripe` only labels a manual entry; **no Stripe integration exists**. **Permissions.** Owner and staff (PO finding). **Tests.** `payment-idempotency.test.mjs`, `business-migration.test.mjs`.

M10 Money panel and finance strip

Five figures (Invoiced, Received, Outstanding, Quote win rate, Active builds) plus quote, job, appointment, invoice lists. Computed by `buildFinanceSummary` (demo, fictional) and from `invoice_balances` (live). It is a snapshot only: no date range, ageing, export or profit (issue #33). Status: `PARTIAL`.



M10 Money panel on a phone. DEMO MODE — fictional data, not production.

M11 Business settings (seller details)

Owner-only form (`legal name`, billing address, company e-mail, phone, company number, VAT number, payment instructions, footer) in a singleton `business_settings` row. RLS: any staff may read, **only an owner may insert/update**. No tax, company or bank detail is pre-filled. The form is hidden for non-owner roles in the UI; RLS is the real control. Tests: `invoice-document.test.mjs`, `business-migration.test.mjs`. NOT VERIFIABLE on screen (owner login required).

M12 Notification centre and push

Purpose. An in-app inbox of workflow and enquiry events plus device push. **Data.** `notification_events` (own team outbox), per-user read marks, per-user category preferences, push device state and install guidance (iOS needs the app installed to the home screen). **Actions.** Open the bell panel (Inbox / Settings & install), mark all read, set preferences, enable/disable push for this device, icon diagnostics. Opening a push notification deep-links to the enquiry (`push-target.mjs`). **Not shown in demo mode** (the bell is hidden), so **NOT VERIFIABLE** on screen. **Tests.** `notification-centre.test.mjs` , `push-support.test.mjs` , `push-target.test.mjs` , `service-worker.test.mjs` , `notification-badge.test.mjs` , `supabase/notification-centre-migration.test.mjs` .

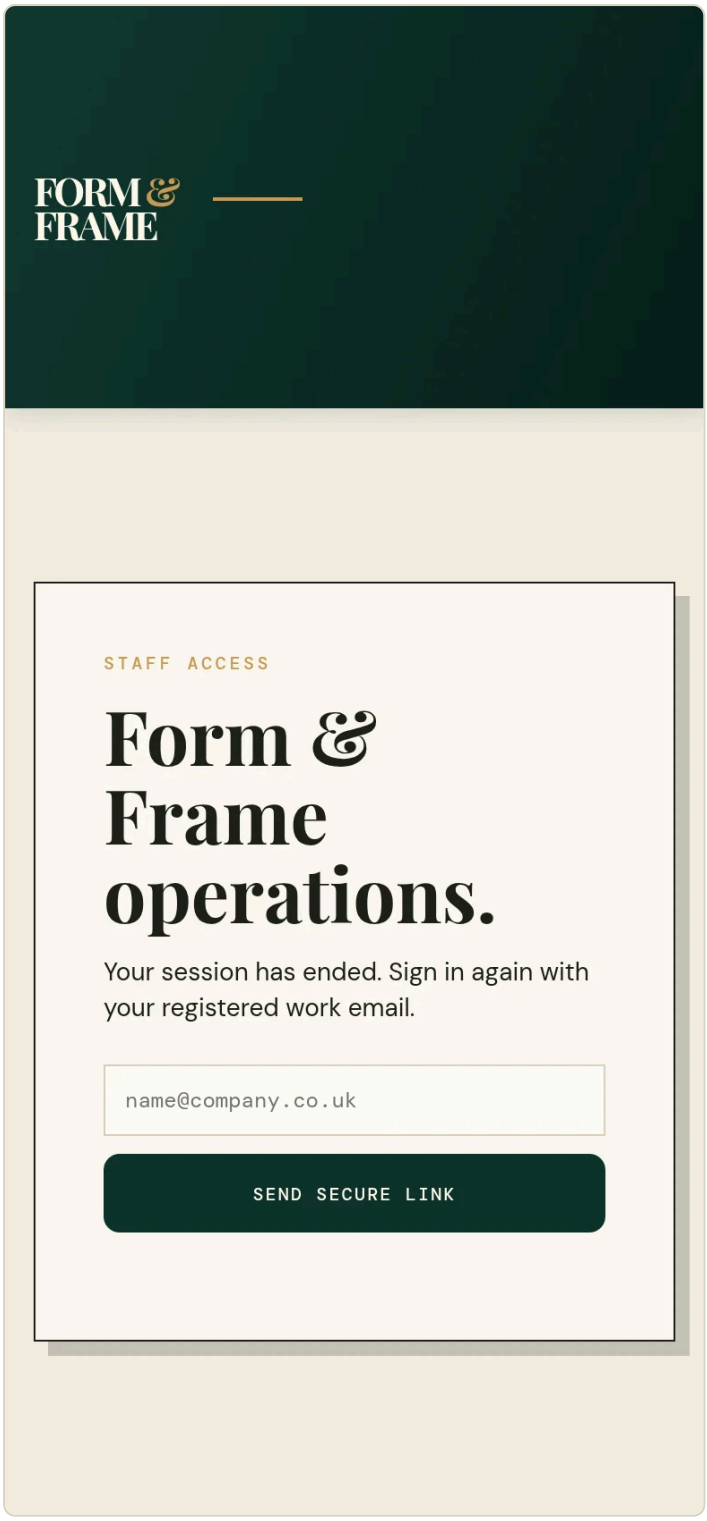
> **Notification inbox and settings panel: NOT VERIFIABLE** (bell hidden in demo; real data needs a login). Pure formatting and filtering logic is covered by tests.

M13 Activity history

An append-only `workflow_activity` table is written by database triggers on every status change and payment; the Money panel shows "Master activity log" (latest 30) and each enquiry workspace shows its own. Shown as actor id, not name (issue #35). Tests: `activity-label.test.mjs` , `business-migration.test.mjs` . NOT VERIFIABLE on screen.

M14 Roles and access

`profiles.role` is `owner` or `staff` . After sign-in `checkStaffAccess` reads the role: no session → "Your session has ended"; signed in without a profile → "not been added to the Form & Frame team"; error → "We couldn't verify your staff access", business data stays hidden. Roles are assigned directly in the database (no UI). **Manager does not exist on `main` .** Owner-only: seller details. **Everything else is available to every staff account.** Draft PRs #23 (permission matrix + unapplied RLS draft) and #42 (role-aware money UI) address this: see Security. Tests: `staff-access.test.mjs` .



Sign-in screen (built site, fictional configuration, no sign-in attempted)

State handling and errors (observed in code)

Every write goes through `saveLive`, which requires the saved row to be returned (`requirePersistedRow`) and otherwise shows an error banner; success banners say exactly what happened ("Quotation recorded as sent. No email was sent."). Destructive or irreversible status changes ask for `window.confirm` (not yet for all status selects: issue #30). A realtime subscription refreshes lists; if it fails, a warning asks the user to press Refresh.

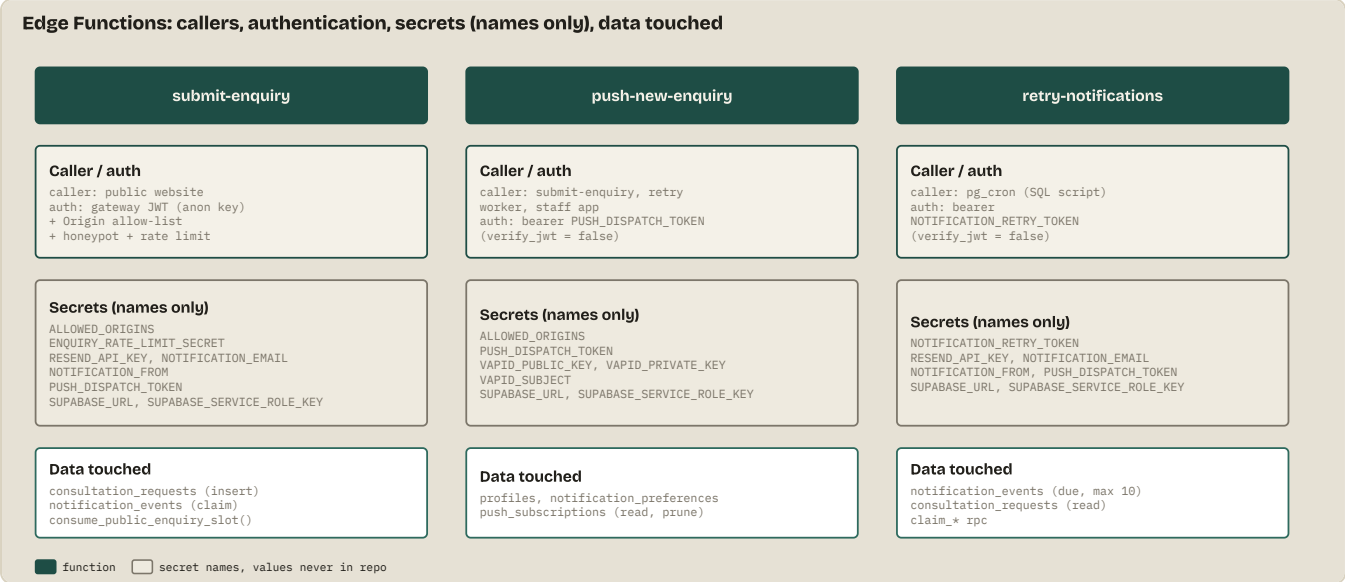
Evidence: `E-09` *to* `E-16`, `E-51` *to* `E-55` *and the stored test logs* `E-37` *to* `E-40`.

SECTION 06

5a. Backend

The backend is a Supabase project plus three Edge Functions written in TypeScript/JavaScript for Deno. All handler logic lives in plain `.mjs` files with injected dependencies so that it can be tested offline. **There is no other server code.**

Edge Functions (`supabase/functions/`)



Edge Functions: callers, authentication, secrets (names only), data touched

Function	Caller	Authentication (`supabase/config.toml`)	Purpose
`submit-enquiry`	Public website	`verify_jwt = true` (the anon key satisfies the gateway) plus handler checks: Origin must be on `ALLOWED_ORIGINS` (403 otherwise), POST only, 32 KB body cap, honeypot `company_website`, UUID idempotency key, field validation, 12 KB project-spec cap	Validates and saves an enquiry, rate-limits it, claims a notification event and sends the owner alert e-mail and push dispatch. Returns `{ reference }`.
`push-new-enquiry`	`submit-enquiry`, the retry worker, the staff app	`verify_jwt = false`; handler requires `Authorization: Bearer <PUSH_DISPATCH_TOKEN>`	Sends Web Push to subscribed staff devices honouring each user's notification preferences; prunes expired subscriptions.
`retry-notifications`	`pg_cron` via a SQL script (not applied by migrations)	`verify_jwt = false`; handler requires `Bearer <NOTIFICATION_RETRY_TOKEN>` compared in constant time	Processes at most 10 due events per run; exponential backoff capped at 16 minutes; recovers expired claims.

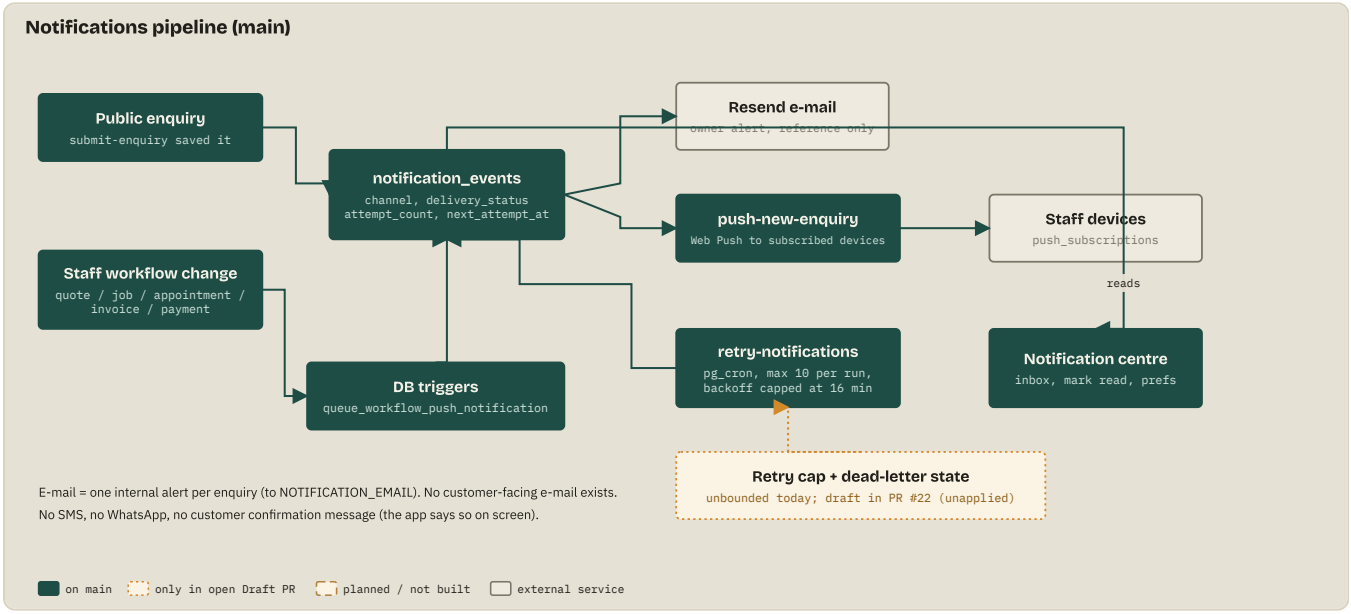
Secrets are referenced by **name only** in this book: `ALLOWED_ORIGINS`, `ENQUIRY_RATE_LIMIT_SECRET`, `RESEND_API_KEY`, `NOTIFICATION_EMAIL`, `NOTIFICATION_FROM`, `PUSH_DISPATCH_TOKEN`, `NOTIFICATION_RETRY_TOKEN`, `VAPID_PUBLIC_KEY`, `VAPID_PRIVATE_KEY`, `VAPID_SUBJECT`, `SUPABASE_URL`, `SUPABASE_SERVICE_ROLE_KEY`. They are set as Supabase Function Secrets (and the retry token in Vault); none is in the repository. Whether they are set in the live project is **not verified**. [`E-19`]

How an enquiry is accepted (`submit-enquiry/handler.mjs`)

1. CORS: preflight allowed only for allowed origins; other origins receive 403.
2. Parse JSON (413 if too large; 400 if invalid); a filled honeypot returns a generic 400.
3. Validate: UUID idempotency key, name 2+ chars, postcode, at least one of e-mail/phone, valid e-mail shape, timestamps, project spec size (422 on failure).
4. Require server configuration (`SUPABASE_URL`, service-role key, a 32+ character `ENQUIRY_RATE_LIMIT_SECRET`) or fail closed with 503.
5. Look up the idempotency key first: a repeat returns the saved reference and continues delivery; otherwise hash the client address with HMAC-SHA-256 and call `consume_public_enquiry_slot` (returns allowed, or 429 with `Retry-After`).
6. Insert into `consultation_requests`; on a unique-index race, reconcile by idempotency key.
7. Claim the e-mail notification (`claim_new_enquiry_notification`, a row-locked RPC), send via Resend if `RESEND_API_KEY`, `NOTIFICATION_EMAIL`, `NOTIFICATION_FROM` are set, record the outcome; then dispatch push using `PUSH_DISPATCH_TOKEN`. A delivery failure never loses the enquiry: the event stays retryable.

Tested by 27 tests in `handler.test.mjs` (CORS, size, honeypot, validation, idempotency, rate limit, failure paths). **Not tested:** the deployed function on Deno, the real Resend API, real cron. [`E-18`]

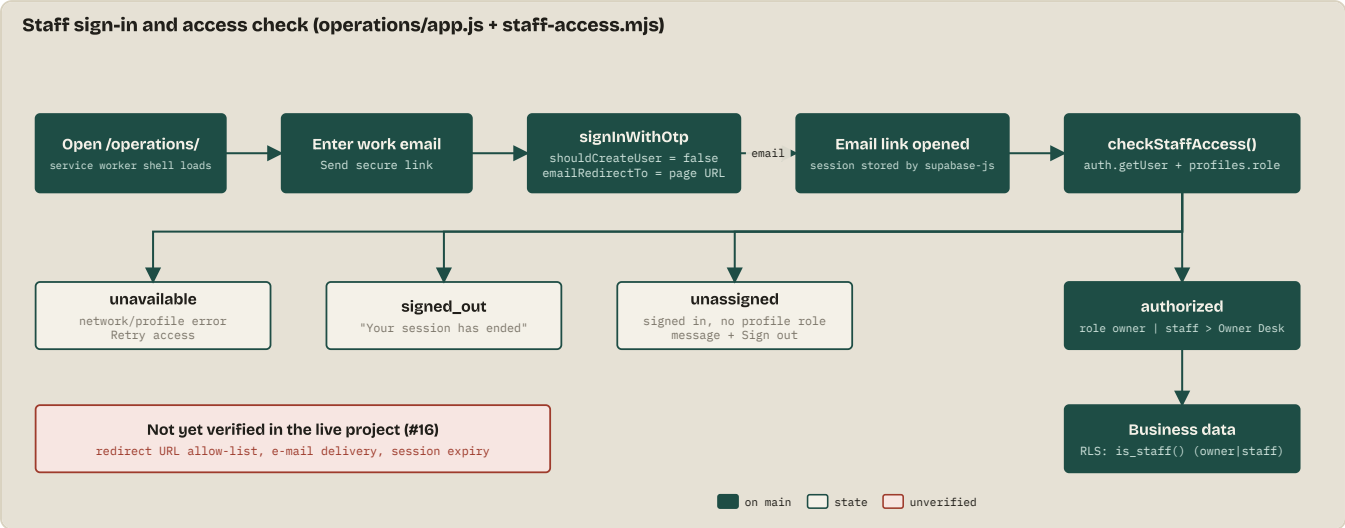
Notification delivery



Notifications pipeline

- **Outbox.** `notification_events` stores channel (`email`, `push`, `webhook`), event type, JSON payload (reference only; the push trigger uses a generic no-money payload), `delivery_status`, attempt count, `next_attempt_at`, a `claim_until` lease.
- **Workflow triggers.** `queue_workflow_push_notification` (migrations 20261008 and 20261016) enqueues events on quote, job, appointment, invoice and payment changes.
- **Retry.** Scheduled by `supabase/schedule_notification_retries.sql` (a script to run manually; not a migration). **Known limit:** there is no retry cap or dead-letter state on `main` (issue #13; draft in PR #22, unapplied). [`E-20`]
- **No customer messages.** E-mail goes to one internal address (`NOTIFICATION_EMAIL`); there is no customer confirmation by e-mail, SMS or WhatsApp. The staff app says so on screen after saving appointments and quotes.

Authentication flow



Staff sign-in and access check

Supabase Auth with an e-mail magic link (`signInWithOtp`, `shouldCreateUser:false`, redirect to the current page). The browser keeps the session (supabase-js default). Access is decided by `profiles.role` and enforced by RLS. **Not verified in the live project:** the redirect-URL allow-list, e-mail deliverability and session lifetime (issue #16).

Public build configuration

`scripts/public-config.mjs` refuses: a production build without both Supabase values; a URL that is not `https://<ref>.supabase.co`; a project ref other than the pinned one; a key that is not an `anon`-role JWT for that ref; a malformed VAPID public key. Six tests cover it (`public-config.test.mjs`). [`E-21`]

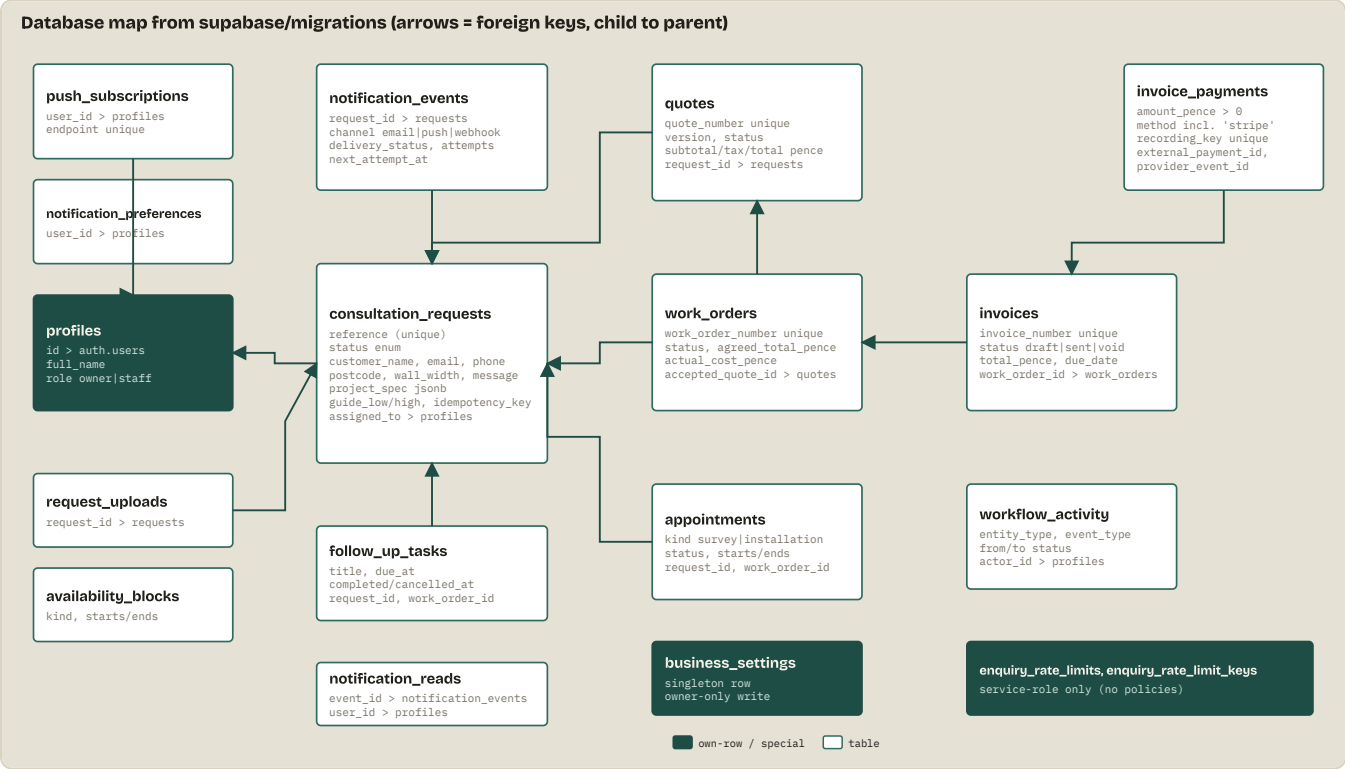
Storage

A private bucket `project-uploads` with a staff-only read policy exists in the first migration. **Nothing in the public site or Edge Functions uploads to it**: the staff workspace only *reads* `request_uploads` and creates 10-minute signed URLs (`app.js:871-878`), and no code on `main` writes to that table or bucket. Whether any photo ever arrives (for example by a manual upload in the Supabase dashboard) is **not verified**.

SECTION 07

5b. Database (from `supabase/migrations/`)

Ten migrations, applied by hand according to the repository's own runbook; **the live schema state is not verified**. Eighteen tables and two views in `public`, all with Row Level Security enabled.



Database map: tables and foreign keys, from the migrations

Tables

Table	Purpose	Introduced
`profiles`	One row per staff member; `role in ('owner','staff')`; id references `auth.users`	20260906
`consultation_requests`	The enquiry **and** the customer record (name, e-mail, phone, postcode, wall width, brief, project spec JSON, guide range, preferred window, source, staff notes, assignee, idempotency key, site-assessment flag)	20260906 + later
`request_uploads`, `availability_blocks`	Photos metadata; blocked / holiday / available windows	20260906
`notification_events`	Outbox with retry bookkeeping	20260906, 20261004, 20261006, 20261008

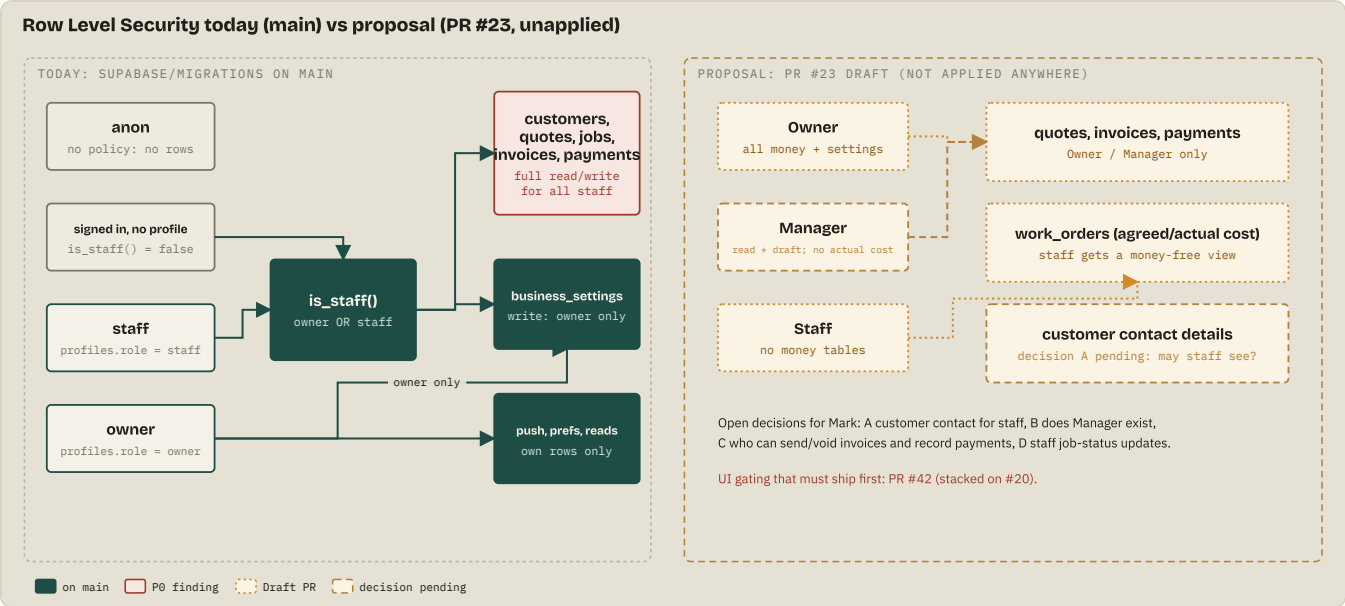
Table	Purpose	Introduced
`quotes`, `work_orders`, `appointments`, `follow_up_tasks`, `invoices`, `invoice_payments`, `workflow_activity`, `push_subscriptions`	The business workflow	20261005
`business_settings`	Singleton seller details	20261009 (invoice settings)
`enquiry_rate_limits`, `enquiry_rate_limit_keys`	Public enquiry throttling (service role only)	20261009 (rate limits)
`notification_preferences`, `notification_reads`	Per-user alert preferences and read marks	20261016

Views: `invoice_balances` (paid, outstanding, overdue) and `work_order_financial_summary`, both `security_invoker` so they inherit the caller's RLS.

Integrity rules enforced in the database

- **Money in integer pence**, currency fixed to GBP, tax as basis points with `tax_pence = round(subtotal * rate)` checked; `total_pence` is a generated column.
- **Status machines** by trigger `enforce_workflow_status_transition` for quotes, jobs, appointments and invoices (illegal jumps raise errors); an **accepted quote is locked**; a **job requires an accepted quote** for the same enquiry; a **sent invoice is locked** (only sent→void), **void is terminal**, an invoice **with payments cannot be voided**, and totals cannot drop below paid.
- **Payments**: amount > 0, **overpayment blocked** with a row lock, only `sent` invoices accept payments, `recording_key` unique (idempotency), `external_payment_id` and `provider_event_id` unique (provisioned for a future payment provider; nothing writes them).
- **Calendar**: an exclusion constraint (`exclude using gist` on the time range, `20261005…sql:76`) stops two active appointments overlapping; the trigger `prevent_calendar_overlap` (advisory-locked) stops an appointment over a `blocked`/`booked` window and a block over a scheduled or confirmed appointment.
- **Quote gate**: when `assessment_required`, a quote needs a completed survey (`enforce_quote_assessment_gate`).
- **Audit trail**: `log_workflow_record_update` writes `workflow_activity` rows.
- **Hardening**: all application `SECURITY DEFINER` functions use an empty `search_path` (migration 20261007; asserted by a test).
- **Identifiers**: quote, job and invoice numbers are `text unique`, generated **by the browser** (see M4/M5/M8).

Row Level Security today



RLS today versus the proposal in PR #23

`is_staff()` is true for any profile with role `owner` or `staff`. Nearly every table's policy is `using (public.is_staff())`, so **any staff account can read and write customers, quotes, jobs, invoices and payments** (finding P0, issue #9). Exceptions: `business_settings` write is owner-only; push subscriptions, preferences and read marks are own-row only; the rate-limit tables have RLS and **no policy**, so only the service role can use them; `profiles` is readable by staff; storage `project-uploads` is staff-read.

Scripts that are not migrations

`supabase/schedule_notification_retries.sql`, `schedule_enquiry_rate_limit_cleanup.sql`, `audit_remote_schema.sql`, `audit_public_enquiry_retention.sql`: operator scripts for the owner to run deliberately in the Supabase SQL editor. The audit scripts are for **inspecting** the live project; they were **not run** for this book.

Not in `main` (Draft PRs)

Draft	What it would change	State
PR #23	Least-privilege role model (Owner/Manager/Staff), money-free job view, security_invoker views	SQL kept in `supabase/drafts/…_DRAFT.sql` ("DO NOT APPLY"); tests incl. real RLS on throwaway PGlite pass
PR #41	Server-side sequences for quote, job and invoice numbers	draft SQL, unapplied
PR #43	Append-only payment reversals	draft SQL, unapplied
PR #22	Retry cap and dead-letter state	draft SQL, unapplied

Order matters: the permissions draft must not be applied before the app is updated (PR #42), or staff will lose the money panels.

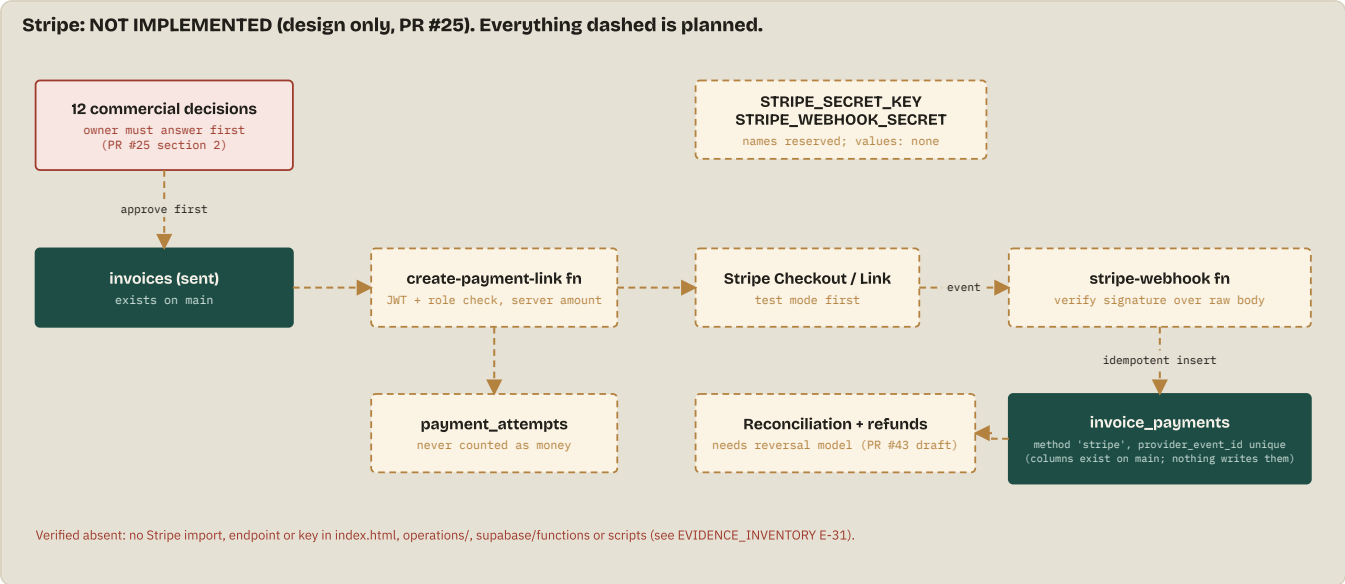
Evidence: `E-17`, `E-28`, `E-29`, `E-30`, `E-33`, `E-35`, `E-41` *to* `E-50`.

SECTION 08

5c. Integrations

Integration	Used for	Where in the code	Status	Notes
Supabase (Auth, Postgres/PostgREST, Realtime, Storage, Edge Functions, Cron, Vault)	Entire backend	`operations/app.js`, `index.html` form, `supabase/`	IMPLEMENTED	Project ref pinned in `scripts/public-config.mjs` and `supabase/config.toml`. Live state not verified.
Vercel	Static hosting, build (`node scripts/build-public.mjs`)	`vercel.json`	IMPLEMENTED	Preview and Production state not verified. The public site's "Staff access" link points to `form-and-frame.vercel.app`.
GitHub Actions	CI (`quality.yml`)	`.github/workflows/quality.yml`	VERIFIED	The same steps were replayed locally on Node 24 for this book (all passed); the GitHub-hosted run itself was not triggered by this work.
Resend	Owner alert e-mail on a new enquiry (and retries)	`submit-enquiry`, `retry-notifications`	IMPLEMENTED	Only if `RESEND_API_KEY`, `NOTIFICATION_EMAIL`, `NOTIFICATION_FROM` are set. Real delivery not verified; sending domain not confirmed (pending Mark).
Web Push (VAPID)	Phone/desktop alerts	`push-new-enquiry`, `service-worker.js`, `push-support.mjs`	IMPLEMENTED	Needs `VAPID_*` secrets and a device subscription. Real device receipt not verified here.
esm.sh	Loads `@supabase/supabase-js@2.117.2` in the staff app and Edge Functions	`operations/app.js:1`, `*/index.ts`	IMPLEMENTED	Runtime dependency on a third-party CDN without integrity check (issues #10/#11; Draft PR #27 vendors it).
Google Fonts	Web fonts	`index.html:15`, `operations/index.html:15`	IMPLEMENTED	Third-party request.
Stripe	Online payments	none	NOT IMPLEMENTED	See below.
E-mail to customers / SMS / WhatsApp	Customer messaging	none	NOT IMPLEMENTED	The app states "No email was sent" after quote/invoice status changes.
AI / language model	Project assistant	none	NOT IMPLEMENTED	The assistant is rule-based and local.
Analytics / tracking	none found	none	NOT IMPLEMENTED	No analytics script in `index.html`.

Stripe: absent, shown as planned



Stripe: not implemented (design only)

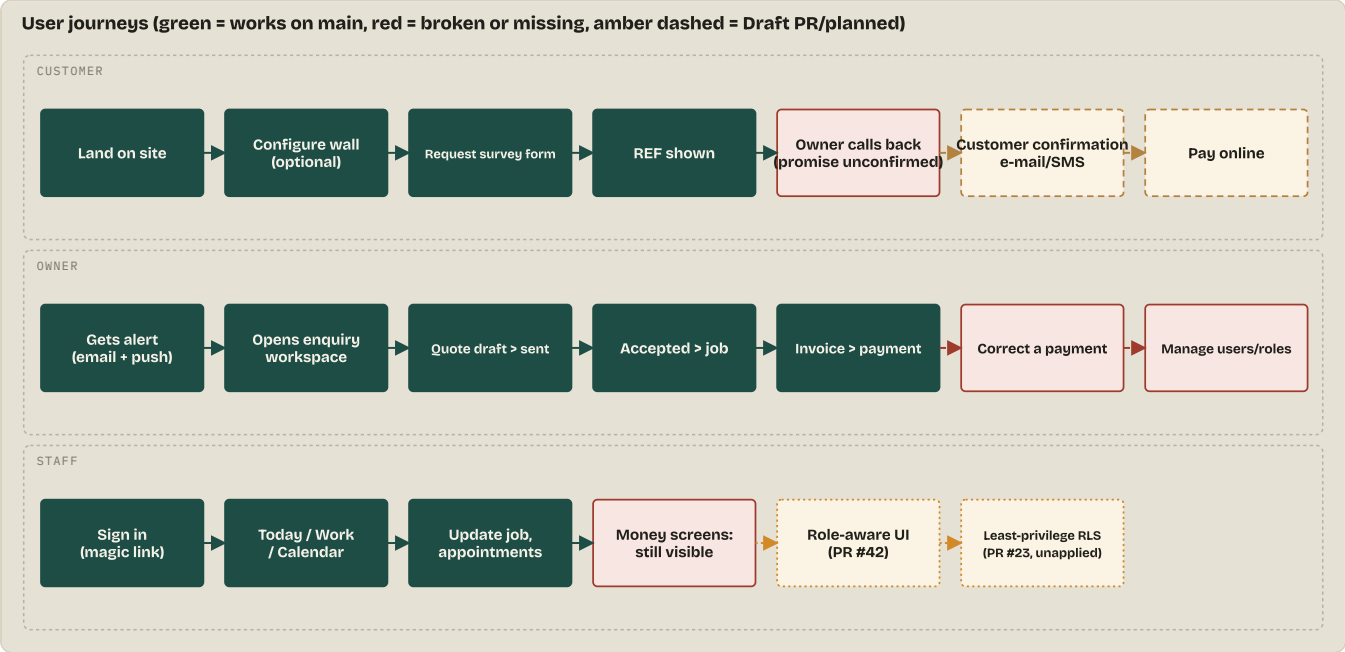
A repository-wide search for "stripe" over code (`.mjs`, `.js`, `.ts`, `.html`, `.sql`, `.toml`, `.json`, `.yml`) finds only: the `stripe` value allowed in the `invoice_payments.method` check and its two provider-id columns, a UI test fixture string, and the prebuilt `docs/MASTER_DOCUMENTATION.html`; Markdown mentions are in `OPERATIONS_HUB.md`, `OVERNIGHT_OPERATIONS_HANDOFF.md` and `supabase/ACTIVATION_RUNBOOK.md`. **There is no Stripe library, key, endpoint, webhook or checkout code.** [`E-17`] Draft PR #25 holds a design document and a test that fails if Stripe code appears; it lists **12 commercial decisions** that only the owner can make (does the customer pay online, deposits, payment methods, VAT, refunds, who holds the Stripe account…). No implementation should start before those answers.

Pending configuration (Mark, 19 October 2026)

Item	State
Stripe account, keys and webhook	Pending, configured by Mark on 19 Oct (not verified). Nothing is implemented in code; values are never recorded in this book.
Production domain	Pending, configured by Mark on 19 Oct (not verified).
Professional business e-mail (also the future Resend sender and notification address)	Pending, configured by Mark on 19 Oct (not verified).

SECTION 09

6. User journeys



Customer, owner and staff journeys. Green works on main; red is broken or missing; dotted amber exists only in a Draft PR or is planned

6.1 Customer

Step	What happens	Outcome	Status
1. Land on the site	Hero, navigation, title strip.	Understands the offer.	Works. Claims in the copy are unconfirmed (pending Mark).
2. Configure a wall (optional)	Sets wall, bays, finish; sees a live guide range; may save the spec locally or send it with the survey.	A guide price in the browser; spec copied into the brief.	Works; pricing logic untested.
3. Request a survey	Fills name, phone or e-mail, postcode, width, brief; optional visit window; submits.	`REF FF-…` is shown; the enquiry is saved; the owner gets an alert.	Implemented and unit-tested; **live path not observed**.
4. Confirmation to the customer	None is sent. The page shows the reference only.	The customer has no copy of the enquiry and no way to contact the business from the page.	**Missing** (no e-mail/SMS; no phone or e-mail is published).
5. Callback	The page promises a call "within one working day".	Depends on the owner; the promise is not confirmed by the owner.	**Unconfirmed claim.**
6. Quote, acceptance, payment	Handled offline: the owner sends the quote outside the app. Online acceptance and payment do not exist.	Customer pays by other means.	**Missing** (Stripe not implemented).

Decisions on the way: a customer may skip the configurator; may enter a phone or an e-mail (one field); may propose a visit window, which is only a request. Failure paths: validation messages inline; 429 "Please wait about N minutes"; timeout message after 30 s with duplicate protection.

6.2 Owner

Step	What happens	Status
1. Alert	E-mail to the internal address (if Resend is configured) and Web Push to enrolled devices; an entry in the notification centre.	Implemented; real delivery not verified.
2. Sign in	E-mail magic link; role is checked.	Implemented; live link/redirects not verified.
3. Open the enquiry	The workspace shows the next action; the enquiry moves from New to Opened.	Verified in demo and by tests.
4. Survey / assessment	Optionally require a site assessment; schedule a survey appointment (conflict-checked); mark it completed.	Implemented.
5. Quote	Create a draft (scope, subtotal, explicit tax), mark sent (no e-mail goes out), then accepted.	Implemented; a **sent quote has to be e-mailed manually**.
6. Job	Convert the accepted quote into a job; step it through to completed.	Implemented.
7. Invoice and payment	Draft invoice from the job, mark sent, record payments manually.	Implemented; invoice and payment numbers/records are browser-driven.
8. Correct a mistake	A wrongly recorded payment **cannot be corrected in the app**.	**Broken / missing** (#14, PR #43).
9. Manage the team	Add a staff member, change a role.	**Missing**: roles are set directly in the database (#31).
10. Report	Five headline figures only.	**Partial** (#33).

6.3 Staff

Step	What happens	Status
1. Sign in	Same magic link; the account must have a `profiles` row.	Implemented.
2. Daily work	Today, Work, Calendar tabs; update appointments, follow-ups, job status.	Implemented.
3. Money screens	**Any staff account can see quotes, invoices, payments, agreed totals and actual job costs, and can record payments.**	**Broken (PO #9, #28).** Fix proposed in PR #42 (UI) and PR #23 (RLS), neither merged or applied.
4. Customer contact details	Visible to staff; whether they should be is decision A.	Pending Mark.

Evidence: `E-05`, `E-06`, `E-08`, `E-09`, `E-11`, `E-14`, `E-15`, `E-17`, `E-34`.

SECTION 10

7. Feature matrix

Statuses are exactly: IMPLEMENTED, VERIFIED, PARTIAL, BROKEN, PLANNED, NOT IMPLEMENTED, BLOCKED (definitions in the README). **VERIFIED** names its proof in the Tests column (an automated test run on Node 24 for this book, or an observed headless-browser run). "Version" is the commit the row was assessed on: `31a08f6` is `main`; rows that exist only in a Draft PR say so in Dependencies and show the PR. Test counts are the static count of `test()` calls (the runner reports 183 in total; the static count is 182, one test is declared in a form the counter misses).

Feature	Route	Component	Backend	Status	Tests (proof)	Dependencies / notes	Issue	PR	Version
Public site shell, nav, sections	`/`	`index.html`	static	VERIFIED	observed render 1440/390; `check-public-build.mjs` run	Google Fonts			31a08f6
Configurator and guide price	`/#specify`	`index.html` inline JS	none (localStorage)	IMPLEMENTED	none touch pricing	prices unconfirmed			31a08f6
Survey vs proposal slider	`/#survey`	`index.html`	none	IMPLEMENTED	none	"real Burnham job" claim unconfirmed	#12	#26	31a08f6
Enquiry form UI and validation	`/#request`	`index.html`	none until submit	VERIFIED	observed validation messages				31a08f6
Enquiry submit, end to end	`/#request`	form + `submit-enquiry`	Edge fn + DB	IMPLEMENTED	live path not observed	needs live Supabase config			31a08f6
`submit-enquiry` handler logic	n/a	`handler.mjs`	Edge fn	VERIFIED	`handler.test.mjs` (27)	injected mocks, not Deno			31a08f6
Public enquiry rate limit	n/a	`consume_public_enquiry_slot`	DB	IMPLEMENTED	mocked RPC only in handler tests	`ENQUIRY_RATE_LIMIT_SECRET`			31a08f6
Project assistant (rule-based)	`/`	`index.html`	none	IMPLEMENTED	opens (observed); replies untested	no language model			31a08f6
"Completed works" section	`/#works`	`index.html`, `assets/cases`	none	BLOCKED	n/a	needs Mark to validate the four projects	#12	#26	31a08f6
"Sample review" testimonials	`/#testimonials`	`index.html`	none	BROKEN	n/a	placeholder text visible publicly; removed by PR #8	#12	#8	31a08f6
Published phone/e-mail	`/`	none	none	BLOCKED	n/a	none published; needs verified details	#12	#26	31a08f6
Privacy notice / terms	`/`	none	none	NOT IMPLEMENTED	n/a	needed before taking money or data at scale			31a08f6
robots.txt, sitemap.xml	`/robots.txt`	none	none	PLANNED	PR #8 test	in PR #8 only		#8	31a08f6
Security headers and CSP	all	`vercel.json`	Vercel	PLANNED	`csp.test.mjs` in PR #27	none on main	#10	#27, #8	31a08f6
Self-hosted supabase-js (no CDN)	`/operations/`	`operations/vendor/`	none	PLANNED	`vendor-integrity.test.mjs` in PR #27	main loads esm.sh	#11	#27	31a08f6
Build boundary and config guard	build	`build-public.mjs`, `public-config.mjs`	none	VERIFIED	`public-config.test.mjs` (6); CI steps replayed				31a08f6
CI quality workflow	GitHub	`quality.yml`	Actions	VERIFIED	all steps replayed on Node 24	PRs not targeting main skip CI			31a08f6
Staff sign-in (magic link)	`/operations/`	`app.js`	Supabase Auth	IMPLEMENTED	sign-in screen observed; live link not tried	redirect allow-list unverified	#16		31a08f6

Feature	Route	Component	Backend	Status	Tests (proof)	Dependencies / notes	Issue	PR	Version
Staff access check	`/operations/`	`staff-access.mjs`	`profiles`	VERIFIED	`staff-access.test.mjs` (3); signed-out message observed			#20 adds session tests	31a08f6
Demo mode	`/operations/`	`app.js startDemo`	none	VERIFIED	observed run, no config	fictional data			31a08f6
Today view and metrics	`/operations/`	`today-view.mjs`	DB reads	VERIFIED	`today-view.test.mjs`; demo observed				31a08f6
Enquiry list and workspace	`/operations/`	`enquiry-workspace*.mjs`	`consultation_requests`	VERIFIED	`enquiry-workspace*.test.mjs` (17); demo observed				31a08f6
Quote draft and status	workspace	`app.js`	`quotes`	IMPLEMENTED	transitions and tax maths verified by `workflow.test.mjs` (3)	live screens not observed			31a08f6
Quote/job/invoice numbers	workspace	`app.js` (browser)	unique column	PARTIAL	none	random suffix; server sequence in PR #41	#15, #29	#41	31a08f6
Jobs (work orders)	workspace	`app.js`	`work_orders`	IMPLEMENTED	`business-migration.test.mjs` (static)				31a08f6
Calendar and availability	`/operations/`	`calendar-records.mjs`	`appointments`, blocks	VERIFIED	`calendar-records`, `availability-list` tests (18); demo observed				31a08f6
Appointments and follow-ups	workspace	`app.js`	DB	IMPLEMENTED	static migration test	no customer message sent			31a08f6
Invoices (draft, sent, void)	Money	`app.js`	`invoices`	IMPLEMENTED	static migration test	marking sent sends nothing			31a08f6
Printable invoice document	Money	`invoice-document.mjs`	`business_settings`	VERIFIED	`invoice-document.test.mjs` (5)	needs seller details			31a08f6
Payment recording (idempotent)	Money	`payment-idempotency.mjs`	`invoice_payments`	VERIFIED	`payment-idempotency.test.mjs` (4)	triggers block overpayment			31a08f6
Payment void / correction	Money	none	none	PLANNED	`payment-reversals.pglite.test.mjs` in PR #43	no way to fix a wrong payment on main	#14	#43	31a08f6
Finance panel (5 figures)	Money	`project-model.mjs`	`invoice_balances`	PARTIAL	`project-model.test.mjs`	no ranges, ageing, export	#33		31a08f6
Business settings (seller details)	Money	`app.js`	`business_settings`	IMPLEMENTED	static migration test	owner-only write by RLS	#37		31a08f6
Notification centre logic	Alerts	`notification-centre.mjs`	`notification_events`	VERIFIED	`notification-centre.test.mjs` (8)				31a08f6
Notification centre screen	Alerts	`notification-view.mjs`	DB	IMPLEMENTED	no test file; bell hidden in demo				31a08f6
Web Push to devices	n/a	`push-new-enquiry`	Edge fn	IMPLEMENTED	handler logic `handler.test.mjs` (17); no real device run	VAPID secrets			31a08f6
Notification retry worker	n/a	`retry-notifications`	Edge fn + cron	IMPLEMENTED	handler tests (8) + migration tests (8)	cron script manual			31a08f6

Feature	Route	Component	Backend	Status	Tests (proof)	Dependencies / notes	Issue	PR	Version
Retry cap and dead letter	n/a	none	DB	PLANNED	`notification-retry-cap.draft.test.mjs` in PR #22	unbounded retries on main	#13	#22	31a08f6
Activity history	Money, workspace	`activity-label.mjs`	`workflow_activity`	IMPLEMENTED	`activity-label.test.mjs`	actor shown as id	#35		31a08f6
PWA install, service worker	`/operations/`	`service-worker.js`	none	IMPLEMENTED	`service-worker.test.mjs` (4), badge test (5); no real install				31a08f6
Financial data access control	DB	RLS `is_staff()`	Postgres	BROKEN	reproduced by baseline test in PR #23 (run now, passes)	any staff account reads money tables	#9, #28	#23, #42	31a08f6
Role-aware money UI	`/operations/`	`role-capabilities.mjs`	none	PLANNED	`role-gating.app.test.mjs` in PR #42	needs PR #20 harness	#28	#42	31a08f6
Manager role (optional)	n/a	none	`profiles.role`	NOT IMPLEMENTED	n/a	not needed for now: Mark decided 18 Oct that both Owners (Thiago, Antonio) have identical full access; proposed row only	#9	#23	31a08f6
User management UI	n/a	none	none	NOT IMPLEMENTED	n/a	roles set in DB	#31		31a08f6
Customer entity and de-duplication	n/a	none	none	NOT IMPLEMENTED	n/a	customer = enquiry row	#32		31a08f6
Stripe / online payments	n/a	none	none	NOT IMPLEMENTED	`stripe-absence.test.mjs` in PR #25	12 owner decisions; Stripe config pending, Mark configures 19 Oct (not verified)	#18	#25	31a08f6
Customer e-mail / SMS	n/a	none	none	NOT IMPLEMENTED	n/a				31a08f6
Browser / E2E / accessibility tests	n/a	none	none	NOT IMPLEMENTED	n/a	no Playwright/axe on main	#36	#20	31a08f6
Master project doc	docs	`MASTER_PROJECT.md`	none	PLANNED	`master-project.test.mjs` in PR #19		#17	#19	31a08f6

Rows marked `VERIFIED` are proven at the level of their named proof only: a unit test is not a live run, and a demo-mode observation is not a signed-in production observation.

Evidence: every row's proof is named in its Tests column; run logs are `E-37` to `E-40`; code locations in the other chapters' evidence lines.

SECTION 11

8. Security

Scope: what the code on `main` (`31a08f6`) enforces, what it does not, and what Draft PRs propose. Nothing here was tested against production or against a real Supabase project, and no penetration testing was done. Pending weaknesses are described at the level of the missing control, with no steps to exploit them.

8.1 Summary

Area	State on main	Evidence	Status
Who can sign in	Supabase Auth, e-mail magic link; the app then needs a `profiles` row with role `owner` or `staff`.	`E-32`	IMPLEMENTED
Anonymous access to data	Tables have RLS; anonymous users have no policies, intake goes through a service-role Edge Function.	`E-33`	IMPLEMENTED
Separation of money from general staff	**None.** One helper, `is_staff()`, gates almost every policy.	`E-34`	BROKEN (PO #9, #28)
Owner-only writes	`business_settings` only.	`E-34`	IMPLEMENTED
Hard deletes of quotes, jobs, invoices, payments	Not allowed through the API (no delete policies).	`E-34`	IMPLEMENTED
Overpayment, status skips, edits of accepted quotes and sent invoices	Blocked by database triggers.	`E-35`	IMPLEMENTED
Content-Security-Policy and security headers	None configured on `main`.	`E-23`, `E-24`	PLANNED (#10, PR #27, PR #8)
Third-party script integrity	`supabase-js` is imported from esm.sh at an exact version (2.117.2) but without an integrity check.	`E-24`	PLANNED (#11, PR #27)
Webhooks	None exist, so none to sign.	`E-36`	NOT IMPLEMENTED
Secret handling	Server secrets live in Supabase; the public build never reads them and refuses unsafe config.	`E-19`, `E-21`	VERIFIED (`public-config.test.mjs`, build guard run)

8.2 Roles and the current permission model

`profiles.role` accepts `owner` and `staff`. The helper `is_staff()` is true for both. Policies for customer enquiries, uploads, availability, appointments, follow-ups, quotes, jobs (including agreed total and actual cost), invoices, payments and the activity log all use it. Only writes to `business_settings` require `owner`.

Consequence: there is effectively one role for everything except invoice seller settings. Hiding buttons in the interface is not a control; the database permits the reads and writes (see the demo-mode screenshots: the money tab is simply visible to a staff user).

Current versus proposed

The proposal is Draft PR #23 (`PERMISSION_MATRIX.md`) with the UI changes in PR #42. **Nothing is applied.** The migration sits outside `supabase/migrations/` on purpose, and PR #23 states it must not be applied before PR #42 ships, otherwise the app would show errors to staff.

Object	Owner now	Staff now	Owner proposed	Manager (optional, not needed for now)	Staff proposed
Customer details (enquiries)	S I U	S I U	S I U	S I U	S I U (decision A)
Uploads, availability blocks	S I U D	S I U D	S I U D	S I U D	S I U D
Appointments, follow-ups	S I U	S I U	S I U	S I U	S I U
Quotes	S I U	S I U	S I U	S I U	none
Jobs with agreed total and actual cost	S I U	S I U	S I U	S I U (not actual cost)	none (money-free view)
Invoices	S I U	S I U	S I U	S I U drafts only	none
Payments	S I	S I	S I	S	none
Business settings	S I U	S	S I U	S	none
Activity log	S	S	S	S	S (no money rows)
Notifications, push, preferences	own rows, team outbox	own rows, team outbox	unchanged	unchanged	unchanged
Delete quotes, jobs, invoices, payments	none	none	none	none	none

S select, I insert, U update, D delete. The "now" columns are read from the migrations; the "proposed" columns are copied from PR #23 and are a proposal only. The Manager column is kept only as an optional, proposed row: **Mark decided on 18 October 2026 that Thiago and Antonio both hold the Owner role with identical permissions and full Owner Dashboard access, and that no Manager role is needed for now.** That is a decision, not something seen in the code or the live database: which accounts actually hold `owner` in Supabase is **not verified**. Remaining open decisions: A (may staff see customer phone and e-mail), C (who may send or void invoices and record payments; with two equal Owners this is now an Owner-only question), D (may staff update job status). Decision B is closed (no Manager).

8.3 Authentication and sessions

- Sign-in is a Supabase magic link sent to the e-mail the user types (`signInWithOtp`, `shouldCreateUser:false`, redirect back to the current page, `app.js:561`), so the form itself does not create new accounts; the server-side sign-up setting is not verified. Sessions are held by `supabase-js` in the browser (default local storage, persisted).
- The access check rejects a signed-in account without a profile (message shown, no data loaded). Unit-tested (`staff-access.test.mjs`) and the signed-out screen was observed.
- **Not verified:** the Supabase redirect allow-list and site URL that make the magic link land on `/operations/` (#16); session expiry settings; whether sign-ups are disabled in the Supabase project; password or multi-factor options. These are dashboard settings and not in the repository.

- There is no sign-out-everywhere or inactivity timeout in the code.

8.4 Client (customer) data protection

- Customer personal data (name, phone, e-mail, postcode, project brief, visit window) is stored in `consultation_requests`. Anonymous visitors cannot read it; staff can.
- Uploaded photos would be private in the `project-uploads` bucket with 10-minute signed links; no code on `main` writes uploads (see Backend).
- There is no privacy notice or retention rule on the site (NOT IMPLEMENTED), no export or erase tool, and no data-processing record in the repository. Whether these are legally required is not assessed here.
- The notification e-mail to the internal address contains the enquiry summary. Delivery needs the Resend API key and sender names listed in Backend.
- This book's screenshots contain only the demo-mode fictional records and the public site; no production data was read.

8.5 Secrets handling (names only)

Server-side secret **names** are listed in the Backend chapter (for example `SUPABASE_SERVICE_ROLE_KEY`, `RESEND_API_KEY`, `ENQUIRY_RATE_LIMIT_SECRET`, the VAPID key pair). Values live in Supabase function secrets and Vault and were never opened for this book; no `.env` file was read. The browser receives only the project URL and the public publishable key through a generated `public-config.js`. The build refuses a service-role key or a production build without config (verified by `public-config.test.mjs` and by running the guard in CI order).

8.6 Content-Security-Policy, headers, dependencies

- **CSP / headers:** none on `main`. PR #27 adds a Report-Only CSP with tests; PR #8 adds headers and `robots.txt`. Neither is merged.
- **Dependencies:** the repository has no `package.json` and no lockfile, so there is no npm audit surface. Runtime dependencies are `supabase-js` (esm.sh), Google Fonts (CSS and font files), and Deno-side imports in the Edge Functions. A dependency vulnerability scan was **not run** (no paid or networked scanners).
- **Service worker:** registered with scope `./` (the `/operations/` folder); tested for its caching rules (`service-worker.test.mjs`).

8.7 Webhooks

There are no inbound webhooks (the only trace of the word is a `webhook` value allowed in the `notification_events.channel` check; no code uses it). When Stripe is built, signature verification and idempotent event handling are required; the design is in PR #25 (documentation only).

8.8 Pending weaknesses (no exploit detail)

#	Weakness	Priority	Issue	PR
1	Money and customer data are available to every signed-in staff account; the UI does not hide it either.	P0	#9, #28	#23, #42

#	Weakness	Priority	Issue	PR
2	Quote, job and invoice numbers are generated in the browser.	P0	#15, #29	#41
3	No CSP or security headers.	P1	#10	#27, #8
4	Third-party script loaded without integrity check.	P1	#11	#27
5	Notification retries have no upper limit.	P1	#13	#22
6	A wrongly recorded payment cannot be corrected; only an out-of-band database edit would do.	P1	#14	#43
7	Magic-link redirect configuration unverified.	P1	#16	
8	No automated browser-level tests for sign-in or role gating.	P1	#20, #36	#20
9	Unvalidated public claims (completed works, testimonials) could mislead customers.	P1	#12	#26, #8

Evidence: `E-11`, `E-12`, `E-19`, `E-21`, `E-23`, `E-24`, `E-32` *to* `E-36`.

8.9 Payments and domain configuration (pending)

Stripe configuration, the production domain and a professional business e-mail address are being configured by Mark on 19 October 2026. Until then they are **pending, configured by Mark on 19 Oct (not verified)**: no keys, domain names, addresses or webhook endpoints are recorded in this book, and none were checked. When they exist, CSP, webhook signature verification, the magic-link redirect allow-list (#16) and the e-mail sender settings must be re-checked against them.

SECTION 12

9. Testing and quality

9.0 How this book is built

Rebuild with `node scripts/master-docs/diagrams.mjs` (diagrams), `node scripts/master-docs/verify-evidence.mjs` (evidence inventory), then `node scripts/build-master-docs.mjs` (Live site and PDF). Node only, no network at build time; the PDF step needs a local Chrome or Chromium. Screenshots were captured with `puppeteer-core` against a local server and optimised to WebP; the capture scripts are in `scripts/master-docs/`.

9.1 Where each result comes from

Environment	What was done for this book	Result
Local (Node 24.22.0)	Full test suite and every CI step replayed on a clean worktree of `main@31a08f6`.	**183 of 183 pass**, 0 fail, 0 skipped (`E-37`).
Local, per Draft PR	Each Draft PR checked out and its suite run (table below).	All pass (`E-37`).
Preview (Vercel)	Not touched.	**Not verified.**
Production	Not touched; no production URL, account or data was opened.	**Not verified.**
Live Supabase	Not touched.	**Not verified.**

9.2 CI replay on main (Node 24)

Step (as in `.github/workflows/quality.yml`)	Result
`node --test` over the tracked test files	exit 0: 183 tests, 183 pass
`node --check` over 29 listed JavaScript files	0 failures
Inline script parse (`index.html`: 1 block; `operations/index.html`: 0)	exit 0
Production build with no config must fail	failed as expected
Build with the fictional CI config	exit 0
`check-public-build.mjs`	"Verified public build root: assets, index.html, operations, public-config.js"

CI itself runs only on pushes to `main` and on pull requests that target `main`; PRs stacked on other branches do not trigger it. The last remote CI status was not read for this book.

9.3 Draft PR suites (run locally on Node 24)

PR	Branch	Tests	Pass	Skipped	Notes
#8	audit/final-production-audit-2026-10-17	186	186	0	

PR	Branch	Tests	Pass	Skipped	Notes
#19	frame/17-master-docs	187	187	0	
#20	frame/16-auth-tests	197	197	0	
#22	frame/13-notifications	201	201	0	5 skipped without the optional local Postgres engine; 0 with it
#23	frame/9-permissions	200	200	0	11 skipped without it; 0 with it (real RLS on a throwaway local database)
#25	frame/18-stripe-design	186	186	0	
#26	frame/12-public-site-main	189	189	0	
#27	frame/10-csp-sri-main	193	193	0	
#41	frame/15-server-numbering	199	199	0	6 skipped without the engine; 0 with it
#42	frame/28-role-gating	213	213	0	
#43	frame/14-payment-reversals	200	200	0	8 skipped without the engine; 0 with it

Passing tests in a PR say that PR's code matches its own tests. They say nothing about whether the PR is approved, merged or applied.

9.4 Test inventory on main

31 test files, 182 `test()` calls by static count (the runner reports 183; one test is declared in a way the counter misses).

Area	Files (tests)
Staff app logic	activity-label (3), assignment (5), availability-list (14), business-records (4), calendar-records (4), datetime-local (2), enquiry-workspace-view (7), enquiry-workspace (10), invoice-document (5), mutation-result (2), notification-badge (5), notification-centre (8), payment-idempotency (4), pipeline (2), project-model (2), push-support (4), push-target (3), quote-readiness (4), service-worker (4), staff-access (3), today-view (2), workflow (3)
Build	scripts/public-config (6)
Database (static migration reading)	business-migration (9), config (3), notification-centre-migration (4), notification-retry (8)
Edge Functions (handler logic with mocks)	submit-enquiry (27), push-new-enquiry (17), retry-notifications (8)

9.5 Gaps

- No test runs the public page in a browser, drives the staff app against a database, or exercises Supabase Auth, RLS, Edge Functions on Deno, or a real push or e-mail delivery.

- The migration tests read SQL text; the only real-database RLS tests are in Draft PRs #22, #23, #41, #43.
- No accessibility, performance or visual regression tests. This book's headless screenshots are observations, not a test suite.
- No coverage measurement is configured.

Evidence: `E-22`, `E-37` *to* `E-40`, `E-56`.

SECTION 13

10. Roadmap



Roadmap P0 to P3 with issue and PR numbers

Titles starting `P0`, `P1`, `P2` are the issue's own label. Issues without one are placed by this book and marked *proposed*. All PRs below are Draft and unmerged. Nothing was merged, applied or deployed for this book.

10.1 P0 : before real money or more than one staff member

Item	Issue	PR	State
Audit and restrict access to customer, quote, payment and financial data	#9	#23 (RLS draft, unapplied)	Draft
Hide money UI from roles without access	#28	#42	Draft
Server-side numbering for quotes, jobs, invoices	#29 (extends #15)	#41	Draft
Verify real contact details and "Completed works" with Mark *(proposed P0 for public trust)*	#12	#26, #8	Waiting for Mark

10.2 P1

Item	Issue	PR
Confirm-guard parity for status selects	#30	
Owner-only user management (two equal Owners today; Manager role not needed for now)	#31	
Customer entity and de-duplication	#32	
Finance panel v2	#33	
Corrected invoice / credit note flow	#34	

Item	Issue	PR
Activity history per record	#35	
App flow test harness for money flows	#36	#20
CSP Report-Only *(proposed)*	#10	#27, #8
Self-host supabase-js *(proposed)*	#11	#27
Cap notification retries, dead-letter state *(proposed)*	#13	#22
Append-only payment reversals *(proposed)*	#14	#43
Verify magic-link redirect allow-list *(proposed)*	#16	

10.3 P2

Item	Issue	PR
Business settings v2	#37	
Printable quote document and manual send record	#38	
Quote expiry job	#39	
Admin manual and deploy/rollback checklist	#40	

10.4 P3 *(proposed)*

Item	Issue	PR
Stripe design and 12 commercial decisions (no implementation); Stripe config pending, configured by Mark on 19 Oct (not verified)	#18	#25
Master project document	#17	#19
Master Book and Live Master (this work)	#44	

10.5 Suggested order (FRAME recommendation, not a decision)

1. Decided 18 Oct: Thiago and Antonio are both Owners with identical access, no Manager role for now. Mark still answers A, C, D (permissions) and confirms the public content (#12). On 19 Oct Mark configures Stripe, the production domain and a professional business e-mail (pending, not verified).
2. PR #8 (audit hardening) first, then #27 and #26, which were rebuilt to be independent of it.
3. PR #20 (auth test harness), then #42 (role-aware UI).
4. Only after #42 is live: apply the permissions migration from #23.
5. #41 (numbering) and #43 (reversals), each with its migration reviewed, then #22 (retry cap).
6. P1 and P2 items; Stripe only after the commercial decisions in #25.

Merge and migration application stay with Mark; this book does neither.

Evidence: issue and PR titles read from GitHub on 18 October 2026; Draft PR suites `E-39`, `E-40`.

SECTION 14

11. Pending confirmation and not verified

11.1 Needs Mark (owner decisions and content)

#	Item	Why it is pending	Where
1	Real phone number and e-mail for the public site	None are published; nothing may be invented.	website.md, #12
2	"Completed works": are the four projects real, and are the photos and descriptions Form & Frame's own?	Content is on `main` but unvalidated.	website.md, #12, PR #26
3	Testimonials ("sample review" text)	Placeholder wording visible on the public page. Remove or replace with real reviews.	website.md, PR #8
4	Business claims in the code: address "Unit 4, Buckingham Ave, Slough SL1", "5-7 days typical completion", "signed off before build", "One Slough workshop", postcode coverage, "free measured survey", "within one working day", the price guide and the "£££" price-range metadata	Nothing in the repository proves them.	website.md
5	Which public address is the real one (a `*.vercel.app` name appears in the metadata)	Not confirmed.	website.md
6	Permission decisions A, C, D (staff seeing customer contact details; who sends or voids invoices and records payments; staff job status updates). **Decided 18 Oct: Thiago and Antonio both hold Owner with identical permissions; no Manager role for now (decision B closed).**	Needed before PR #23 can be finalised.	security.md
7	Stripe: the 12 commercial decisions and the Stripe configuration	**Pending, configured by Mark on 19 Oct (not verified).** Design only; no values recorded.	integrations.md, PR #25
7b	Production domain and professional business e-mail	**Pending, configured by Mark on 19 Oct (not verified).** No domain or address is recorded; the public site still shows no contact e-mail.	website.md, #12
8	Whether to publish a privacy notice and terms	Nothing exists.	security.md
9	Merge order of the Draft PRs and PR #8	Owner decision.	roadmap.md

11.2 Could not be verified in this work

Item	Reason
Production or Preview behaviour (live site, Vercel settings, environment variable values, deployments)	Not accessed, by instruction.
Live Supabase project: applied migrations, RLS as deployed, Auth settings and redirect allow-list, sign-up setting, Edge Function secrets, cron jobs, Storage buckets	Not accessed; the repository is the only source.

Item	Reason
Signed-in staff screens (quotes, jobs, invoices, payments, settings, notification centre, activity history)	Need real login and data; shown as *not verifiable*, never mocked.
Real e-mail (Resend) and Web Push delivery	Needs live secrets and devices.
Edge Functions running on Deno	Tests use Node with mocks.
Remote CI status of `main` and PRs	Not read; CI was replayed locally instead.
Dependency vulnerability scan	No networked scanners were used.
Accessibility, performance and cross-browser behaviour	Only headless Chrome (155) was used.
External links	Checked only where reachable from this machine; failures are in the quality report.

11.3 Observations to confirm

- Money screens visible to every staff account: see security.md. Needs a decision, not just a fix.
- `#desk` is not an anchor in the staff page although some copy points to it.
- Notification retries are unbounded on `main` (#13).
- The count of 182 test declarations versus 183 reported tests is a counting difference only.

SECTION 15

12. Coverage summary

12.1 What is documented

Area	Documented	Notes
Identity and design system	Yes	Public and staff palettes, fonts, components, responsive rules from the CSS.
Platform map and architecture	Yes	17 diagrams.
Public site	All sections, at desktop and mobile	Placeholder content flagged.
Owner Dashboard	Modules M1 to M14	Only demo-mode screens are shown; the rest are "not verifiable".
Backend, database, integrations	Yes	From the ten migrations and three Edge Functions.
Journeys	Customer, owner, staff	Broken and missing steps marked.
Feature matrix	49 rows	Statuses limited to the seven allowed.
Security	Yes	No exploit detail.
Testing	Local runs on Node 24; Preview and production not verified.	
Roadmap	Issues #9 to #18, #28 to #40, PRs #8, #19 to #27, #41 to #43	
Evidence inventory	57 rows, re-checked on each build	

12.2 Screenshots and diagrams

Type	Count
Public site, desktop 1440	13 (full page, fold, dark fold, 8 section crops, chat open, form validation)
Public site, mobile 390	11 (fold, 8 section crops, nav open, chat open)
Staff app demo mode, desktop 1440	10
Staff app demo mode, mobile 390	7
Staff sign-in screen (no data), desktop and mobile	2
Total screenshots	**43** (WebP, about 3 MB)
Diagrams (SVG, generated from `diagrams.mjs`)	17

Public screenshots come from the repository's own build with the CI fictional configuration, served locally. Staff screenshots are DEMO MODE with the built-in fictional data; they are captioned as such.

12.3 Tests

183 of 183 pass on `main` (Node 24); Draft PR suites pass (see Testing). No live, Preview or production test.

12.4 Not covered

Production, Preview, live Supabase, signed-in money screens, and real delivery of e-mail or push: see Pending confirmation.

SECTION 16

Evidence inventory

Generated by `scripts/master-docs/verify-evidence.mjs` on the working tree of the commit named in the README. Each row is re-checked every time the script runs: it fails if a file or pattern has moved, so a row never silently points at nothing. `E-nn` markers in the chapters point here. Rows marked "command" or a stored log refer to commands run for this book; the logs are in `docs/master/assets/evidence/`.

How a chapter claim is justified:

- **Code facts** point at a file and the first line where the pattern occurs.
- **Test and run results** point at stored logs.
- **Observations** (screenshots, headless runs) are described in the chapter next to the image; the capture scripts are in `scripts/master-docs/`.
- **Not verified** items are listed in pending-confirmation.md and are never backed by an E-row.

ID	Chapter	Claim	Evidence (file:line or command)
E-01	README	Version, commit and branch of the analysed code	`git rev-parse HEAD` = `31a08f6ee1fa507d4f78c30ede78c4b1fda746a4`
E-02	Architecture	Build copies an explicit list of files into dist/public (docs/ is not on it)	`scripts/build-public.mjs:17`
E-03	Architecture	Vercel builds with node scripts/build-public.mjs and serves dist/public	`vercel.json:2`
E-04	Website	Public page sections: drawing, survey, specify, process, works, testimonials, request, footer	`index.html:1084`
E-05	Website	Form submit is the single fetch to submit-enquiry; spec in localStorage ff_spec; rule-based assistant	`index.html:2837`
E-06	Website/Backend	submit-enquiry validates, caps the brief at 12,000 characters and handles 429	`supabase/functions/submit-enquiry/handler.mjs:173`
E-07	Backend	Enquiry rate limit is consumed through a service-role-only function with a secret	`supabase/functions/submit-enquiry/handler.mjs:176`
E-08	Backend	Internal e-mail goes through Resend only if configured	`supabase/functions/submit-enquiry/handler.mjs:261`
E-09	Owner Dashboard	Demo mode starts when no FF_OPERATIONS_CONFIG is present	`operations/app.js:484`
E-10	Owner Dashboard	Realtime listens to row changes on the workflow tables	`operations/app.js:549`
E-11	Owner Dashboard	Sign-in is signInWithOtp with shouldCreateUser:false	`operations/app.js:561`
E-12	Owner Dashboard	supabase-js imported from esm.sh at an exact version, no integrity check	`operations/app.js:1`
E-13	Owner Dashboard	Staff workspace reads request_uploads and creates 10-minute signed URLs	`operations/app.js:878`

ID	Chapter	Claim	Evidence (file:line or command)
E-14	Owner Dashboard	Payment recording uses a per-attempt recording_key	`operations/payment-idempotency.mjs:16`
E-15	Owner Dashboard	Browser-generated quote/job/invoice numbers	`operations/app.js:1129`
E-16	Owner Dashboard	Access check accepts owner and staff only	`operations/staff-access.mjs:10`
E-17	Integrations	Stripe: only a 'stripe' payment-method value exists (no library, key, endpoint or webhook)	`supabase/migrations/20261005130000_business_management_backend.sql:123`
E-18	Backend	Three Edge Functions exist: submit-enquiry, push-new-enquiry, retry-notifications	`supabase/functions/retry-notifications/index.ts:4`
E-19	Backend/Security	Server secret names read with Deno.env.get / env(…) (names only recorded, no values)	`supabase/functions/push-new-enquiry/index.ts:6`
E-20	Backend	Retry worker and outbox: retry scheduled via Vault-backed cron; no attempt cap on main	`supabase/schedule_notification_retries.sql:1`
E-21	Architecture/Security	Public config guards: production build fails without config; service-role key refused	`scripts/public-config.mjs:30`
E-22	Architecture/Testing	CI runs on push to main and PRs to main with Node 24	`.github/workflows/quality.yml:25`
E-23	Security/Architecture	vercel.json has no headers block (no CSP)	`vercel.json:3`
E-24	Security/Design	Google Fonts and esm.sh are third-party requests; no CSP meta tag	`index.html:15`
E-25	Design	CSS design tokens (colours, radii, shadows) in the public page	`index.html:21`
E-26	Architecture	Staff app third-party hosts	`operations/index.html:15`
E-27	Design	Staff PWA manifest and icon set	`operations/manifest.webmanifest:11`
E-28	Database	profiles.role and is_staff() helper	`supabase/migrations/20260906110000_operations_hub.sql:74`
E-29	Database	Appointment overlap: exclusion constraint on active appointments	`supabase/migrations/20261005130000_business_management_backend.sql:76`
E-30	Database	Calendar trigger blocks appointments over blocked time	`supabase/migrations/20261005130000_business_management_backend.sql:281`
E-31	Integrations	Stripe absent: repository search for 'stripe' returns only the payment-method value (command re-run by this script)	command `git grep -il stripe -- index.html operations supabase/functions scripts/build-*.mjs scripts/public-config.mjs` returned `operations/enquiry-workspace-view.test.mjs`
E-32	Security	Magic-link sign-in and redirect to current page	`operations/app.js:561`
E-33	Security	RLS enabled on tables; anonymous has no policies; intake via service role	`supabase/migrations/20260906110000_operations_hub.sql:84`

ID	Chapter	Claim	Evidence (file:line or command)
E-34	Security	Policies use is_staff(); business_settings writes are owner-only; no delete policies on money tables	`supabase/migrations/20261009100000_invoice_business_settings.sql:29`
E-35	Security/Database	Overpayment, status-machine and locking triggers	`supabase/migrations/20261005130000_business_management_backend.sql:312`
E-36	Security	The only 'webhook' trace is a channel value in a check constraint	`supabase/migrations/20260906110000_operations_hub.sql:63`
E-37	Testing	Full test run on main, Node 24: 183 pass / 0 fail	`docs/master/assets/evidence/main-node-test.log:186`
E-38	Testing	CI step replay on main	`docs/master/assets/evidence/main-ci-replay.log:18`
E-39	Testing	Per-PR suite results	`docs/master/assets/evidence/pr-suites.tsv:5`
E-40	Testing	Per-PR results with the local Postgres engine (PGlite)	`docs/master/assets/evidence/pr-suites-pglite.txt:2`
E-41	Database	Realtime publication required by the business migration	`supabase/migrations/20261005130000_business_management_backend.sql:592`
E-42	Database	Notification outbox table with channel check	`supabase/migrations/20260906110000_operations_hub.sql:60`
E-43	Backend	Push sender claims events server-side only	`supabase/migrations/20261008120000_workflow_push_notifications.sql:4`
E-44	Database	Notification centre: reads and preferences tables, own-row policies	`supabase/migrations/20261016120000_notification_centre_and_preferences.sql:19`
E-45	Database	Invoice seller settings table	`supabase/migrations/20261009100000_invoice_business_settings.sql:4`
E-46	Database	Optional site assessment flag	`supabase/migrations/20261010100000_optional_site_assessment.sql:1`
E-47	Database	Rate-limit tables revoked from public roles	`supabase/migrations/20261009150000_public_enquiry_rate_limits.sql:26`
E-48	Database	SECURITY DEFINER functions pinned to an empty search path	`supabase/migrations/20261007100000_harden_definer_search_paths.sql:5`
E-49	Database	Retryable enquiry notifications: claim function, server role only	`supabase/migrations/20261006100000_retryable_enquiry_notifications.sql:17`
E-50	Database	Enquiry hardening migration	`supabase/migrations/20261004120000_harden_enquiry_submission.sql:4`
E-51	Owner Dashboard	Invoice document renderer	`operations/invoice-document.mjs:9`
E-52	Owner Dashboard	Today view and metrics logic	`operations/today-view.mjs:1`
E-53	Owner Dashboard	Calendar record selection	`operations/calendar-records.mjs:12`
E-54	Owner Dashboard	Notification centre logic	`operations/notification-centre.mjs:4`
E-55	Owner Dashboard	Service worker registered with scope ./	`operations/app.js:520`

ID	Chapter	Claim	Evidence (file:line or command)
E-56	Testing	Test file with real tests for the submit handler	`supabase/functions/submit-enquiry/handler.test.mjs:138`
E-57	Docs	AGENTS.md rules the book respects (no secrets, real content only)	`AGENTS.md:1`

Rows: 57. Missing: 0.

SECTION 17

Changelog

1.0.0 : 18 October 2026

First complete Master Book and Live Master, written for FRAME issue #44 against `main` at `31a08f6ee1fa507d4f78c30ede78c4b1fda746a4`.

- Chapters, 17 diagrams, 43 screenshots, feature matrix, security and testing chapters, roadmap, evidence inventory, build script.
- Corrections made while writing, after checking the code: staff module count is 21 (one without a test); enquiries have no "set status" action; appointment double-booking is prevented by an exclusion constraint (not only by the blocked-time trigger); the staff workspace only reads `request_uploads`, nothing on `main` writes uploads; a `#desk` anchor does not exist.

Rules for later versions: bump the version in the README, record the new commit SHA, rerun `verify-evidence.mjs` (it fails if a cited file or pattern moved), regenerate screenshots if the UI changed, and list the change here.

Owner decisions recorded (18 October 2026, after first draft)

- Thiago and Antonio both hold the Owner role with identical permissions and full Owner Dashboard access; no Manager role for now (Manager kept only as an optional proposed row).
- Stripe configuration, production domain and professional business e-mail: pending, configured by Mark on 19 Oct (not verified); no values recorded.